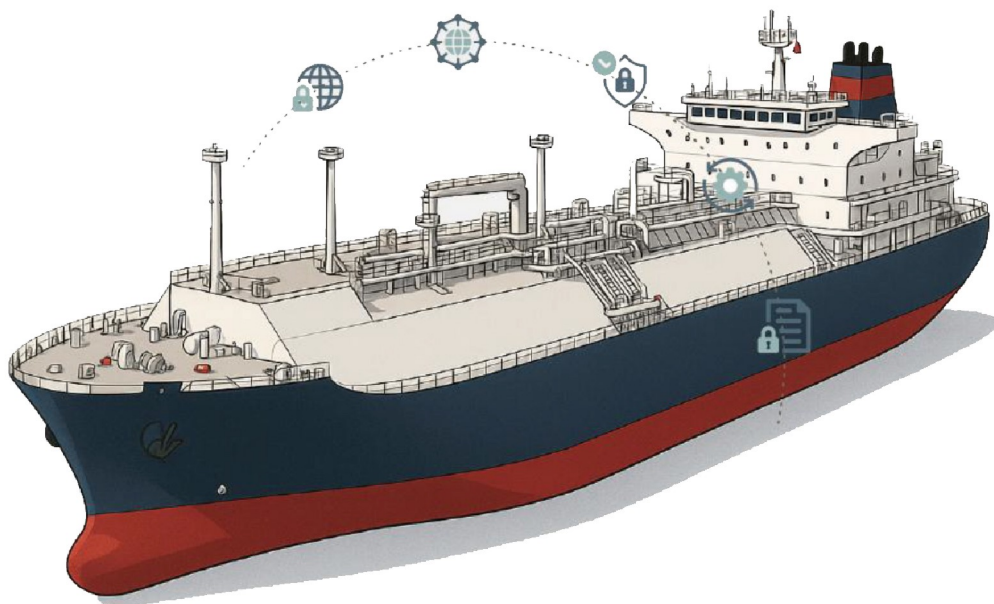


스마트선박 보안모델 해설서 및 사례집



과학기술정보통신부



한국인터넷진흥원



유의 사항

본 해설서는 스마트선박 보안모델의 사이버보안 강화를 위한 기술적, 관리적 보호조치에 대한 이해를 돕기 위해 발간된 것입니다.

본문에 수록된 설정 방안, 절차, 시나리오는 보편적인 권고사항으로, 실제 적용 시에는 각 선박의 고유한 시스템 아키텍처, 운영 환경, 관련 법규 및 선급 규정을 종합적으로 고려하여야 합니다.

본 해설서는 절대적인 기준이 아니며, 최신 보안 위협과 기술 발전에 따라 지속적으로 보완되어야 합니다. 따라서 본 해설서의 내용을 참조하되, 각 운영 주체의 책임하에 최적의 보안 방안을 수립하고 이행할 것을 권고합니다.



CONTENTS

01 개 요	5
1.1 목적	6
1.2 활용 방법	7
02 보안모델과 해설서의 연계구조	9
2.1 '무엇을(WHAT)'에서 '어떻게(HOW)'로: 개념적 연관성 및 통합 아키텍처	10
2.2 PDCA 기반 통합 적용 절차	11
03 6대 보안 영역별 기술 해설	15
3.1 인증 (Authentication)	17
3.2 접근/권한 통제 (Access/Privilege Control)	22
3.3 암호화 (Encryption)	27
3.4 부인방지 (Non-repudiation)	32
3.5 가용성 (Availability) 및 사이버 복원력 (Cyber Resilience)	36
3.6 관리체계 (Management System)	41
04 시나리오 기반 Best Practice	49
4.1 인증: 원격 접근 계정 탈취 위협 대응을 위한 MFA 도입	50
4.2 접근·권한 통제: 랜섬웨어의 내부망 확산(Lateral Movement) 방지를 위한 네트워크 분할	52
4.3 암호화: 중간자 공격(MITM) 방지를 위한 운항 데이터 전송 암호화	54
4.4 부인방지: GPS 스푸핑 의심 사고의 명확한 원인 규명	56
4.5 가용성: 주 ECDIS 시스템 장애 대응 모의 훈련	58
4.6 관리체계: 해운사의 CSMS 도입 및 이행	60
05 자체평가를 위한 보안점검 체크리스트	63
5.1 인증 (Authentication)	64
5.2 접근/권한 통제 (Access/Privilege Control)	65
5.3 암호화 (Encryption)	65
5.4 부인방지 (Non-repudiation)	66
5.5 가용성 (Availability)	67
5.6 관리체계 (Management System)	67
06 부 록	69
1 스마트선박 보안 솔루션 맵 및 해설	70
2 IACS UR E26/E27 요구사항-보호조치 연계표	77
3 스마트선박 보안모델 적용 사례집	80
4 용어 정의	170

01

개 요

1.1 목적	6
1.2 활용 방법	7

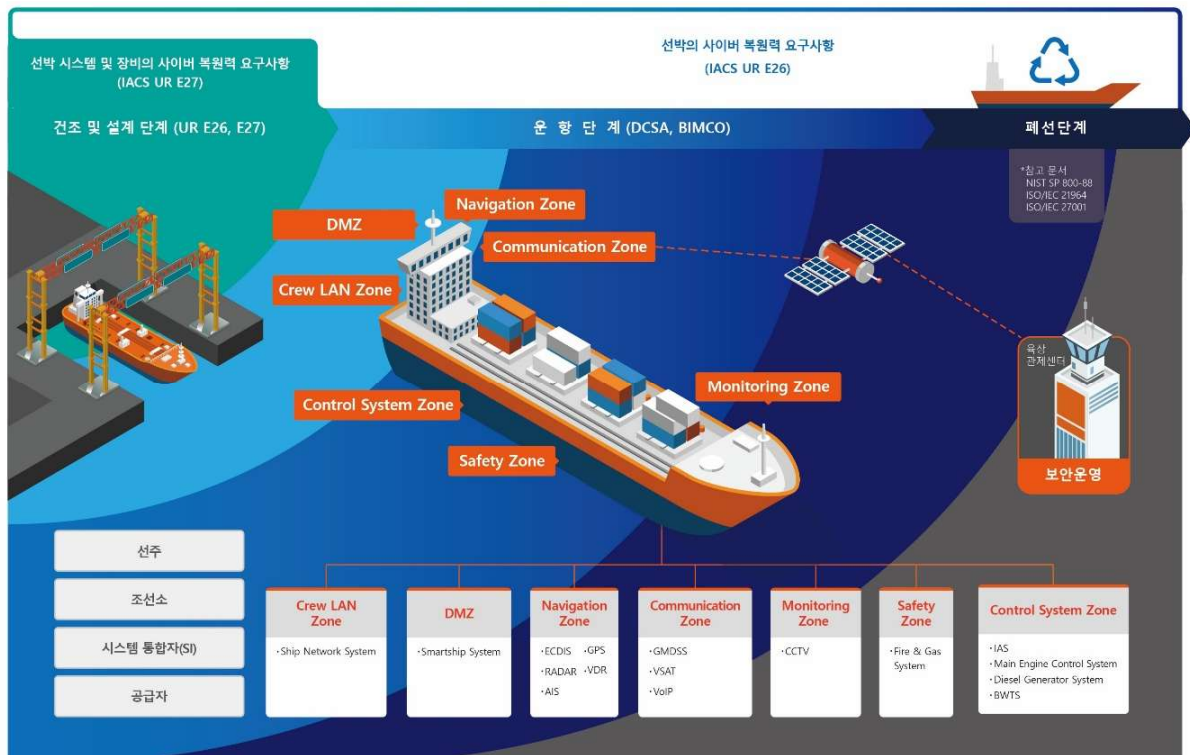
1.1 목적

본 『스마트선박 사이버보안 모델 해설서 및 사례집』(이하 '해설서')는 앞서 발간된 『스마트선박 보안모델』에서 제시한 선박 사이버보안 프레임워크와 보안 요구사항을 현장에서 효과적으로 적용할 수 있도록 지원하는 데 그 목적이 있다. 이 문서는 이론과 실제의 간극을 메우는 포괄적인 이행 지침서(Implementation Guide)로서의 목적을 가진다.

『스마트선박 보안모델』이 스마트선박의 자산, 위협, 보안 아키텍처 및 요구사항 등 "무엇을(WHAT)" 보호하고 준수해야 하는지에 대한 전략적 방향성을 제시했다면, 본 해설서는 해당 요구사항을 "어떻게(HOW)" 구현하고 운영할 것인지에 대한 상세한 기술적 지침, 실행 가능한 절차, 그리고 검증 가능한 실증 사례(Best Practice)를 제공한다.

이를 통해 해운사, 조선소, 시스템 통합(SI) 기업, 기자재 제조사 등 스마트선박의 전 생애주기에 걸친 모든 이해관계자들이 일관된 보안 수준을 확보하고, 국제해사기구(IMO)의 사이버 리스크 관리 지침(MSC.428(98)) 및 국제선급연합회(IACS)의 공통규칙(UR) E26, E27과 같은 강화되는 국제 규제에 효과적으로 대응할 수 있도록 돕는 것을 최종 목표로 한다.

그림 1-1 ▶ 선박 생애주기와 보안 요구사항



* Note : 본 그림의 Security Zone 구성은 보안 모델의 이해를 돕기위한 개념적 모델입니다.

1.2 활용 방법

본 해설서는 사용자의 역할과 목적에 따라 맞춤형 활용이 가능하도록 구성되었다. 각 이해관계자는 자신의 핵심 책임 영역에 맞춰 특정 장을 집중적으로 참고함으로써 실무적 가치를 극대화할 수 있다.

그림 1-2 ▶ 스마트선박의 다양한 이해관계자



🔍 해운사(Shipping Companies)를 위한 활용 예시

해운사는 스마트선박 사이버보안의 최종 운영 주체로서, 본 해설서를 사이버보안 관리체계(CSMS, Cyber Security Management System) 수립을 위한 청사진으로 활용해야 한다. 특히 제3장(기술 해설), 제4장(Best Practice), 제5장(보안점검 체크리스트)을 중심으로 운영 단계의 보안 정책을 정의하고, 선원 교육 프로그램을 개발하며, 조선소 및 기자재 제조사의 보안 수준을 관리·감독하는 기준으로 삼아야 한다.

❶ 조선소(Shipyards)를 위한 활용 예시

조선소는 "설계 기반 보안(Secure by Design)" 원칙을 구현하는 핵심 주체이다. 제3장(기술 해설)과 제4장(Best Practice)을 기술 지침으로 삼아, IT/OT 네트워크 분리와 같은 보안 아키텍처를 설계하고, 시스템 강화(Hardening) 조치를 이행하며, 최종적으로 해운사에 안전한 선박을 인도하기 위한 **'사이버보안 및 복원력 프로그램'**을 준비하는 데 본 해설서를 활용할 수 있다.

❷ 시스템 통합(SI)/기자재 제조사(System Integrators/Equipment Manufacturers)를 위한 활용 예시

SI 기업과 기자재 제조사는 "기본 설정부터 안전하게(Secure by Default)" 원칙을 준수해야 하는 공급망의 핵심 요소이다. 제3장(보안 영역별 기술 해설)를 통해 자사 제품이 충족해야 할 보안 요구사항(예: MFA 옵션 제공, 안전한 코딩 적용)을 명확히 인지하고, 취약점 패치 제공과 같은 생애주기 전반의 기술 지원 의무를 이행하기 위한 내부 프로세스를 수립하는 데 활용해야 한다.

❸ 선급/검사기관(Classification Societies/Auditors)를 위한 활용 예시

선급 및 검사기관은 본 해설서를 선박의 사이버보안 상태를 평가하고 인증하기 위한 기준 참고서(Baseline Reference)로 활용할 수 있다. 특히 제5장(보안점검 체크리스트)과 부록의 상세 내용을 통해 IACS 공통규칙(UR) 및 기타 국제 표준에 대한 선박의 준수 여부를 체계적이고 객관적으로 감사하는 데 필요한 기준과 검증 방법을 확보할 수 있다.

2.1 '무엇을(WHAT)'에서 '어떻게(HOW)'로:

개념적 연관성 및 통합 아키텍처 10

2.2 PDCA 기반 통합 적용 절차 11

2.1 '무엇을(WHAT)'에서 '어떻게(HOW)'로: 개념적 연관성 및 통합 아키텍처

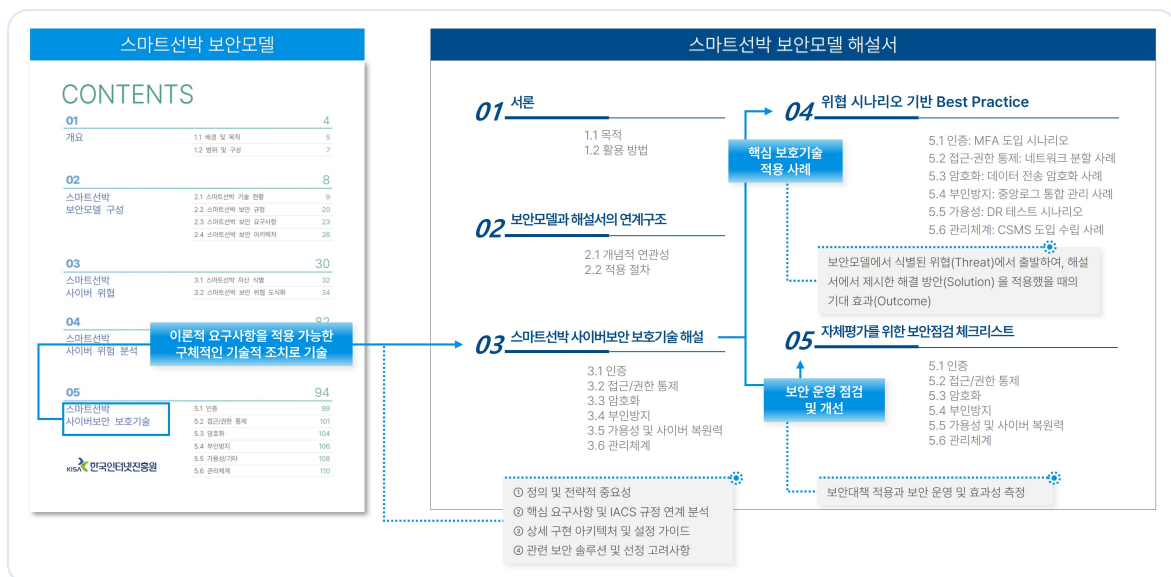
본 이행 가이드의 핵심 가치는 선행된 『스마트선박 보안모델』과의 유기적인 연계성에 있다. 두 문서는 분절된 결과물이 아니라, 하나의 통합된 사이버보안 프레임워크를 구성하는 전략(WHAT)과 실행(HOW)의 양면이다.

『스마트선박 보안모델』은 스마트선박이 보유한 정보기술(IT) 및 운영기술(OT) 자산을 식별하고(예: ECDIS, IAS, Smartship System), 이들 자산에 가해질 수 있는 사이버 위협(예: 랜섬웨어, GPS 스푸핑)을 분석하여, 이를 방어하기 위해 반드시 지켜야 할 거시적인 보안 요구사항을 정의한다.

본 해설서는 이 요구사항을 이어받아 구체적인 실행 방안으로 전환하는 역할을 수행한다. 예를 들어, 『스마트선박 보안모델』이 "중요 시스템 원격 접근 시 다중 인증(MFA)을 적용해야 한다"는 요구사항을 제시했다면, 본 해설서는 MFA를 구현하기 위한 기술 옵션(OTP, PKI 인증서 등), 적용 아키텍처, 상세 설정 방안, 그리고 실제 도입 시나리오까지 상세히 기술한다.

이러한 연계 구조는 아래 [그림 2-1]과 같이 도식화할 수 있다. 『보안모델』의 위협 분석은 본 해설서의 보호기술(제3장) 선정의 근거가 되며, 이 보호기술은 Best Practice(제4장)를 통해 현실적인 적용 가능성을 입증하고, 최종적으로 보안점검 체크리스트(제5장)를 통해 그 이행 여부를 검증받는 선순환 구조를 형성한다.

그림 2-1 ▶ 『스마트선박 보안모델』과 본 『해설서 및 사례집』의 연계 구조

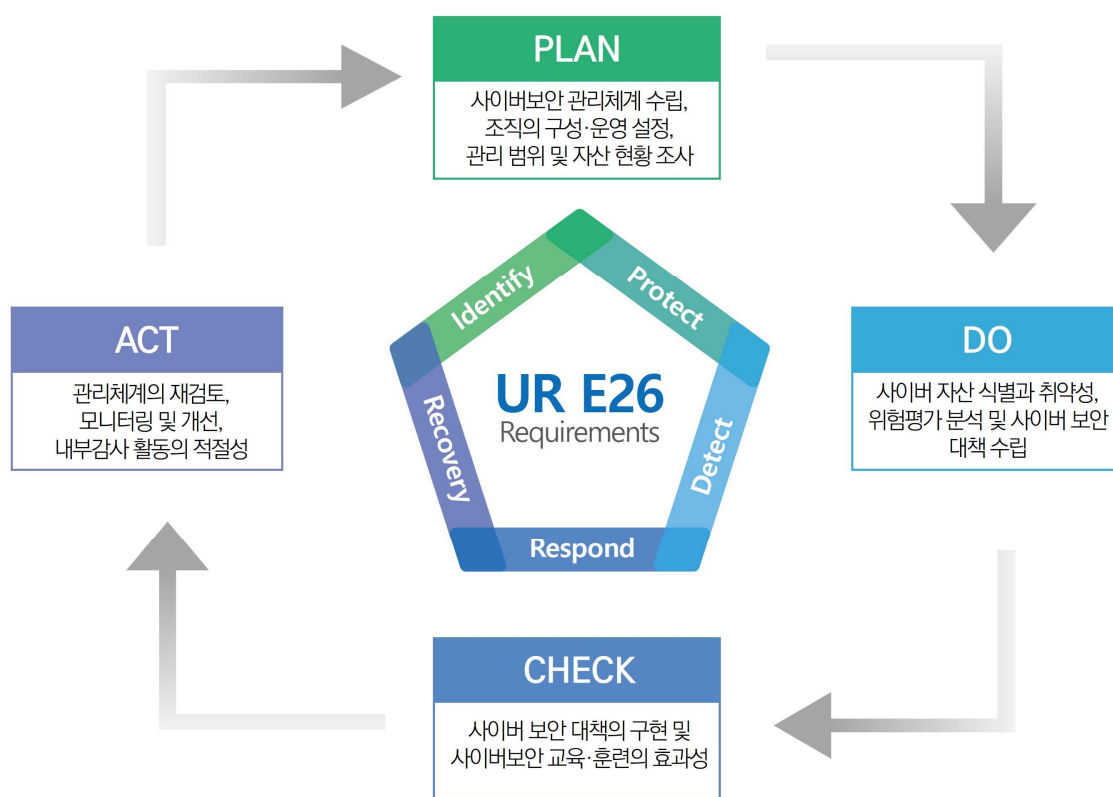


2.2 PDCA 기반 통합 적용 절차

스마트선박의 사이버보안을 체계적으로 강화하기 위해, 본 이행 가이드는 국제적으로 통용되는 관리체계 프레임워크인 **PDCA(Plan-Do-Check-Act) 사이클**에 기반한 통합 적용 절차를 제시한다. 이는 일회성 조치가 아닌, 지속적인 개선을 목표로 하는 동적인 프로세스이다. 사용자는 다음의 5단계 절차를 통해 『스마트선박 보안모델』과 본 해설서를 유기적으로 활용할 수 있다.

본 절차는 스마트선박의 사이버보안을 위해 PDCA(Plan-Do-Check-Act) 방법론과 IACS UR E26의 5가지 핵심 기능(식별, 보호, 탐지, 대응, 복구)을 통합하고, 『스마트선박 보안모델』에서 제시하는 사이버보안 관리체계(CSMS)를 구축하여 지속적으로 관리하는 것을 목표로 한다.

그림 2-2 ▶ 스마트선박 보안 적용 절차 (PDCA 모델 연계)



2.2.1 PLAN (계획): 사이버보안 관리체계 기반 수립 및 위험 평가

○ 활동:

- 범위 및 목표 설정: 조직의 사이버보안 목표와 관리 범위를 명확히 설정한다. 이를 위해 네트워크 구성도, 시스템 정보, 자산 목록 등 관련 문서를 수집하여 평가 대상을 구체화한다.
- 주요 자산 식별 및 위험 평가: 『스마트선박 보안모델』을 참조하여 운영 또는 건조하는 선박의 핵심 IT/OT 자산을 식별하고 중요도를 평가한다. 식별된 자산에 대해 발생 가능한 위협과 내재된 취약점을 분석하여 사이버 위험 수준을 평가하고, 위험도에 따른 우선순위를 결정한다.
- 보안 정책(Security Policy) 수립: 위험 평가 결과를 바탕으로 선박의 보안 관리 정책과 지침을 수립한

다. 여기에는 위협 관리 전략, 자산 관리, 위협 정보 수집 및 분석 절차 등이 포함된다. 또한, 식별된 위협을 완화하기 위한 기술적·관리적 보호 대책의 기본 방향과 조직의 역할과 책임(R&R)을 명확히 정의한다.

- UR E26 해설: 사이버보안 관리체계(CSMS)의 기반을 마련하는 핵심 과정이다. 특히 위협 평가를 통해 보호 대상을 명확히 하는 'Identify(식별)' 기능과, 평가된 위협을 기반으로 보안 정책과 보호 대책의 방향성을 수립하는 'Protect(보호)' 기능의 보호 범위를 식별하여 토대를 마련한다. 이는 선박 생애주기 전반에 걸친 보안 활동의 청사진을 그리는 단계이다.

2.2.2 DO (실행): 보안 대책 적용 및 역량 강화

● 활동:

- (Identify/Protect) 보안 설정(Security Configuration) 적용: PLAN 단계에서 수립된 정책에 따라 각 시스템(CBS)을 안전하게 설정한다. 방화벽 정책 적용, 네트워크 분리, 애플리케이션 보안 설정, 데이터 암호화, 취약점 관리 및 패치 적용 등 구체적인 보호조치를 구현한다.
- (Protect) 보안 교육(Security Training) 실시: 선박의 모든 선원 및 관련 인력이 사이버보안 위협을 인지하고 대응할 수 있도록 정기적인 교육을 시행한다. 피싱 및 소셜 엔지니어링 대응, 신규 위협 트렌드, 역할 기반 보안 교육 등을 통해 조직의 보안 인식을 제고한다.
- (Protect) 유지보수(Maintenance) 수행: 선박 시스템 및 소프트웨어에 대한 정기적인 유지보수와 보안 패치 적용을 수행한다. 시스템 업데이트 시 보안 취약점에 대한 사전 검토와 테스트를 진행하고, 자산 폐기 또는 반출 시 데이터가 완전히 삭제되도록 관리한다.
- UR E26 해설: 이 단계는 UR E26의 'Identify(식별)' 와 'Protect(보호)' 기능을 본격적으로 수행하는 과정이다. 위협 기반 접근 방식에 따라 구체적인 보안 통제 항목을 정의하고 시스템에 직접 구현하며, 인적 요소 강화를 위한 교육과 지속적인 시스템 관리를 통해 실질적인 방어 체계를 구축한다.

2.2.3 CHECK (점검): 보안 운영 및 효과성 측정

● 활동:

- (Protect/Detect) 보안 운영(Security Operations) 및 모니터링: 구현된 보안 대책이 정책에 따라 정상적으로 운영되는지 실시간으로 모니터링한다. 로그 및 이벤트 분석, 악성코드 탐지 및 분석, 침입 탐지 시스템 관리 등을 통해 신속하게 위협을 탐지하고 분석한다.
- (Detect) 효과성 평가: 『스마트선박 보안모델』의 체크리스트 등을 활용하여 구현된 보안 수준을 주기적으로 평가하고, 정기적인 보안 교육 및 모의 훈련의 효과성을 분석하여 감사에 대비한다.
- UR E26 해설 : 이 단계는 'Protect(보호)' 대책의 구현 상태와 'Detect(탐지)' 기능의 운영 효과성을 검증한다. UR E26은 구현된 보안 통제가 효과적으로 작동하는지, 그리고 보안 사고를 신속하게 탐지할 수 있는 능력을 갖추었는지 지속적으로 검증할 것을 요구한다. 주기적인 자체 평가 및 감사를 통해 이를 확인 한다.

2.2.4 ACT (조치): 사고 대응 및 지속적 개선

⦿ 활동:

- (Respond/Recover) 사고 대응(Incident Response): Check(점검) 단계에서 탐지된 위협이나 실제 발생한 사이버 사고에 대해 수립된 계획에 따라 신속하게 대응한다. 사고 대응 계획 실행, 침해사고 분석(디지털 포렌식), 사고 복구 절차 수행, 사후 분석 보고 및 교훈 도출 등의 활동을 포함한다.
- (Recover) 사고 발생 시 신속하게 시스템을 복구하고 운영을 정상화하기 위한 계획의 실효성을 검증하고 보완한다.
- 지속적 개선: 내부 감사, 모니터링, 사고 대응 결과 분석을 통해 도출된 개선 사항을 차기 계획(Plan)에 반영하여 사이버보안 관리체계(CSMS)를 지속적으로 개선하고 내재화한다.

- ⦿ UR E26 해설: 이 단계는 'Respond(대응)' 및 'Recover(복구)' 기능과 직접적으로 연결된다. 사고 대응 및 복구 능력의 적절성을 평가하고 개선하며, 이 모든 활동의 결과를 통해 CSMS를 강화한다. 사이버 복원력은 일회성 구축이 아닌, 변화하는 위협 환경에 맞춰 지속적으로 발전하는 보안 체계를 강조하며, ACT 단계는 이를 실현하는 핵심적인 과정이다.

6대 보안 영역별 기술 해설

3.1 인증 (Authentication)	17
3.2 접근/권한 통제 (Access/Privilege Control)	22
3.3 암호화 (Encryption)	27
3.4 부인방지 (Non-repudiation)	32
3.5 가용성 (Availability) 및 사이버 복원력 (Cyber Resilience) ...	36
3.6 관리체계 (Management System)	41



본 장에서는 『스마트선박 보안모델』에서 제시된 6대 보안 영역(인증, 접근/권한 통제, 암호화, 부인방지, 가용성, 관리체계)에 대한 상세 기술 해설을 제공한다. 각 절은 ①정의 및 전략적 중요성, ②핵심 요구사항 및 IACS 규정 연계 분석, ③상세 구현 아키텍처 및 설정 가이드, ④관련 보안 솔루션 및 선정 고려사항으로 구성된다. 이를 통해 이론적 요구사항을 실제 현장에서 적용 가능한 구체적인 기술적 조치로 전환하는 것을 목표로 한다.

그림 3-1 ▶ 스마트선박 보호기술 아키텍처

		IT 계층				OT/ICS 계층					
		Client	Network	Server	Application	Data(DB)	OT N/W	SCADA/HMI	PLC	Sensor	
UR E26 E27	인증			사용자 계정 생성 및 관리				업무용 단말기 인증			
		업무용 단말기 인증	외부 접속 시 이중 인증	인증정보의 평문정보 하드코딩 제한			외부 접속 시 이중 인증	인증 사용자계정 생성 및관리			
			최초 패스워드 변경 / Default 계정 사용 제한 / 사용자 계정 공동 사용 제한 / 안전한 패스워드 설정								
	접근 / 권한통제		비인가 접속제한	바이러스 백신 설치	로그인 실패사유 알림 금지			비인가 접속제한	로그인 실패사유 알림 금지		
			보안구역	관리자 역할 분리	최종 접속시간 표시			보안구역	최종 접속시간 표시	비인가 접속제한	비인가 접속제한
					접속시도 횟수 제한			유해 트래픽 차단	이동 저장매체 통제		
		이동저장 매체 통제	유해 트래픽 차단		다중 연결세션 차단			무선 네트워크 통제	접속시도 횟수 제한		무선 네트워크 통제
			무선 네트워크 통제	불필요한 서비스 금지				불필요한 서비스 금지			
									관리자 역할 분리		
			로그오프 또는 세션 종료								
	암호화	표준 암호화 준수	전송구간 암호화		표준 암호화 준수		전송구간 암호화	표준 암호화 준수		전송구간 암호화	
			사용자 인증정보 암호화				사용자 인증정보 암호화				
	부인 방지		시간 동기화					시간 동기화			
		로그인/ 로그오프 로깅	관리자/운영자 로깅			로깅 정보 위/변조 방지	관리자/운영자 로깅		로깅 정보 위/변조 방지	로그인/ 로그오프 로깅	
		계정/권한관리 내역 로깅				계정/권한관리 내역 로깅					
가용성 / 기타		백업 및 복구									
			대체전원								

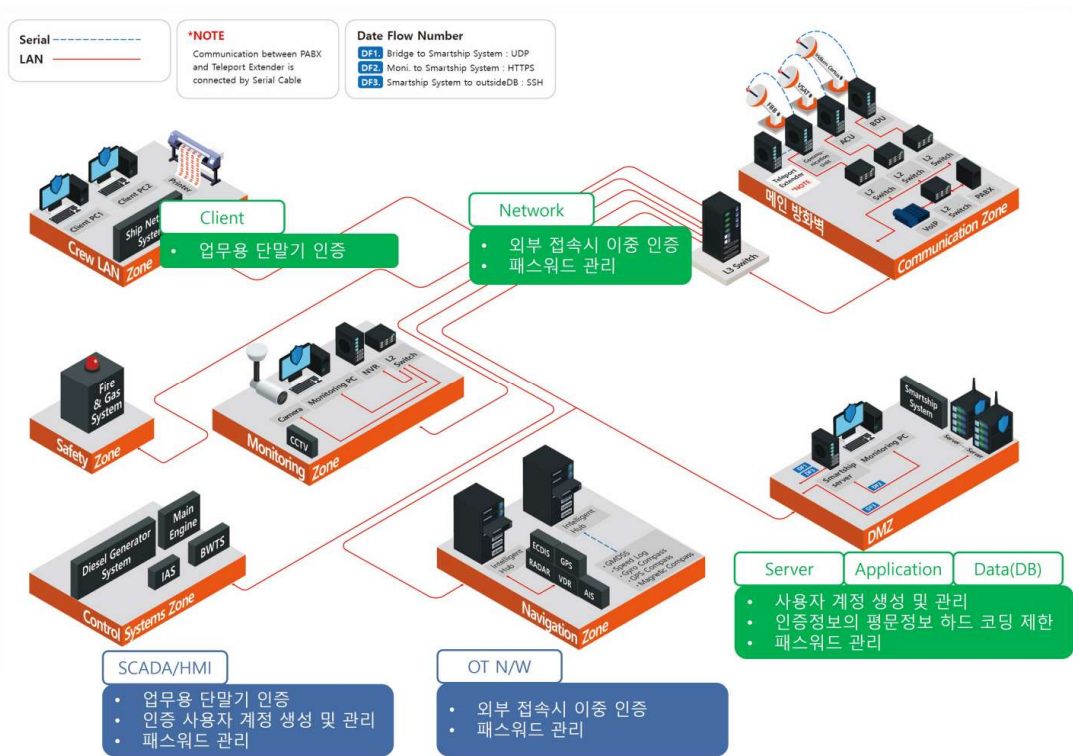
DCSA BIMCO	관리체계 (CSMS)	보안정책	보안설정	보안교육	보안운영	유지보수	사고대응
---------------	----------------	------	------	------	------	------	------

3.1 인증 (Authentication)

3.1.1 정의 및 전략적 중요성

인증(Authentication)은 시스템, 데이터, 서비스에 접근을 시도하는 사용자나 시스템의 신원이 정당한지를 확인하는 절차이다. 스마트선박 환경에서 선원, 육상 관제사, 외부 기술자, 그리고 각종 자동화 시스템은 모두 신원 확인의 대상이 된다. 인증은 사이버보안의 가장 기본적인 출발점이자 첫 번째 방어선이다. 허가되지 않은 사용자 또는 장비가 전자해도 표시 시스템(ECDIS)이나 기관 제어 시스템(IAS)과 같은 핵심 OT 시스템에 접근할 경우, 선박의 안전 운항에 치명적인 결과를 초래할 수 있으므로, 강력하고 신뢰할 수 있는 인증 체계의 구축은 무엇보다 중요하다. 인증 체계가 무너지면 이후의 접근 통제, 암호화 등 다른 모든 보안 통제는 무력화될 수 있다.

그림 3-2 ▶ 보호기술 (인증) 아키텍처



3.1.2 핵심 요구사항 및 IACS 규정 연계 분석

스마트선박의 인증 요구사항은 『스마트선박 보안모델』과 IACS 공통규칙(UR)에 명확히 규정되어 있으며, 이는 강력한 신원 확인을 통해 비인가 접근을 원천 차단하는 데 중점을 둔다.

표 3-1 ▶ 보호기술 (인증) 목록

코드	항목	UR E26/E27 요구사항
인증-01	사용자 계정 생성 및 관리	• UR E27 : 2. 계정 관리. 3. 식별자 관리
인증-02	업무용 단말기 인증	• UR E26 : 2.7 모바일 및 휴대용 장치 사 • UR E27: 32. 소프트웨어 프로세스, 장치 식별과 인증
인증-03	외부 접속 시 이중 인증	• UR E26: 2.6 원격 접근 통제 및 신뢰할 수 없는 네트워크와의 통신 • UR E27: 31. 인간 사용자에게 대한 다중요소 인증, 35. 비신뢰 네트워크를 통한 접근, 36. 명시적 접근 요청 승인
인증-04	인증정보의 평문정보 하드코딩 제한	• UR E27 4. 인증자 관리, 6. 패스워드 기반 인증 강도
인증-05	패스워드 관리	• UR E27: 1. 사용자 식별 및 인증, 4. 인증자 관리, 6. 패스워드 기반 인증 강도, 7. 인증자 피드백

IACS UR E27은 시스템이 사용자를 고유하게 식별하고 인증하는 기능을 요구하며(4.1.1), 특히 최초 접속 시 패스워드 강제 변경(4.1.4), 안전한 패스워드 강도 정책(4.1.6)을 명시하고 있다. 또한, UR E26은 비신뢰 네트워크(untrusted network)로부터의 원격 접근 시 다중 인증(MFA) 사용을 강제(2.6)함으로써 인증의 중요성을 강조한다.

3.1.3 상세 구현 아키텍처 및 설정 가이드

3.1.3.1 (인증-05) 패스워드 관리

모든 서버, 네트워크 장비, 주요 애플리케이션에 대해 중앙에서 관리되는 강력한 패스워드 관리 정책을 적용해야 한다. 이는 시스템의 가장 기본적인 방어선을 강화하는 조치이다.

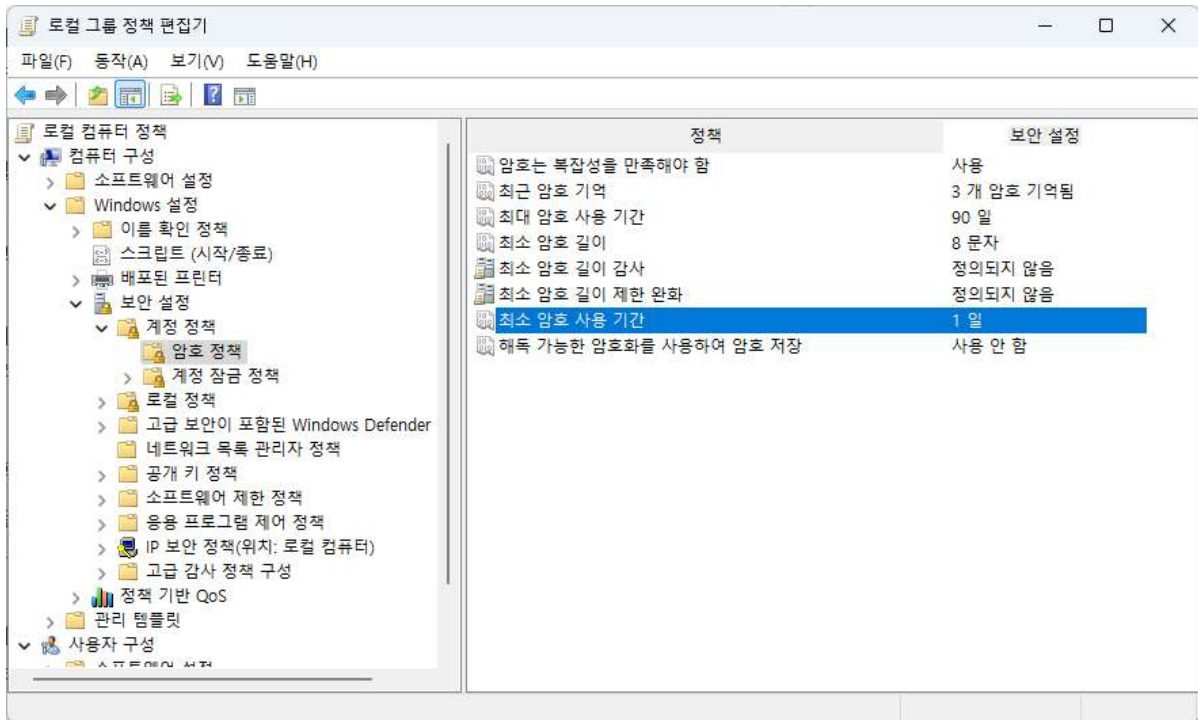
🔍 설정 항목 (예시) :

- **최초 패스워드 변경:** 최초/재발급 계정생성 시 패스워드 변경
- **Default 계정 사용 제한:** 상용 애플리케이션 또는 패키지에 존재하는 Default 계정 사용 제한
- **사용자 계정 공동 사용 제한:** 사용자 계정들에 대해 공동(공유) 사용 제한
- **안전한 패스워드 설정**
 - 최소 길이: 10자 이상
 - 복잡도: 영문 대/소문자, 숫자, 특수문자 중 2종류 이상 조합
 - 변경 주기: 최대 90일
 - 이력 관리: 최근 24개 이내 재사용 금지
 - 쉬운 비밀번호 제한 : 동일한 문자 반복, 키보드 상에서 나란히 있는 문자열, 일련번호, 연속적인 숫자, 생일, 전화번호 등 추측하기 쉬운 개인정보 및 ID와 비슷한 비밀번호사용 제한

🔍 **구현 기술:** Windows 환경에서는 그룹 정책 객체(GPO)의 '계정 정책 > 암호 정책'을 통해, Linux

환경에서는 /etc/login.defs 파일과 PAM(Pluggable Authentication Modules) 모듈 설정을 통해 강제할 수 있다.

그림 3-3 ▶ Windows GPO 암호 정책 편집기를 통한 암호정책 설정



3.1.3.2 (인증-03) 외부 접속 시 이중 인증

ID와 패스워드만으로는 더 이상 안전을 보장할 수 없다. 패스워드 탈취 시에도 추가적인 인증 단계를 거치도록 하여 보안을 강화해야 한다.

● 적용 대상:

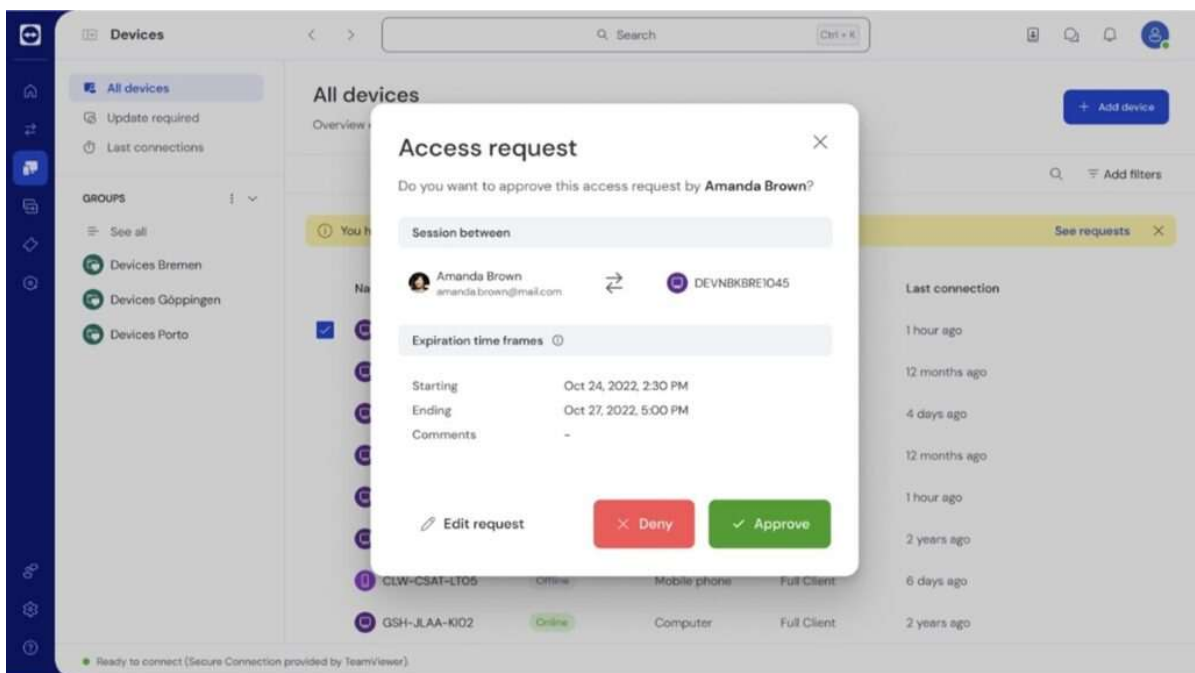
- **육상 원격 접근(Ship-to-Shore):** 육상 관제 센터에서 선박 시스템에 접근하거나, 외부 유지보수 업체가 원격으로 장비를 점검할 때 반드시 적용해야 한다.
- **선내 중요 시스템 접근:** 기관장, 항해사 등 특정 권한을 가진 사용자가 ECDIS, 기관 제어 시스템(IAS), 안전 관리 시스템(SMS) 등에 접근할 때 추가 인증을 요구한다.
- **구현 아키텍처:** 원격 사용자가 VPN을 통해 접속을 시도하면, VPN 게이트웨이는 1차로 ID/PW를 확인한 후, RADIUS 프로토콜을 통해 별도의 MFA 서버(OTP 서버 등)에 2차 인증을 요청한다. 사용자가 자신의 OTP 기기에서 생성된 코드를 입력하여 인증에 성공해야만 내부 네트워크 접근이 허용된다.
- **구현 기술:**
 - 하드웨어/소프트웨어 OTP: RSA SecurID와 같은 하드웨어 토큰 또는 Google Authenticator와 같은 스마트폰 앱을 활용한다.
 - PKI 기반 인증서: 사용자 또는 기기별로 고유한 디지털 인증서를 발급하고, 시스템 접근 시 인증서 유효성을 검증한다.

❶ 시스템 간 상호 인증(mTLS) 구현

사용자뿐만 아니라 시스템 간의 통신에서도 신뢰성을 확보해야 한다. 특히 OT 네트워크 내에서 허가된 시스템만이 민감한 데이터를 교환하도록 보장하는 것이 중요하다.

- **적용 구간:** ECDIS와 GPS 간, 기관 제어 시스템과 센서 간 통신 등 OT 네트워크 내 중요 시스템 간 통신에 적용한다.
- **구현 기술:** 상호 TLS(mutual TLS, mTLS)를 적용하여 통신하는 양측 시스템이 모두 신뢰할 수 있는 인증기관(CA)에서 발급한 유효한 인증서를 제시해야만 암호화된 세션을 설정하도록 구성한다. 이는 한쪽만 인증서를 제시하는 일반적인 TLS(HTTPS)보다 강력한 보안을 제공한다.

그림 3-4 ▶ 원격 접근 승인 화면



3.1.4 관련 보안 솔루션 및 선정 고려사항 (부록. 보안솔루션맵)

❶ 04-1: 인증 솔루션 (SSO, MFA)

- 다양한 인증 방식(OTP, 인증서, 생체인증 등)을 지원하는지, 기존 시스템(VPN, 운영체제)과 연동이 용이한지 평가해야 한다.

그림 3-5 ▶ 다중인증 옵션



출처 : 보안 뉴스 <https://m.boannews.com/html/detail.html?idx=134041>

01-3: 계정/접근권한 관리 솔루션

- 패스워드 정책 강제, 계정 라이프사이클 관리, 권한 신청/승인 워크플로우 기능을 제공하는 솔루션을 고려할 수 있다.

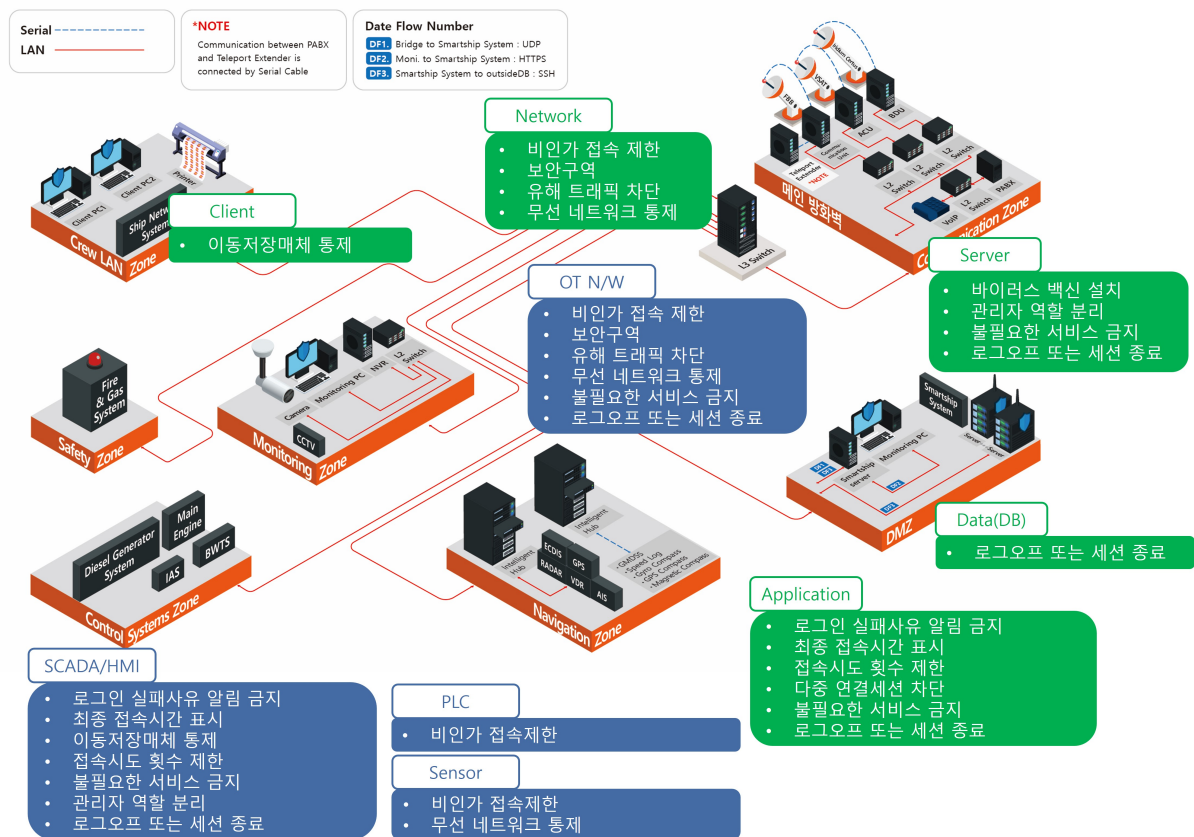
3.2 접근/권한 통제 (Access/Privilege Control)

3.2.1 정의 및 전략적 중요성

접근/권한 통제는 '인증'을 통과한 정당한 사용자가 구체적으로 어떤 정보나 시스템 기능에 접근하고 실행할 수 있는지를 제어하는 메커니즘이다. 이 영역의 핵심 원칙은 "최소 권한의 원칙(Principle of Least Privilege)"으로, 모든 사용자와 시스템은 업무 수행에 필요한 최소한의 권한만을 부여 받아야 한다는 것이다. 이를 통해 내부자에 의한 정보 유출이나 악성코드 감염 시 피해 범위를 최소화할 수 있다. 특히 IT망과 OT망의 경계에서 구현되는 강력한 접근 통제는 외부 위협으로부터 선박의 핵심 운항 시스템(OT)을 보호하는 가장 중요한 방어선 역할을 수행한다.

그림 3-6 ▶ 보호기술(접근/권한 통제) 아키텍처

[그림 60] 보호기술 아키텍처(인증)



3.2.2 핵심 요구사항 및 IACS 규정 연계 분석

접근 통제는 시스템과 네트워크를 논리적, 물리적으로 보호하는 것을 목표로 하며, IACS UR은 네트워크 분리와 역할 기반 접근 제어를 명확히 요구한다.

표 3-2 ▶ 보호기술 (접근통제) 목록

코드	항목	UR E26/E27 요구사항
접근통제-01	이동저장매체 통제	• E27 : 10. 휴대용 및 모바일 장치의 사용 통제
접근통제-02	비인가 접속 제한	• E26 : 2.4 접근통제 • E27 : 8. 권한부여 시행, 30. 최소화 기능
접근통제-03	보안 구역	• E26 : 2.1 보안 구역 및 네트워크 분할
접근통제-04	유해 트래픽 차단	• E26 : 2.2 네트워크 보호 안전장치 • E27 : 18. 악성코드로부터의 보호, 24. 서비스 거부로부터의 보호
접근통제-05	무선 네트워크 통제	• E26 : 2.5 무선통신 • E27 : 5. 무선 접근 관리, 9. 무선 사용 통제
접근통제-06	로그오프 또는 세션종료	• E27 : 12. 세션 잠금, 37. 원격 세션 종료, 41. 세션 종료 후 세션 ID 무효화
접근통제-07	바이러스 백신 설치	• E26 : 2.3 안티바이러스, 멀웨어 방지, 스팸 방지 및 악성코드로부터의 보호 • E27 : 18. 악성코드로부터의 보호
접근통제-08	관리자 역할 분리	• E27 : 8. 권한부여 시행
접근통제-09	불필요한 서비스 금지	• E27 : 30. 최소화 기능
접근통제-10	로그인 실패 사유 알림 금지	• E27 : 7. 인증자 피드백
접근통제-11	최종 접속시간 표시	• E27 : 34. 시스템 사용 알림
접근통제-12	접속시도 횟수 제한	• E27 : 33. 실패한 로그인 시도
접근통제-13	다중 연결세션 차단	• E26 : 2.4 접근통제 • E27 : 12. 세션 잠금

IACS UR E26 2.1은 보안 구역(Security Zones) 개념을 통해 네트워크를 분할하고 구역 간 통신을 엄격히 통제할 것을 요구하며, 이는 IT/OT 분리의 근거가 된다. UR E27 4.1.8은 시스템이 역할에 따라 권한을 차등 부여하는 기능(Authorization enforcement)을 갖추도록 규정하고 있다.

3.2.3 상세 구현 아키텍처 및 설정 가이드

3.2.3.1 (접근통제-08) 관리자 역할 분리

역할 기반 접근 제어(Role-Based Access Control, RBAC)은 사용자의 직책이나 직무에 따라 권한을 부여하는 체계적인 방법이다.

- 🌀 **1단계 (역할 정의):** 선장, 기관장, 1등 항해사, 조타수, 육상 관제사, 시스템 관리자 등 직책과 업무에 따라 역할을 정의한다.
- 🌀 **2단계 (권한 매핑):** 각 역할이 수행해야 할 업무에 필요한 시스템 접근 권한(예: ECDIS 항로 계획-생성/수정, 기관 제어 시스템-모니터링/제어)을 매핑한다.

- **3단계 (정책 적용):** Active Directory, LDAP 또는 개별 시스템의 RBAC 기능을 활용하여 정의된 정책을 적용한다. 예를 들어, 조타수 역할의 계정은 ECDIS의 항로를 조회할 수는 있지만 수정하거나 삭제할 수는 없도록 설정한다.

그림 3-7 ▶ RBAC 기반시스템 사용자 정보 관리

계정	부서	성명	권한	회사	수정일시
admin		관리자	관리자	EEDIOM	2018-09-13 18:08:19
member		member	사용자	EEDIOM	2018-09-13 16:37:53
new_root		root	마스터	EEDIOM	2018-09-11 18:38:30
root		na_root	마스터	EEDIOM	2018-09-13 16:37:38
samsam		삼삼이	관리자	SAMDIOM	2018-09-13 17:47:33
samsawon		삼사원	사용자	SAMDIOM	2018-09-13 17:48:08
xeraph		양봉열	관리자	EEDIOM	2018-08-10 15:34:50
김문연	QA팀	김문연	마스터	EEDIOM	2018-08-29 17:49:01

▶ 주기적으로 계정 현황 점검하여 퇴사자, 테스트 계정 등 불필요/미사용 또는 잘못된 권한 부여된 계정 점검

3.2.3.2 (접근통제-02) 비인가 접속 제한

- **통제 구역 설정 및 시건 장치:** 서버실, 통신 장비실, 주요 제어 콘솔(브릿지, 기관실) 등을 통제 구역으로 지정하고 시건 장치를 설치하며, 인가된 인원만 출입하도록 출입 관리 대장을 운영한다.
- **포트 보안(Port Security):** 사용하지 않는 네트워크 포트(이더넷, USB)는 물리적으로 포트 블로커를 사용해 막거나, 스위치 설정에서 비활성화(Shutdown)하여 비인가 장비의 연결을 원천 차단한다. 스위치의 Port Security 기능을 사용하여 허가된 MAC 주소를 가진 장비만 연결되도록 설정할 수 있다.
- **네트워크 접근 제어(NAC) 아키텍처:** NAC는 비인가 또는 보안에 취약한 단말이 네트워크에 접속하는 것을 자동으로 탐지하고 격리하는 데 효과적이다.
- **동작 원리:** ① 미인가 노트북이 네트워크 포트에 연결을 시도한다. ② 스위치는 단말 정보를 NAC 정책 서버에 전달하여 인증을 요청한다. ③ NAC 정책 서버는 사전에 등록된 자산 정보와 비교하여 미인가 장비임을 확인하고 스위치에 차단 명령을 내린다. ④ 스위치는 해당 포트를 비활성화하거나, 인터넷 접속만 가능한 격리 VLAN으로 자동 할당하여 내부 OT 시스템으로의 접근을 원천 차단한다.

3.2.3.3 (접근통제-03) 보안구역

IT망의 위협이 OT망으로 전파되는 것을 막는 것이 핵심 목표이다.

- **논리적 분리 (VLAN):** 스위치 장비의 VLAN(Virtual LAN) 기능을 사용하여 IT망(선원 인터넷, 행정: VLAN 10)과 OT망(항해/통신: VLAN 20, 기관 제어: VLAN 30)을 논리적으로 분리한다. 각 VLAN

간 통신은 반드시 경계 방화벽을 통해서만 허용되도록 라우팅 경로를 설정한다.

- **물리적 분리**: 가장 높은 보안 수준이 요구되는 경우, IT망과 OT망에 별도의 스위치, 케이블 등 물리적 인프라를 구축하여 완벽한 에어갭(Air-gap)에 가까운 환경을 구성한다.
- **경계 방화벽 설정**: IT와 OT 경계에 방화벽을 배치하고, '모든 것을 차단(Deny All)'을 기본 정책으로 설정한다. 이후, 반드시 필요한 통신만을 명시적으로 허용(Allow)하는 화이트리스트 기반 정책을 적용한다.

그림 3-8 ▶ 경계 방화벽 설정



▶ 방화벽, 네트워크 장비 설정을 통해 허용된 IP, MAC 주소를 가진 단말기만 접근 허용

표 3-3 ▶ 방화벽 정책 예시

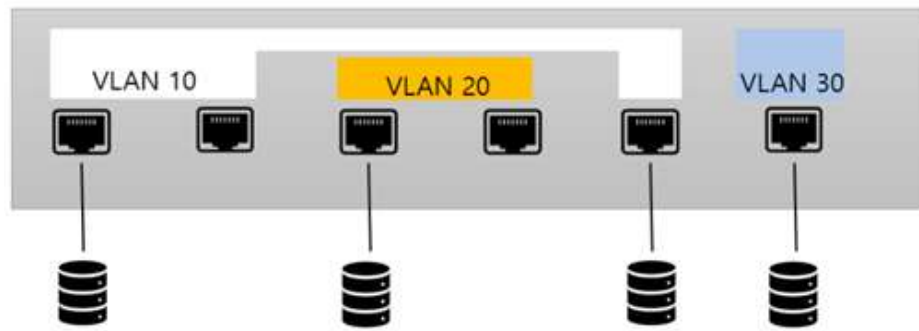
No.	출발지 (Source)	목적지 (Destination)	서비스 (Service)	행위 (Action)	설명
1	육상 해도 업데이트 서버 IP	ECDIS IP (VLAN 20)	HTTPS (TCP 443)	Allow	ECDIS 해도 업데이트 허용
2	육상 원격 유지보수 IP	IAS 서버 IP (VLAN 30)	SSH (TCP 22)	Allow	인가된 원격 유지보수 접속 허용
3	IT Zone (VLAN 10)	OT Zones (VLAN 20, 30)	Any	Deny	IT망에서 OT망으로의 모든 접근 차단
4	Any	Any	Any	Deny	그 외 모든 트래픽 차단 (기본 정책)

3.2.4 관련 보안 솔루션 및 선정 고려사항 (부록. 보안솔루션맵)

● 01-1: 네트워크 접근제어 솔루션(NAC)

802.1X 표준 기반 인증, IP/MAC 기반 통제, Agent/Agentless 방식 등 다양한 인증 및 통제 방식을 지원하는지 확인해야 한다.

그림 3-9 ▶ VLAN 설정을 통한 네트워크 접근제어



- ▶ VLAN을 구성하여 네트워크 영역을 논리적으로 분리하여, 권한 없는 사용자의 접근통제 적용 필요
- ▶ 방화벽과 접근제어(ACL) 정책을 설정하여 필요 최소한의 트래픽만 허용

01-5: 방화벽 (UTM, NGFW 포함)

- OT 프로토콜(예: Modbus, NMEA)에 대한 인지 및 제어 기능(Deep Packet Inspection)을 제공하는 산업용 방화벽을 고려해야 한다.

그림 3-10 ▶ 방화벽의 OT 프로토콜에 대한 DPI 지원

Firewall	Throughput	Firewall: Max. 80K packets per second / 1000 Mbps (based on RFC 2544) IPS: Max. 40K packets per second / 500 Mbps (based on RFC 2544)
	Filter	DDoS Ethernet protocols ICMP IP address MAC address Ports
	Intrusion Prevention System	Enabled by default. IPS pattern update functionality requires an additional license.
	Deep Packet Inspection	Modbus TCP Modbus UDP DNP3 IEC 60870-5-104 IEC 61850 MMS EtherNet/IP MELSEC Omron FINS OPC UA Siemens S7 Comm. Siemens S7 Comm. Plus Additional protocols will be supported through future firmware updates.

03-2: 보안 USB

- 중앙 관리 서버를 통해 인가된 사용자 및 데이터만 저장/사용할 수 있도록 통제하고, 분실 시 원격 삭제 기능을 제공하는지 확인해야 한다.

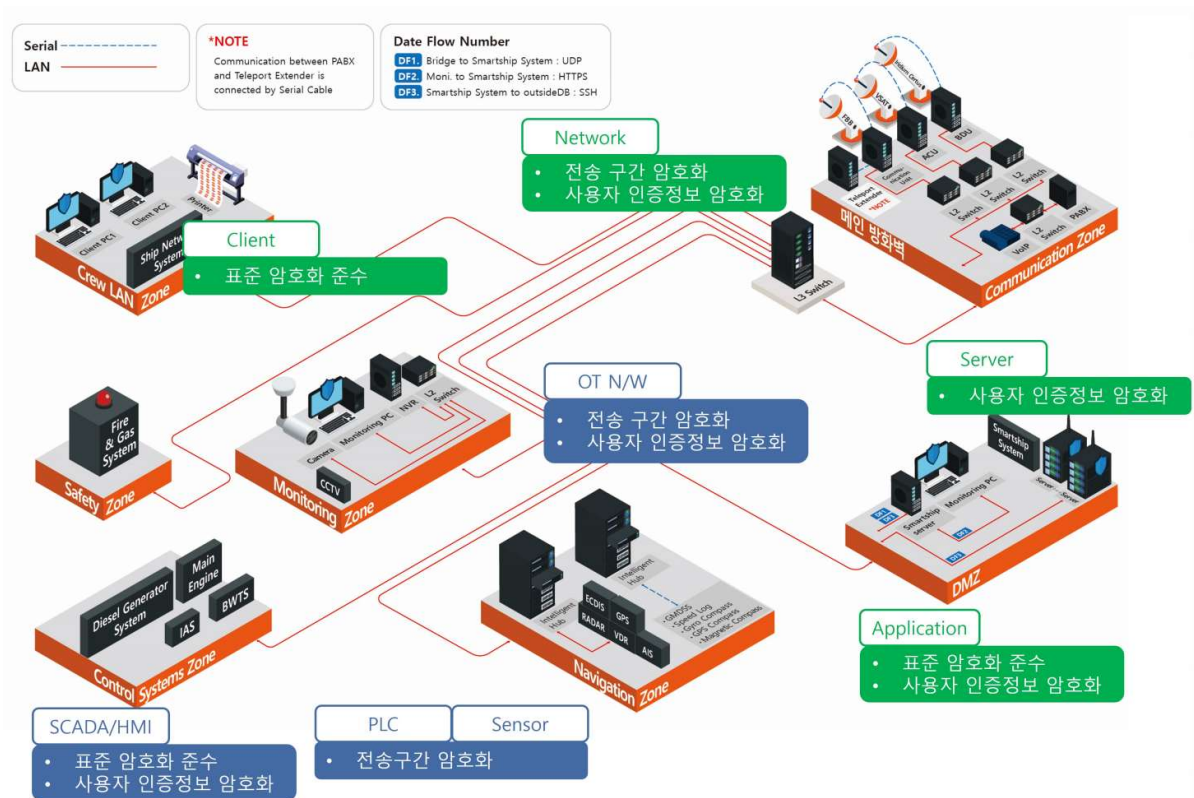
3.3 암호화 (Encryption)

3.3.1 정의 및 전략적 중요성

암호화는 평문(Plaintext) 데이터를 정해진 알고리즘을 사용하여 권한 없는 자는 해독할 수 없는 형태의 암호문(Ciphertext)으로 변환하는 과정을 의미한다. 스마트선박 환경에서 암호화는 두 가지 핵심 영역에서 데이터의 기밀성(Confidentiality)을 보장하는 역할을 한다.

- **전송 데이터(Data-in-Transit) 보호:** 선박과 육상 관제센터 간, 또는 선박 내 시스템 간에 위성 통신망이나 인터넷을 통해 전송되는 데이터를 보호한다. 이를 통해 중간자 공격(Man-in-the-Middle Attack)이나 도청(Eavesdropping)으로부터 운항 정보, 제어 명령 등 민감한 데이터를 안전하게 지킬 수 있다.
- **저장 데이터(Data-at-Rest) 보호:** 항해기록저장장치(VDR), 서버의 하드디스크, 백업 테이프 등에 저장된 데이터를 보호한다. 이를 통해 물리적인 저장 매체를 도난당하거나 비인가자가 시스템에 접근하더라도 중요 정보(운항 데이터, 선원 개인정보, 시스템 로그 등)의 유출을 막을 수 있다.

그림 3-11 ▶ 보호기술(암호화) 아키텍처



3.3.2 핵심 요구사항 및 IACS 규정 연계 분석

민감 데이터의 전송 및 저장은 반드시 암호화되어야 하며, 이는 IACS UR의 핵심 요구사항 중 하나이다.

표 3-4▶ 보호기술 (암호화) 목록

코드	항목	UR E26/E27 가이드라인
암호화-01	표준 암호화 준수	• E26: 2.5 무선통신, 2.6 원격 접근 통제 및 신뢰할 수 없는 네트워크와의 통신 • E27: 22. 암호 사용, 38 암호 무결성 보호
암호화-02	전송구간 암호화	• E26: 2.5 무선통신, 2.6 원격 접근 통제 및 신뢰할 수 없는 네트워크와의 통신 • E27: 17 통신 무결성, 21. 정보 기밀성, 22 암호 사용
암호화-03	사용자 인증 정보 암호화	• E27: 17 통신 무결성, 21. 정보 기밀성, 22 암호 사용

IACS UR E26 2.6은 비신뢰 네트워크와의 원격 연결은 반드시 종단점 인증, 무결성 보호, 암호화를 제공하는 보안 연결을 통해 이루어져야 한다고 명시한다. UR E27 4.1.17은 시스템이 저장하거나 전송하는 정보의 기밀성을 보호하는 기능을 요구하며, 4.1.38은 비신뢰 네트워크 통신 시 암호화 메커니즘을 적용하여 정보 변경을 감지하도록 규정하고 있다.

3.3.3 상세 구현 아키텍처 및 설정 가이드

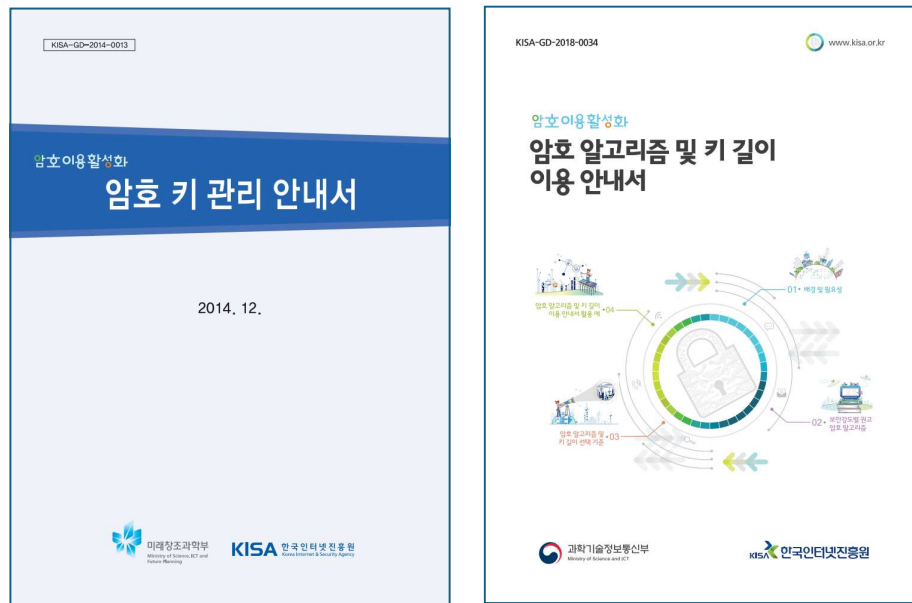
3.3.3.1 (암호화-01) 표준 암호화 준수

안전한 암호 알고리즘 사용과 암호키 관리에 그 안전성이 달려있다.

표 3-5▶ 국정원, KISA 등이 권고하는 알고리즘

분류	안전한 암호 알고리즘
대칭키 암호 알고리즘	SEED, ARIA-128/192/256, AES-128/192/256, HIGHT, LEA 등
공개키 암호 알고리즘	RSAES-OAEP 등
일방향 암호 알고리즘	SHA-256/384/512 등

- ❶ **암호키 생명주기 관리:** 키 생성, 저장, 백업, 배포, 교체, 파기 등 전 과정에 대한 명확한 절차를 수립하고 이행해야 한다.
- ❷ **키 저장소 분리:** 암호키는 암호화된 데이터와 동일한 위치에 저장해서는 안 되며, 별도의 안전한 장소에 보관해야 한다.
- ❸ **권장 방안:** 물리적 보안이 강화된 HSM(Hardware Security Module) 장비를 사용하여 암호키를 안전하게 생성하고 보관하는 것이 가장 이상적이다.
- ❹ **대체 방안:** 별도의 키 관리 서버(KMS)를 구축하고, 해당 서버에 대한 접근을 엄격히 통제한다.



※ 본 가이드는 예시이며, 실제 적용 시에는 국가정보원 암호모듈 검증(KCMVP) 제도에 따라 검증된 제품을 사용하거나 최신 국제 표준(NIST FIPS 140-3 등)을 우선적으로 참조해야함.

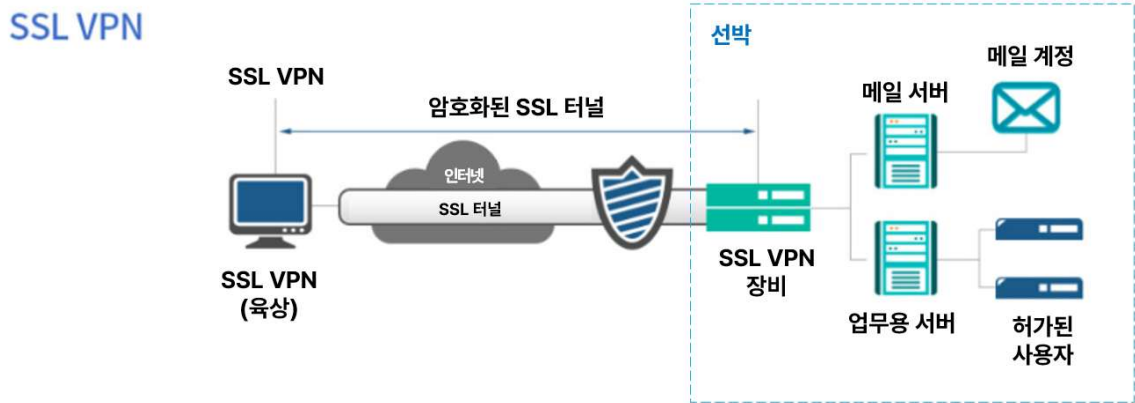
3.3.3.2 (암호화-02) 전송구간 암호화

가상 사설망(VPN, Virtual Private Network) 구축:

- **목적:** 선박과 육상 관제센터 간의 모든 통신을 암호화된 터널로 연결하여, 공용 위성 통신망을 마치 전용선처럼 안전하게 사용하기 위함이다.
- **아키텍처:** 선박과 육상 네트워크 경계에 각각 VPN 게이트웨이 장비(방화벽 등)를 설치하고, 두 지점 간에 IPsec 또는 SSL/TLS 기반의 VPN 터널을 설정한다. 모든 데이터는 이 터널을 통해서만 교환된다.
- **권장 기술:** 최신 보안 표준을 준수하기 위해 터널 프로토콜은 IKEv2, 암호화 알고리즘은 AES-256-GCM, 무결성 알고리즘은 SHA-384, 키 교환을 위한 Diffie-Hellman Group은 14 이상 사용을 권고한다.

보안 소켓 계층(SSL/TLS) 적용 (HTTPS):

- **목적:** 웹 브라우저를 통해 선박 관리 시스템, CCTV 모니터링 시스템 등에 접속할 때, 사용자 PC와 서버 간의 통신 구간을 암호화한다.
- **기술 방안:** 웹 서버에 공인 또는 사설 인증기관(CA)에서 발급받은 SSL/TLS 인증서를 설치한다. TLS 1.2 또는 최신 버전인 1.3 프로토콜을 사용하도록 서버를 설정하고, 취약점이 발견된 하위 버전(SSLv3, TLS 1.0/1.1)은 비활성화한다.



3.3.3.3 (암호화-03) 사용자 인증 정보 암호화

🔍 파일 시스템 암호화:

- **목적:** 서버의 디스크 전체 또는 특정 디렉토리를 암호화하여, 디스크 도난이나 OS 접근 권한 탈취 시에도 데이터 유출을 방지한다.
- **기술 방안:** Windows 환경에서는 BitLocker, Linux 환경에서는 LUKS(Linux Unified Key Setup)와 같은 운영체제 기본 제공 기능을 활용하여 디스크 전체를 암호화할 수 있다.

🔍 데이터베이스 암호화:

- **목적:** 운항 정보, 화물 관리 정보 등 데이터베이스에 저장된 민감한 데이터를 컬럼 단위 또는 테이블스페이스 단위로 암호화한다.
- **기술 방안:** Oracle, MS-SQL 등 상용 DBMS에서 제공하는 TDE(Transparent Data Encryption) 기능을 사용하여 애플리케이션 수정 없이 데이터베이스 파일을 암호화할 수 있다.

🔍 백업 데이터 암호화:

- **목적:** 선내 또는 육상에 소산 보관되는 백업 데이터가 유출되더라도 내용을 확인할 수 없도록 보호한다.
- **기술 방안:** 대부분의 상용 백업 솔루션은 백업 정책 설정 시 암호화 옵션을 제공한다. 백업 작업 수행 시 이 옵션을 활성화하여 백업 파일 생성 시점에 암호화를 적용한다.

3.3.4 관련 보안 솔루션 및 선정 고려사항 (부록. 보안솔루션맵)

🔍 01-4: 가상 사설망 (VPN)

- 지원하는 암호화 알고리즘의 강도와 종류, 처리 성능(throughput), HA(High Availability) 구성 지원 여부를 확인해야 한다.

🔍 04-2: 전송구간 암호화 (SSL/TLS)

- 주로 웹 서버, 방화벽, 로드밸런서 등의 SSL 가속 기능 형태로 제공된다. 지원하는 TLS 프로토콜

버전과 암호화 스위트(Cipher Suite)를 확인해야 한다.

그림 3-14 ▶ 외부로 정보를 전송할 경우 암호화 통신 채널 적용

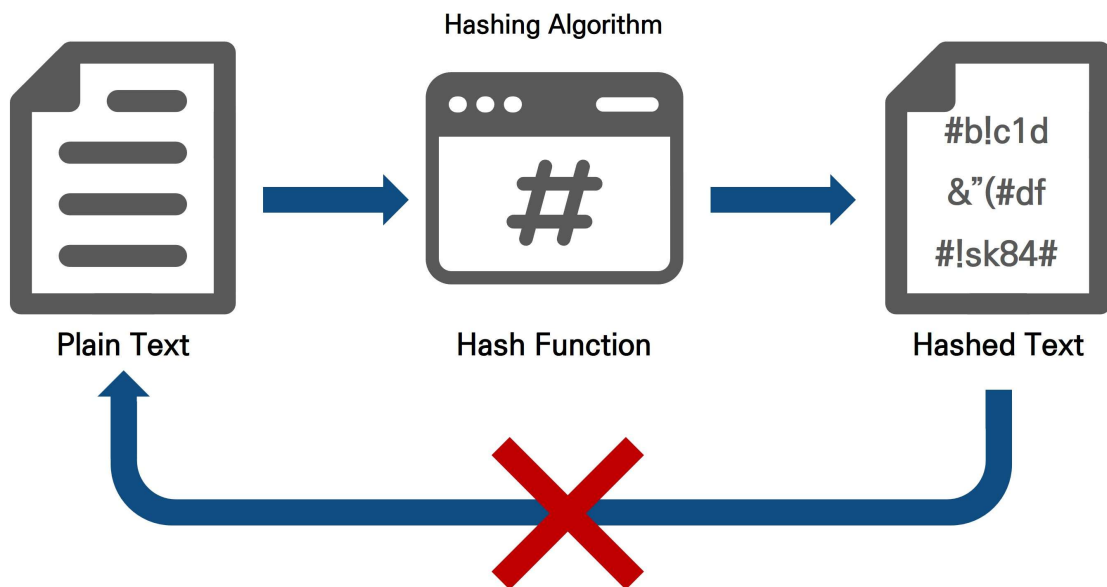


- ▶ SSL/TLS 기반의 보안 프로토콜(SSL 인증서) 적용
- ▶ VPN(Virtual Private Network)을 활용하여 내부 네트워크와 외부 간의 통신을 암호화

05-4 백업/복구 솔루션 (암호화 기능 포함)

- 백업 데이터 암호화 기능을 제공하는지, 암호키 관리 방안은 무엇인지 확인해야 한다.

그림 3-15 ▶ 사용자 로그인 인증 정보는 단방향 복호화 불가 암호화 적용



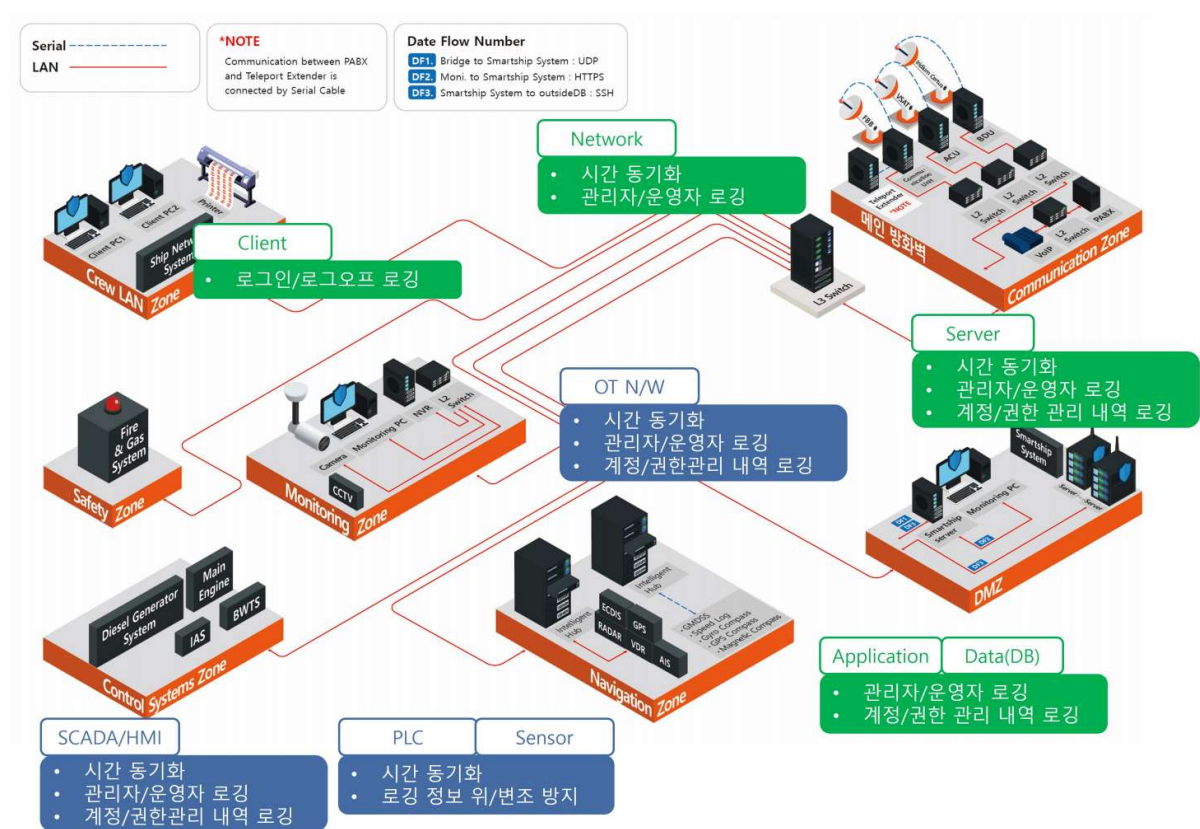
- ▶ 비밀번호 등 인증정보는 안전한 Hash 함수로 암호화하여 저장 (SHA-256/384/512 등)

3.4 부인방지 (Non-repudiation)

3.4.1 정의 및 전략적 중요성

부인방지는 특정 행위나 이벤트가 발생했다는 사실을 행위자가 사후에 부인할 수 없도록, 제3자가 객관적으로 증명할 수 있는 증거를 제공하는 보안 속성이다. 이는 주로 **로그 기록**, **시간 동기화**, **무결성 보증** 기술을 통해 구현된다. 선박에서 사이버보안 사고(예: 시스템 무단 조작, 악성코드 감염)나 해양 사고(예: 충돌, 좌초) 발생 시, 부인방지 메커니즘은 사고의 원인을 정확히 규명하고 책임 소재를 파악하는 데 결정적인 법적 증거를 제공한다. 예를 들어, "누가, 언제, 어떤 시스템에 접속하여, 무엇을 변경했는가"를 명확히 입증할 수 있어야만 정확한 사고 조사와 후속 조치가 가능하다.

그림 3-16 ▶ 보호기술(부인방지) 아키텍처



3.4.2 핵심 요구사항 및 IACS 규정 연계 분석

신뢰할 수 있는 증거를 확보하기 위해 로그 생성, 보호, 시간 동기화, 무결성 검증은 필수적이며, IACS UR은 이를 구체적으로 요구한다.

표 3-6 ▶ 보호기술 (부인방지) 목록

코드	항목	UR E26/E27 가이드라인
부인방지-01	로그인/로그오프 로깅	- E26: 3.1 네트워크 운영 모니터링 - E27: 13. 감사가능 사건

부인방지-02	관리자/운영자 로깅	• E26: 2.5 무선통신, 2.6 원격 접근 통제 및 신뢰할 수 없는 네트워크와의 통신 • E27: 13. 감사가능 사건
부인방지-03	계정/권한 관리 내역 로깅	• E27: 13. 감사가능 사건
부인방지-04	시간 동기화	• E27: 16. 타임스탬프
부인방지-05	로깅 정보 위/변조 방지	• E27: 14. 감사 저장 용량, 15. 감사 처리 실패 대응, 23. 감사로그 접근성

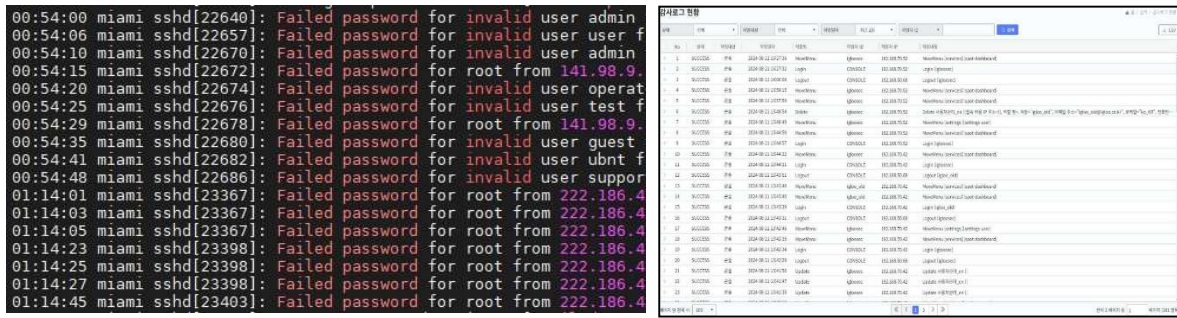
IACS UR E27 4.1.13은 접근 통제, 운영체제 이벤트, 백업/복구 등 보안 관련 이벤트에 대한 감사 기록 (auditable events) 생성을 요구한다. 또한, 4.1.16은 감사 기록에 정확한 시간 정보를 포함하기 위해 신뢰할 수 있는 시간 소스와의 동기화(timestamps)를 필수 요건으로 규정하고 있으며, 4.1.23은 인가된 사용자만 로그에 접근할 수 있도록 제한(audit log accessibility)하여 로그의 위변조를 방지하도록 하고 있다.

3.4.3 상세 구현 아키텍처 및 설정 가이드

3.4.3.1 (부인방지-01,02,03) 로깅 및 분석

- ❁ 목적:** 선내에 분산된 다양한 시스템(방화벽, 서버, 네트워크 장비, ECDIS 등)의 로그를 한 곳으로 모아 통합적으로 관리하고, 위변조를 방지하며, 신속한 검색 및 분석을 지원한다.
- ❁ 기술 방안 (SIEM – Security Information and Event Management):**
 - 1단계 (로그 수집):** 각 시스템에서 Syslog, WMI, Agent 등 다양한 방식으로 로그를 생성하도록 설정하고, 이 로그들을 암호화된 채널(예: TLS)을 통해 선내 보안 구역에 설치된 중앙 SIEM 서버로 전송한다.
 - 2단계 (로그 저장 및 보호):** SIEM 서버는 수집된 원본 로그를 변경 불가능한(Append-only) 형태로 저장한다. 주기적으로 로그 파일 전체에 대한 해시(Hash) 값을 계산하여 별도의 안전한 저장소에 보관함으로써, 로그 파일의 위변조 여부를 사후에 검증할 수 있다.
 - 3단계 (상관관계 분석 및 경보):** SIEM은 사전에 정의된 규칙(Correlation Rule)에 따라 여러 시스템의 로그를 실시간으로 분석한다. 예를 들어, '짧은 시간 내에 다수의 로그인 실패 후 성공'과 같은 패턴이 탐지되면 무차별 대입 공격(Brute-force attack)으로 판단하고 즉시 보안 관리자에게 경보를 보낸다.

그림 3-17 ▶ 로그 분석 예시



- ▶ 접속 인증 성공·실패 기록 로깅 및 1년 이상 보관하도록 정책 정의
- ▶ 10회 이상 실패, 야간 접속 시도 등 점검 기준 수립 및 주기적으로 점검
- ▶ 시스템 운영자 및 보안 관리자의 시스템 내 작업 로그를 일정 기간(예: 1년 이상) 보관하는 정책 수립
- ▶ 주요 로그 위/변조, 도난, 분실 등이 발생하지 않도록 별도의 백업장치, 솔루션 등을 통해 안전하게 보존 및 관리

3.4.3.2 (부인방지-04) 시간 동기화

- ❖ **목적:** 모든 시스템의 시간을 하나의 기준 시간으로 일치시켜, 사고 발생 시 여러 시스템의 로그를 시간 순으로 정확하게 재구성하기 위함이다. 이는 IACS UR E27의 필수 요구사항이다.
- ❖ **기술 방안:** 선박 내에 GPS 신호를 수신하는 최상위 NTP 서버를 1대 또는 2대(이중화) 설치한다. 선내의 모든 서버, PC, 네트워크 장비, OT 시스템은 외부 인터넷의 불특정 NTP 서버가 아닌, 이 선내 최상위 NTP 서버를 바라보도록 설정하여 시간을 동기화한다.

그림 3-18 ▶ 시간 동기화



- ▶ 신뢰할 수 있는 NTP 서버(time.google.com, time.windows.com, NIST 서버 등)와 동기화 설정

3.4.3.3 (부인방지-05) 로깅 정보 위/변조 방지

● **목적:** 악성코드나 공격자에 의해 핵심 시스템 파일, 설정 파일, 항로 데이터 등이 무단으로 변경되는 것을 탐지한다.

● **기술 방안:**

- **1단계 (베이스라인 설정):** 시스템이 정상 상태일 때, 보호 대상 파일들(예: /etc/passwd, C:\Windows\System32\drivers, ECDIS 항로 파일)에 대한 해시 값(SHA-256 등) 목록인 '베이스라인'을 생성하여 안전하게 보관한다.
- **2단계 (주기적 비교 검증):** 무결성 검증 도구(예: Tripwire, AIDE)를 사용하여 주기적으로(예: 매일) 대상 파일들의 현재 해시 값을 계산하고, 저장된 베이스라인과 비교한다.
- **3단계 (경보 및 조치):** 해시 값이 일치하지 않는 파일이 발견되면, 이는 무단 변경이 발생했음을 의미하므로 즉시 보안 관리자에게 경보를 보내고 상세 분석을 수행한다.

그림 3-19▶ 로깅 정보의 위/변조 방지 적용



- ▶ 주요 로그는 보존기간, 보존방법 등을 정하고 로그 삭제 및 변경 권한은 최소 권한 원칙에 따라 부여
- ▶ 시스템 이외의 별도의 보조저장매체나 별도의 저장장치, 오브젝트 스토리지 등에 보관
- ▶ CD-ROM, DVD-R, WORM(Write Once Read Many) 등과 같은 덮어쓰기 방지 매체 사용
- ▶ 접속기록을 수정 가능한 매체(하드디스크, 자기 테이프 등)에 백업하는 경우에는 무결성 보장을 위해 위·변조 여부를 확인할 수 있는 정보(MAC값, 전자서명 값 등)를 별도의 장비에 보관·관리

3.4.4 관련 보안 솔루션 및 선정 고려사항 (부록. 보안솔루션맵)

● **05-2: 모니터링 및 로그분석 솔루션 (ESM/SIEM)**

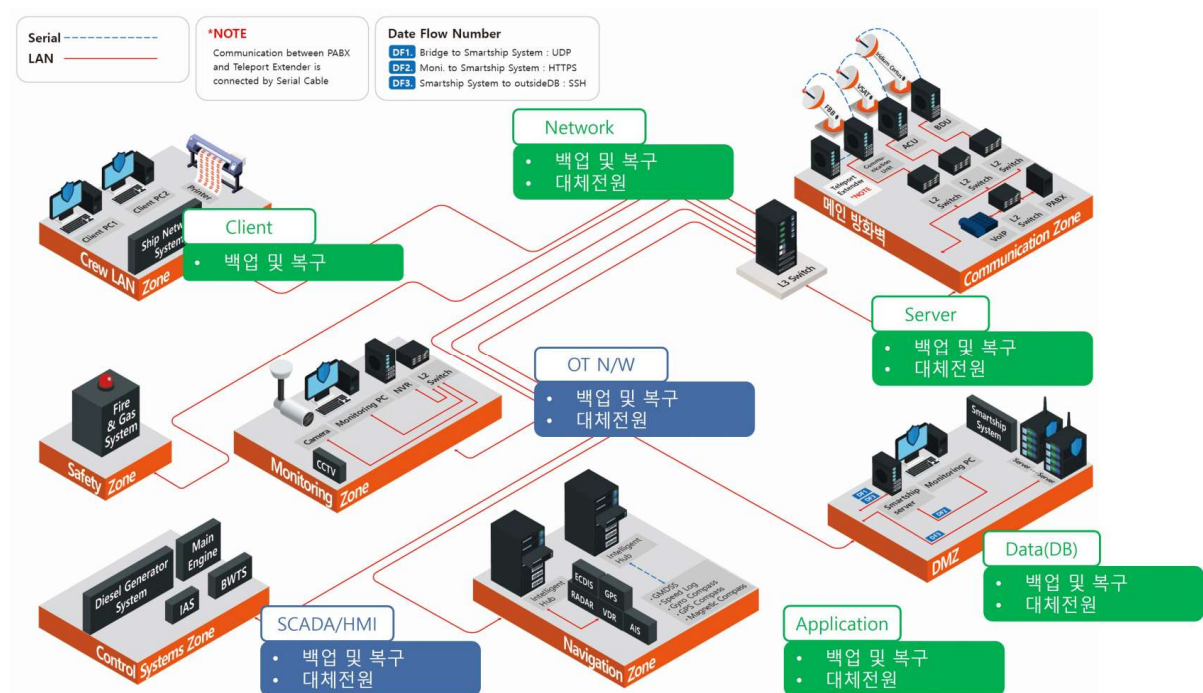
- 다양한 이기종 장비(네트워크, 서버, 보안장비, OT 시스템)의 로그 수집을 지원하는지, 상관관계 분석 시나리오를 커스터마이징 할 수 있는지, 로그의 장기 보관 및 위변조 방지 기능을 제공하는지 확인해야 한다.
- ESM/SIEM은 일반적으로 사이버 자산 관리정보 모니터링, 공격자 위협정보 모니터링 및 시각화, 사고 로그 수집 및 분석 지원 등을 지원한다.

3.5 가용성 (Availability) 및 사이버 복원력 (Cyber Resilience)

3.5.1 정의 및 전략적 중요성

가용성(Availability)은 인가된 사용자가 필요로 하는 시점에 정보 자산 및 시스템에 접근하여 정상적으로 서비스를 사용할 수 있는 능력을 의미한다. 그러나 스마트선박 환경에서는 단순한 가용성을 넘어 사이버 복원력(Cyber Resilience)의 개념으로 확장하여 이해해야 한다. 사이버 복원력이란 사이버 공격이나 시스템 장애와 같은 역경에 대해 예측하고(Anticipate), 견디고(Withstand), 복구하고(Recover), 적응(Adapt)하는 능력을 의미한다. 전자해도표시시스템(ECDIS), 동적위치제어시스템(DPS), 기관 제어 시스템 등 핵심 OT 시스템의 서비스 중단은 좌초, 충돌 등 치명적인 사고로 이어질 수 있다. 따라서 사이버 공격(예: 랜섬웨어, DDoS)이나 시스템 장애로부터 핵심 서비스를 보호하고, 장애 발생 시 신속하게 복구할 수 있는 능력을 확보하는 것은 선박과 선원의 안전과 직결되는 가장 중요한 보안 목표이다.

그림 3-20 ▶ 보호기술 (가용성/기타) 아키텍처



3.5.2 핵심 요구사항 및 IACS 규정 연계 분석

IACS UR E26의 제목 자체가 '선박의 사이버 복원력(Cyber resilience of ships)'일 정도로, 가용성 확보는 규정의 핵심 목표이다.

표 3-7 ▶ 보호기술 (가용성 및 사이버 복원력) 목록

코드	항목	UR E26/E27 가이드라인
가용성-01	백업 및 복구	E26: 5.1 복구 계획, 5.2 백업 및 복구 솔루션, 5.3 제어된 섯다운, 재설정, 롤백 및 재시작

		• E27: 26. 시스템 백업, 27. 시스템 복구 및 재구성
가용성-02	대체 전원	• E27: 28. 대체 전원

IACS UR E26은 복구 계획(5.1), 백업 및 복구 기능(5.2), 제어된 섀다운 및 재시작(5.3) 등 복원력 확보를 위한 포괄적인 요구사항을 제시한다. 특히 UR E27 4.1.28은 시스템이 대체 전원으로 중단 없이 전환될 수 있는 능력을 요구하여 전원 공급 장애에 대한 대비를 강조한다.

3.5.3 상세 구현 아키텍처 및 설정 가이드

3.5.3.1 (가용성-01) 백업 및 복구

⦿ 백업 정책 수립:

- **대상:** OS, 애플리케이션, 데이터베이스, 설정 파일, 항로 데이터, 로그 등 모든 중요 데이터를 포함한다.
- **주기:** 데이터의 중요도와 변경 빈도에 따라 차등 적용한다. (예: 중요 DB는 매일, 시스템 설정은 변경 시)
- **방식:** 전체 백업과 증분/차등 백업을 혼합하여 백업 시간과 저장 공간을 효율적으로 사용한다.
- **보관:** 3-2-1 원칙(3개의 복사본, 2개의 다른 미디어, 1개의 오프사이트)에 따라, 선내 안전 구역과 육상에 원격 소산 보관한다.

- **복구 절차 수립 및 테스트:** 백업은 복구 테스트를 통과해야만 의미가 있다. 백업 데이터를 실제로 복원하여 시스템이 정상적으로 동작하는지 검증하는 '복구 테스트'를 정기적으로(예: 반기 또는 연 1회) 수행해야 한다. 복구 목표 시간(RTO, Recovery Time Objective)과 복구 목표 지점(RPO, Recovery Point Objective)을 사전에 정의하고, 테스트 결과가 이를 만족하는지 평가한다.

그림 3-21 ▶ 백업 유형별 복구 목표 설정

유형	처리방식	복구 목표(RTO)	선박 시스템
Cold Site	테이프 소산방식	데이터 손실 가능 복구시간 지연	중요도가 낮은 CBS
Warm Site			
Hot Site	로그파일 전송방식	복구시간지연(24시간)	핵심 CBS 시스템
	미러링 방식	복구시간 2~3시간 백업센터 Stand-by	
Mirror Site	디스크 미러링		즉시 복구 백업센터 활용
	데이터 미러링		
	혼합형		

- ▶ 백업 대상, 방법, 주기, 보관 기간 등 절차 수립
- ▶ 복구 시간 목표(RTO), 복구 시점 목표(RPO), 복구 담당자 등 절차 수립
- ▶ 비상시 백업 복구 절차를 신속하게 수행할 수 있도록 절차서 마련
- ▶ 정기적으로 백업 및 복구 훈련 수행

🔗 재해 복구 계획(DRP, Disaster Recovery Plan) 수립 및 훈련:

- **목적:** 랜섬웨어 감염으로 인한 전 시스템 마비, 서버실 침수 등 최악의 재해 상황을 가정하여, 선박의 필수 기능을 복원하기 위한 종합적인 절차를 문서화한다.
- **주요 내용:** 비상 연락망, 역할별 임무 카드, 시스템별 복구 우선순위, 상세 복구 절차, 외부 지원 요청 절차 등을 포함한다.
- **훈련:** 연 1회 이상 재해 복구 계획에 기반한 모의 훈련(Table-top exercise, Full-scale drill 등)을 실시하여 계획의 실효성을 검증하고, 선원들의 위기 대응 능력을 숙달시킨다.

3.5.3.2 (가용성-02) 대체 전원

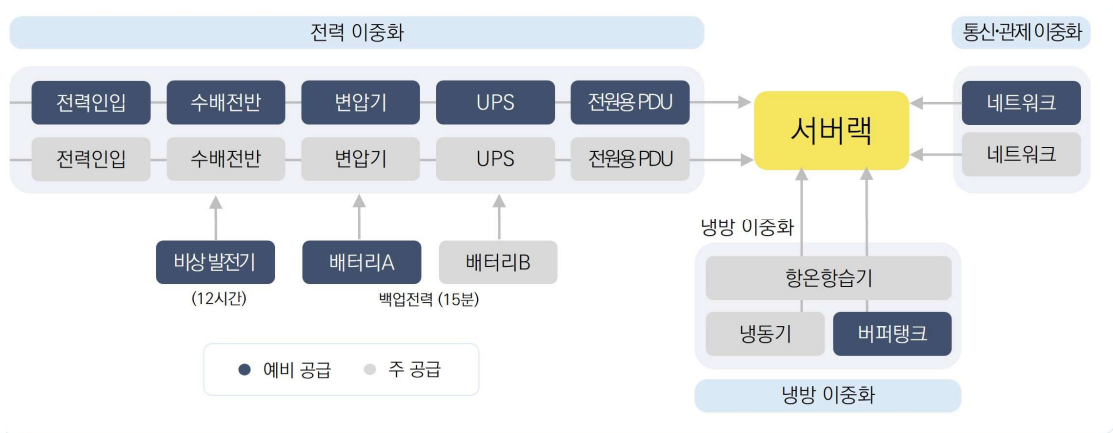
주요 CBS가 사이버 공격 전력 중단 또는 기타 비상 상황에서 운영을 지속할 수 있도록 보조 전원 시스템을 마련, 선박의 항해, 통신, 안전 및 보안 장치가 항상 작동할 수 있도록 단일 장애점(Single Point of Failure)을 제거하는 것이 목표이다.

- 🔗 **네트워크 이중화:** 백본 스위치, 방화벽 등 핵심 네트워크 장비를 이중으로 구성(HA Cluster)하고, 서로 다른 경로로 케이블을 포설하여 물리적 손상에 대비한다.
- 🔗 **서버 이중화:** 중요 서비스를 제공하는 서버(예: IAS 서버, Smartship Platform 서버)를 Active-Standby 또는 Active-Active 클러스터로 구성하여 하나의 서버에 장애가 발생해도 서비스가 중단되지

않도록 한다.

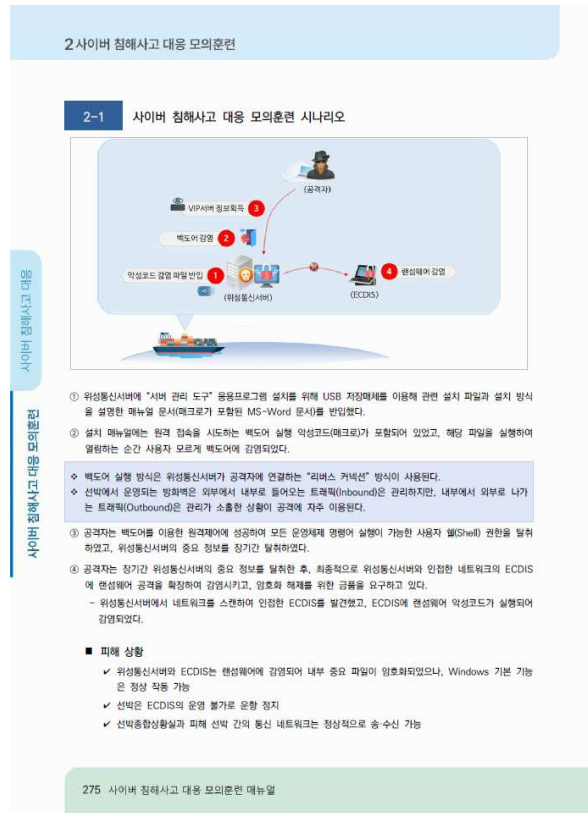
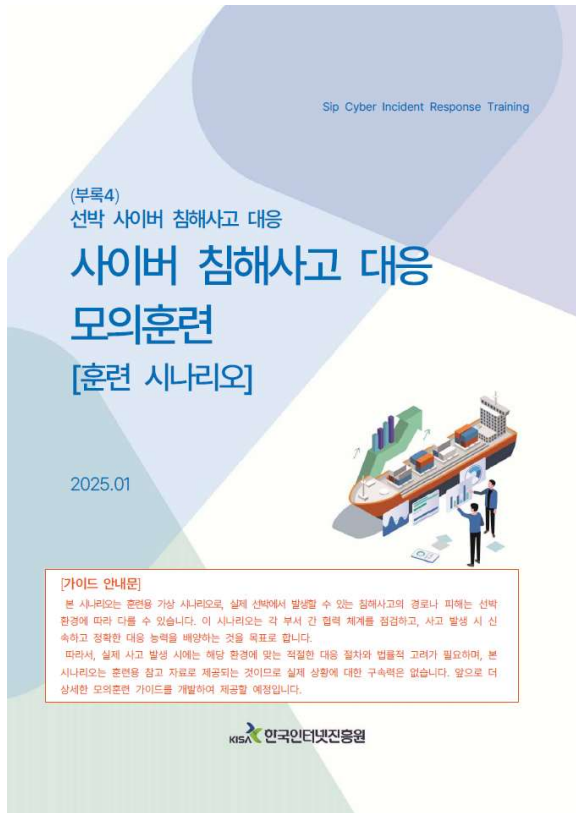
- **핵심 장비 이중화:** IACS 및 SOLAS 규정에 따라, GPS, 자이로컴퍼스, Radar 등 핵심 항해 장비는 반드시 2개 이상의 독립적인 시스템을 설치하여 하나의 시스템이 고장 나더라도 다른 시스템을 즉시 사용할 수 있어야 한다.

그림 3-22 ▶ 전력 및 네트워크 이중화 구성 예시



- ▶ UPS(무정전 전원 공급 장치), 이중 전원 공급 장치(Redundant Power Supply, RPS) 적용
- ▶ 주기적으로 비상 발전기 작동 여부 점검

그림 3-23 ▶ 스마트선박 보안모델 가이드-부록4 사이버 침해사고 대응 모의훈련



3.5.4 관련 보안 솔루션 및 선정 고려사항 (부록. 보안솔루션맵)

05-4: 백업/복구 솔루션

- 다양한 OS 및 애플리케이션(DB 등)에 대한 에이전트를 지원하는지, 백업 데이터 암호화 및 중복 제거 기능을 제공하는지, 복구 테스트 자동화 기능이 있는지 등을 평가해야 한다.

그림 3-24 ▶ KISA-랜섬웨어 대응을 위한 데이터백업 8대 보안 수칙

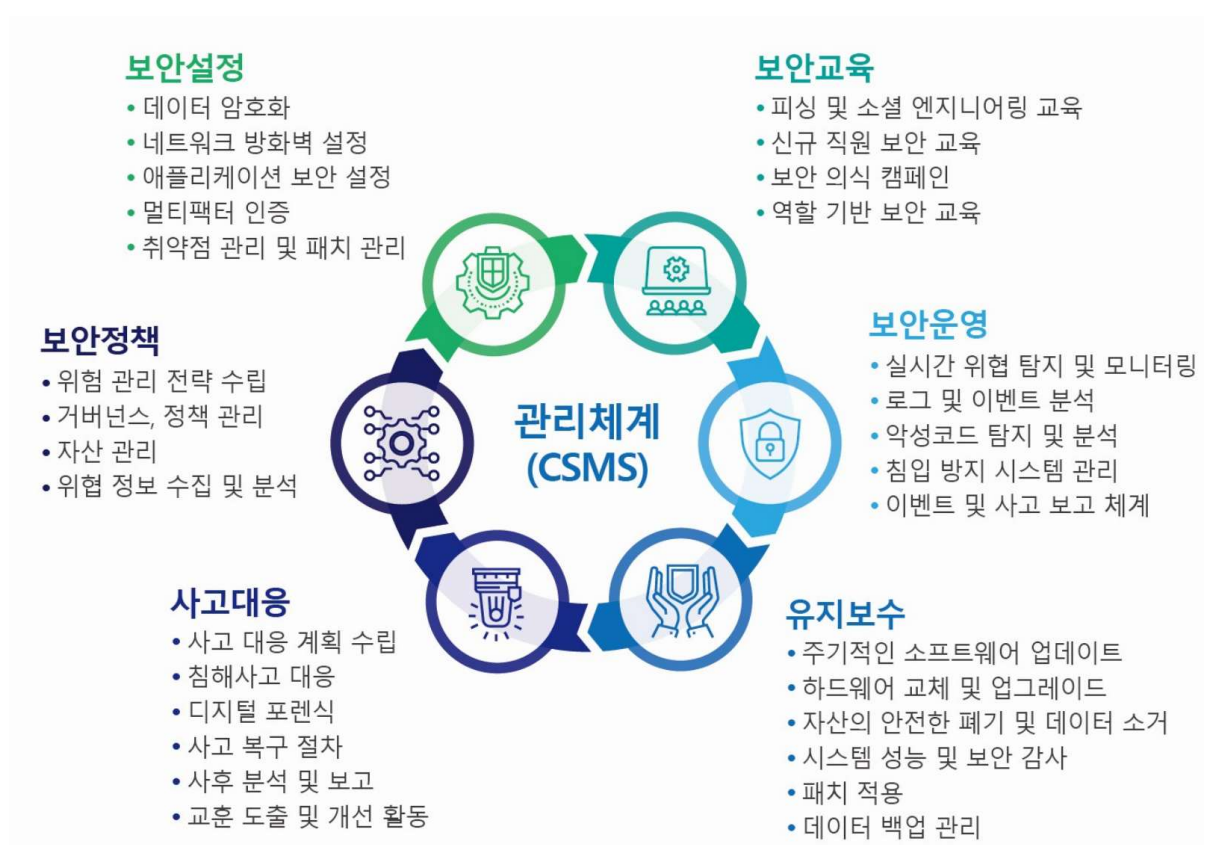


3.6 관리체계 (Management System)

3.6.1 정의 및 전략적 중요성

사이버보안 관리체계(CSMS, Cyber Security Management System)는 개별적인 기술적 보호조치들을 유기적으로 통합하고, 조직의 정책과 절차에 따라 지속적으로 운영·관리하기 위한 프레임워크이다. 이는 '사람, 프로세스, 기술'을 모두 아우르는 총체적인 접근 방식이다. 효과적인 사이버보안은 단순히 좋은 보안 제품을 설치하는 것만으로 달성될 수 없으며, 최고경영진의 의지, 명확한 정책, 잘 훈련된 인력, 그리고 지속적인 개선 활동이 포함된 체계적인 관리체계가 뒷받침되어야만 가능하다. IMO의 MSC.428(98) 결의안은 기존의 안전관리체계(SMS, Safety Management System)에 사이버 리스크 관리 절차를 통합할 것을 요구하고 있으며, 이는 CSMS 구축이 선택이 아닌 필수 규제 요건임을 의미한다.

그림 3-25 ▶ 보호기술 (관리체계) 아키텍처



3.6.2 핵심 요구사항 및 IACS 규정 연계 분석

관리체계는 모든 보안 활동의 근간을 이루며, IMO와 IACS 모두 강력한 거버넌스 수립을 요구한다.

표 3-8▶ 보호기술 상세

코드	보호기술	『스마트선박 보안모델』 상세 요구사항	국제 규정
관리-01	보안정책	선박 내 정보시스템(IT) 및 운영 기술(OT) 환경에서 일관된 보안 기준을 적용하고 사이버보안 목표, 원칙, 규칙 및 지침을 명시하고, 이를 준수할 책임을 조직 내 각 부서 및 개인에게 부여	- IACS UR E26: 전반적인 사이버 복원력 프레임워크 구축 요구 - IACS UR E27: 2. 계정 관리, 3. 식별자 관리 (정책 기반) - ISO/IEC 27001: 5. 리더십 및 의지 / 6. 기획 (정보보호 목표 수립) A.5.1 정보보호 정책 / A.5.2 정보보호 역할 및 책임
관리-02	보안설정	각 CBS는 안전하게 설정되어야 하며, 정기적으로 설정 상태를 점검하고 취약점을 수정하여 최신 보안 상태를 유지	- IACS UR E26: 2.1 보안 구역 및 네트워크 분할 / 2.2 네트워크 보호 안전장치 - IACS UR E27: 29. 네트워크 및 보안 구성 설정 / 30. 최소화 기능 - ISO/IEC 27001: A.8.9 구성 관리 / A.8.20 네트워크 보안 / A.8.26 보안 코딩
관리-03	보안교육	- 선박의 모든 선원 및 관련 인력이 사이버보안 위협을 인지하고 대응할 수 있도록 교육 - 이 교육은 정기적으로 시행되어야 하며, 선원들이 각자의 역할에서 필요한 보안 조치를 이해하고 실천할 수 있어야 함	- IACS UR E26: (내재적 요구사항) 선원이 사고 대응/복구 계획을 숙지하고 이행 - IACS UR E27: 34. 시스템 사용 알림 (인식 제고) - ISO/IEC 27001: 7.2 역량 및 적격성 / 7.3 인식 / A.6.3 정보보호 인식, 교육 및 훈련
관리-04	보안운영	보안 운영에는 선박 시스템의 실시간 모니터링 및 경고 체계가 포함되며, 이를 통해 신속하게 위협을 탐지하고 대응할 수 있어야 함	- IACS UR E26: 3.1 네트워크 운영 모니터링 / 3.2 CBS 및 네트워크 검증 및 진단 기능 - IACS UR E27: 13. 감사가능 사건 14. 감사 저장 용량 19. 보안 기능 검증 - ISO/IEC 27001: 9. 성과 평가 / A.8.16 모니터링 활동
관리-05	유지보수	선박 시스템 및 소프트웨어에 대한 정기적인 유지보수와 보안 패치 적용은 필수이며, 이 과정에서 보안 요구사항이 충분히 반영되어야 함	- IACS UR E26: 1.1 선박 자산 목록 (자산 변경 관리) / 2.6 원격 접근 통제 (원격 유지보수) - IACS UR E27:

		- 시스템 업데이트 시에는 보안 취약점에 대한 사전 검토와 테스트가 요구됨 - 자산이 폐기 또는 반출될 때 데이터가 완전히 삭제되고 복구되지 않도록 관리가 필요함	18. 악성코드로부터의 보호 (백신 업데이트) / 26. 시스템 백업 • ISO/IEC 27001: A.8.8 기술적 취약점 관리 / A.7.10 저장 매체 (안전한 폐기)
관리-06	사고대응	- 선박은 사이버 사고 대응 계획을 수립하고, 사고 발생 시 즉각적으로 대응할 수 있는 체계를 갖추어야 함. - 사고 대응 과정에서 발생한 모든 활동은 기록되어야 하며, 사고 후 복구 및 재발 방지를 위한 사례가 수집되고 개선에 반영되어야 함.	• IACS UR E26: 4.1 사고 대응 계획 / 4.3 네트워크 격리 / 5.1 복구 계획 / 5.2 백업 및 복구 기능 • IACS UR E27: 27. 시스템 복구 및 재구성 • ISO/IEC 27001: A.5.24 정보보호 사고 관리 계획 및 준비 / A.5.26 정보보호 사고에 대한 대응

IMO 지침은 식별(Identify), 보호(Protect), 탐지(Detect), 대응(Respond), 복구(Recover)의 5가지 기능적 요소를 기반으로 사이버 리스크를 관리할 것을 권고하며, 이는 CSMS의 핵심 구성요소가 된다. IACS UR E26은 선박의 전체 생애주기에 걸쳐 사이버 복원력 프로그램이 유지되어야 함을 명시하며 관리체계의 지속성을 강조한다.

3.6.3 상세 구현 아키텍처 및 설정 가이드

3.6.3.1 (관리-01, 04) 보안 정책 및 운영

PDCA 기반 사이버보안 관리체계(CSMS) 수립 및 운영은 일회성 프로젝트가 아니라, 지속적으로 개선되는 순환 모델을 따라야 한다.

🌀 Plan (계획 수립):

- **거버넌스 수립:** 최고경영진의 지원을 확보하고, 정보보호최고책임자(CISO)를 임명하여 보안 활동을 총괄한다.
- **정책 및 지침 제정:** 전사 보안 정책과 접근통제, 패스워드 관리, 백업 등 영역별 세부 지침을 문서화하고 승인 받는다.
- **위험 평가(Risk Assessment):** 선박의 중요 자산을 식별하고, 자산별 위협과 취약점을 분석하여 위험도를 산정한다. (TARA - Threat Analysis and Risk Assessment 수행)

[정책/지침]



- ▶ 국제해사기구, 검사기관 등의 요구사항을 충족하는 정책-지침-절차 마련
- 정책: 사이버보안 목표 및 원칙을 정의한 상위 정책
- 지침: 보안 요구사항을 준수하기 위한 상세 지침(예: 접근통제, 패치관리 등)
- 절차: 실무에서 적용할 수 있도록 절차를 구체화
- ▶ 내부감사를 통해 최신 사이버 위협, 국내외 해사 사이버보안 요구사항을 반영하여 정책 및 절차를 정기적으로 업데이트

Do (실행 및 운영):

- **위험 처리 계획 이행:** 평가된 위험을 줄이기 위해 본 해설서 3.1~3.5절에서 설명한 기술적, 관리적 보호조치를 적용한다.
- **보안 인식 제고 및 훈련:** 역할 기반(선원, 육상 관리자 등)으로 맞춤형 보안 교육을 실시하고, 피싱 메일 모의 훈련 등을 통해 실전 대응 능력을 강화한다.
- **침해사고 대응팀(CERT) 구성 및 절차 수립:** 사고 발생 시를 대비한 대응 절차를 마련하고, 정기적인 모의 훈련을 실시한다.

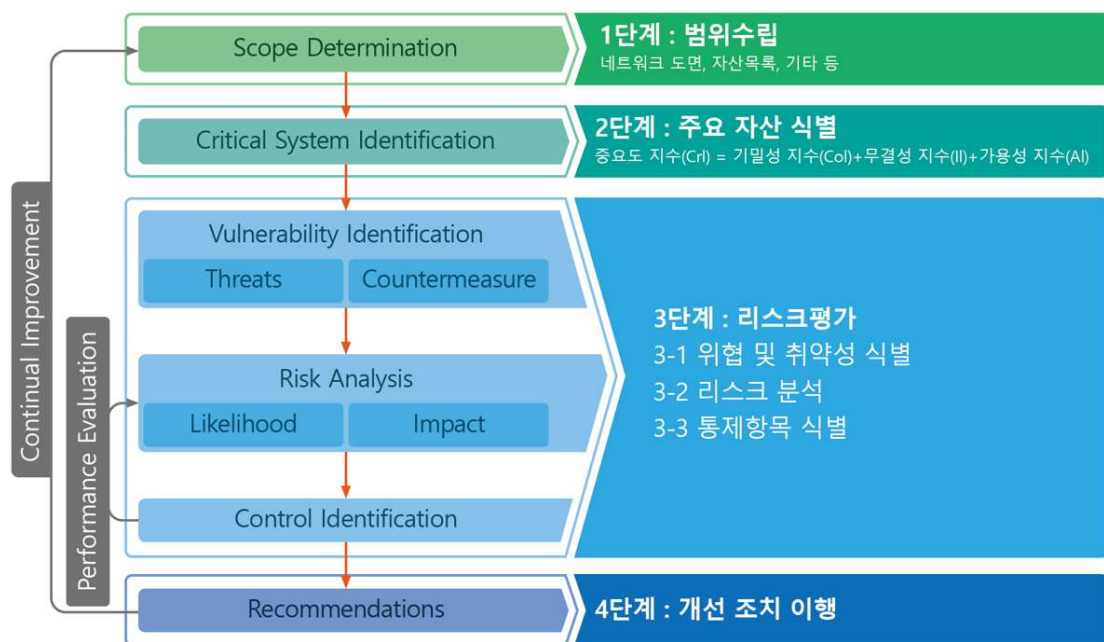
표 3-9 ▶ 선박 사이버보안 교육

전문 교육	일반 교육
• 선박 사이버보안 조직 구성 대상으로 전문 교육 실시 • 한국선급(이러닝, USB, 오프라인) 교육 및 세미나 등 활용	• 일반 선원 대상으로 연 1회 이상 사이버보안 인식제고 교육 실시 • 신규 승선자 대상으로 사이버보안 절차서 등 교육 실시 • 방선자 대상으로 사이버보안 관련 의무사항 안내 및 서약서 징구

Check (점검 및 평가):

- **주기적 감사:** 수립된 정책과 절차가 현장에서 잘 준수되고 있는지 내부 또는 외부 감사를 통해 점검한다.
- **취약점 분석:** 선박 시스템에 대해 정기적으로 취약점 스캐닝, 모의 해킹 등을 수행하여 잠재적 보안 약점을 식별한다.

그림 3-26 ▶ 스마트선박 사이버 리스ٹ 평가 방법론



○ Act (개선 조치):

- **시정 조치:** 감사 및 취약점 분석 결과 발견된 문제점들을 개선하고, 재발 방지 대책을 수립한다.
- **지속적 개선:** 변화하는 위협 환경과 기술 발전에 맞춰 보안 정책 및 관리체계를 지속적으로 검토하고 개선한다.

3.6.3.2 (관리-05) 유지보수

안전한 유지보수의 시작은 시스템이 선박에 도입되기 이전인 공급망(Supply Chain) 단계에서부터 비롯됩니다. 조선소, 시스템 통합(SI) 업체, 기자재 제조사 등 공급망을 통해 유입될 수 있는 잠재적 보안 위협을 사전에 관리하는 것이 핵심입니다.

- **공급망 보안:** 조선소, SI 업체, 기자재 제조사 등 공급망을 통해 유입될 수 있는 보안 위협을 관리하기 위해 계약 시 보안 요구사항을 명시하고, 납품되는 소프트웨어 및 하드웨어에 대한 인수 테스트 절차를 수행한다.

○ 기술 방안:

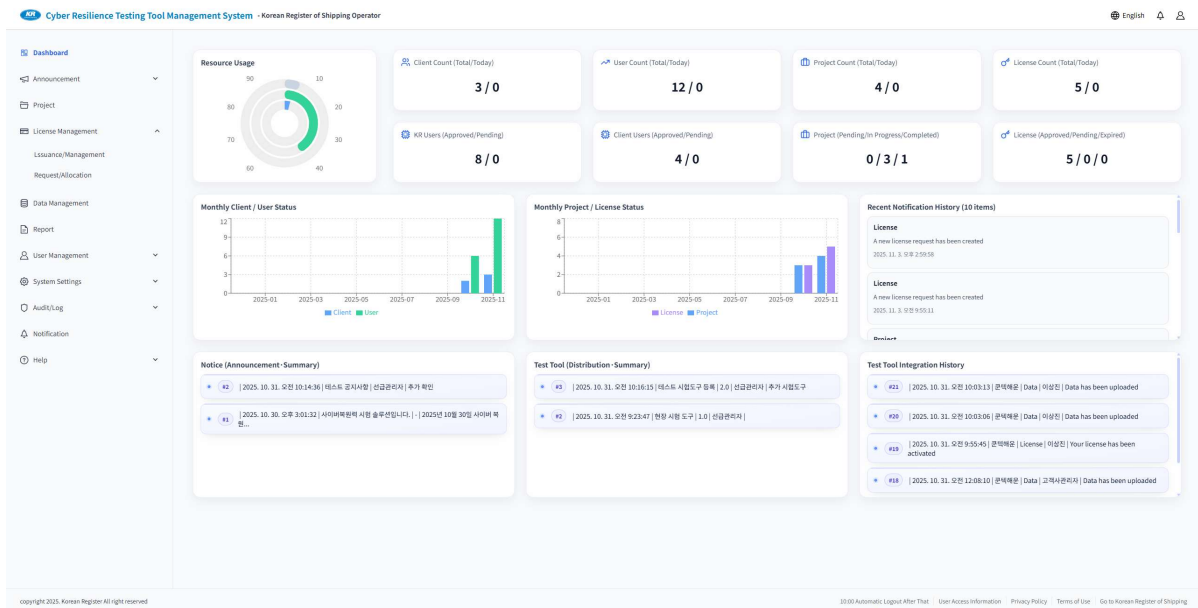
- 계약 시 보안 요구사항 명시 (예: SDLC 적용, 취약점 정보 제공 의무).
- 납품되는 소프트웨어 및 하드웨어에 대해 악성코드 검사, 보안 설정 검토 등 인수 테스트 절차 수립 및 이행.
- 소프트웨어 자재 명세서(SBOM, Software Bill of Materials) 제출을 요구하여 구성 요소의 투명성을 확보하고 잠재적 취약점을 사전에 파악한다.

3.6.4 관련 보안 솔루션 및 선정 고려사항 (부록. 보안솔루션맵)

○ 취약점 진단 솔루션

- 네트워크 기반 스캐너와 에이전트 기반 스캐너를 모두 지원하는지, 최신 취약점 정보(CVE) 데이터베이스를 유지하는지, 오탐을 최소화하는 기술을 보유했는지 평가해야 한다.

그림 3-27 ▶ 사이버복원력 시험도구



출처 : 한국선급, 선박 사이버 복원력 시험도구

- ▶ 연 1회 이상 또는 시스템 변경시 네트워크 스캐닝 및 취약점 진단 수행
- ▶ 서버, 네트워크, DB 및 OT 장비의 네트워크 가시성 확보
- ▶ 취약점 식별 (프로토콜, 포트, OS, 서비스) 및 상세 보고서 제공

05-3: 패치 관리 솔루션 (PMS)

- 다양한 OS(Windows, Linux) 및 서드파티 애플리케이션(Adobe, Java 등) 패치를 지원하는지, 패치 배포 정책(스케줄링, 대역폭 제어)을 유연하게 설정할 수 있는지, 패치 성공/실패 현황에 대한 가시성을 제공하는지 확인해야 한다.

06-2: 선박 사이버보안 관제 및 운영 (SOC)

- 해상 환경의 특수성(제한된 통신, OT 시스템)을 이해하는 전문 인력을 보유한 외부 전문 서비스를 활용하는 것을 고려할 수 있다.

06-3: 선박 사이버보안 교육

- 선원, 육상 관리자 등 역할별 맞춤형 콘텐츠를 제공하는지, 피싱 모의훈련과 같은 실습 기반 훈련을 포함하는지 평가해야 한다.

그림 3-28 ▶ SIEM 솔루션



출처 : 이글루코퍼레이션, SPiDER OT for Maritime

- ▶ 선박 시스템에 대한 통합보안관리 및 탐지/분석 체계 제공
- ▶ 중요 자산관리 및 현황, 장애, 네트워크 통신 오류 등 실시간 모니터링(UR E26 대응)
- ▶ 탐지 위협에 위험도 정의 및 가시성을 확보하여 선원들에게 위협 상황을 알림
- ▶ 최신 사이버 위협 정보를 통한 자동 사전 예방 체계 구축

그림 3-29 ▶ 선박 사이버보안 오프라인 교육(한국선급, KISA)

해사 사이버안전 기본 교육생 모집

교육대상: 조선, 기자재 및 해운업계 종사자

교육장소: 동남정보보호클러스터 교육장 (부산 동서대학교 선형캠퍼스 7층)

교육일정: 2025년 9월 16일(목) ~ 9월 17일(금) (2일, 12시간)

교육내용: 해사 사이버안전 기본 이론 + 실습 교육

교육인원: 30명

교육문의: 한국선급 사이버안전기술팀 (070-8799-8577)

교육혜택: 교육비 전액 무료, 교육 수료증 제공

교육목적: 사이버 공격으로부터 회사와 선박을 보호할 수 있는 방어책에 대한 이해와 실습 실습을 통한 사이버보안 역량 향상

날짜	교육시간	교육내용	수업시간
9.16 (목)	10:00 ~ 11:30 [14(2)308]	선박 사이버보안 기초(이론)	모두 12시간
	11:30 ~ 13:00 [14(2)308]	실습(이론)	
	13:00 ~ 14:00 [14(2)308]	선박 적률 최신 보안 기술 소개(NGFW, IDS/IPS)	
	14:00 ~ 17:30 [14(2)308]	선박 적률 최신 보안 기술 소개(NGFW, IDS/IPS)	
9.17 (금)	10:00 ~ 11:30 [14(2)308]	선박 적률 실습(이론)	모두 12시간
	11:30 ~ 13:00 [14(2)308]	실습(이론)	
	13:00 ~ 17:30 [14(2)308]	선박 적률 실습(이론)	

스마트선박 사이버보안 전문인력 양성 교육생 모집

교육대상: 조선 및 해운업계 종사자

교육장소: 동남정보보호클러스터 교육장 (부산 동서대학교 선형캠퍼스 7층)

교육일정: 2024년 11월 12일(목)

교육내용: 스마트선박 사이버보안 이론교육

교육인원: 40명

교육문의: 한국선급 사이버안전기술팀 (070-8799-8577)

교육혜택: 교육비 전액 무료, 교육 수료증 제공

교육목적: 스마트선박에 탑재되는 장비 및 시스템 보안 개념 및 글로벌 보안 규정(IACS UR E27, IEC 62443)에 대해 이해할 수 있다.

시간	주제	교육 주제/내용	강사명
10:00 ~ 10:30	IACS 488(2017)에 따른 사이버보안 요구사항	IACS UR E27 요구사항 해설	한지은
10:30 ~ 11:30	IT Cybersecurity 소개	• IT 보안 소개 • 주요 보안 정책 및 절차에 대해	한지은
12:00 ~ 13:00	중점강연		
13:00 ~ 13:30	선박에 적용된 IACS UR E27에 따른 요구사항	• 선박에 적용된 IACS UR E27에 따른 요구사항 해설	한지은
14:00 ~ 14:30	IEC 62443 소개	• IEC 62443 소개 및 해설	한지은
15:00 ~ 17:30	IEC 62443-2-1에 따른 요구사항	• IEC 62443-2-1에 따른 요구사항 해설 • IEC 62443-2-1에 따른 요구사항 해설	한지은

위협 시나리오 기반 Best Practice

4.1 인증: 원격 접근 계정 탈취 위협 대응을 위한 MFA 도입	50
4.2 접근·권한 통제: 랜섬웨어의 내부망 확산(Lateral Movement) 방지를 위한 네트워크 분할	52
4.3 암호화: 중간자 공격(MITM) 방지를 위한 운항 데이터 전송 암호화 ...	54
4.4 부인방지: GPS 스푸핑 의심 사고의 명확한 원인 규명	56
4.5 가용성: 주 ECDIS 시스템 장애 대응 모의 훈련	58
4.6 관리체계: 해운사의 CSMS 도입 및 이행	60

본 장에서는 제3장에서 설명한 보안 기술들이 실제 선박 환경에서 어떻게 적용될 수 있는지를 시나리오 기반의 Best Practice 형태로 제시한다. 각 시나리오는 『스마트선박 보안모델』에서 식별된 구체적인 위협(Threat)에서 출발하여, 본 해설서에서 제시한 해결 방안(Solution)을 적용했을 때 어떤 기대 효과(Outcome)를 얻을 수 있는지를 명확히 보여준다. 이를 통해 이론적인 기술을 실제적인 해결책으로 전환하는 과정을 입체적으로 이해할 수 있도록 구성하였다. 다음의 Best Practice 는 선박 내 발생 가능한 시나리오의 예시이며 실제 선박의 IT/OT 환경에 따라 적용 방안이 다를 수 있으므로 참조로 활용 가능하다.

4.1 인증: 원격 접근 계정 탈취 위협 대응을 위한 MFA 도입

● 관련 보호기술: 인증-02 (다중 인증 적용)

● 관련 솔루션: 04-1 암호/인증 (인증 솔루션)

● 위협 시나리오 (Threat Scenario)

육상 관제센터의 엔지니어가 선박의 추진 제어 시스템을 원격으로 점검해야 하는 상황이다. 기존에는 ID와 비밀번호만으로 VPN을 통해 접속했다. 엔지니어의 PC가 피싱 공격으로 악성코드에 감염되어 원격 접속용 ID/PW가 공격자에게 탈취되었다. 공격자는 이 정보를 이용해 선박의 PCS에 직접 접속을 시도한다.

● Best Practice (해결 방안)

선사는 원격 접근 보안 강화를 위해 다중 인증(MFA)을 도입한다. 해결 방안은 다음과 같은 단계로 구성된다.

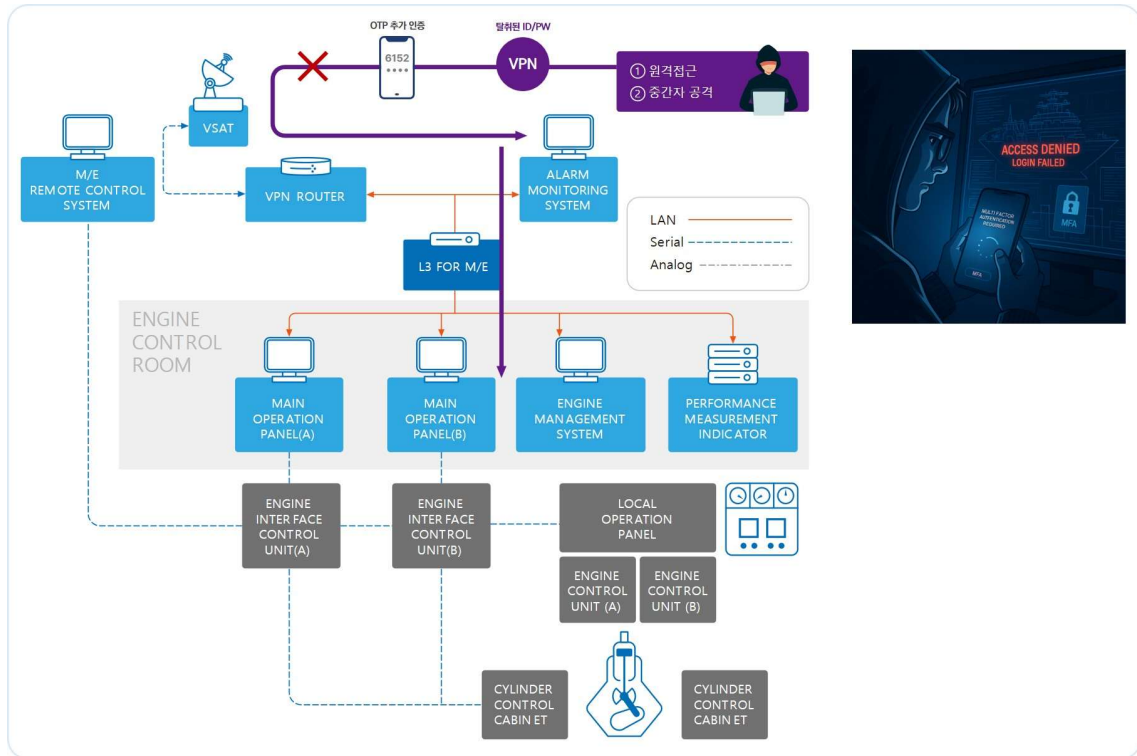
1. **VPN 접속 (1차 관문):** 공격자는 탈취한 ID/PW를 사용하여 VPN 클라이언트로 육상 관제센터 네트워크에 접속을 시도한다.
2. **원격 접속 시스템 로그인 (1차 인증):** VPN 접속 후, 선박 원격 접속 게이트웨이 시스템에 탈취한 ID와 비밀번호를 입력한다. 1차 인증은 성공한다.
3. **OTP 추가 인증 (2차 인증):** 그러나 시스템은 ID/PW가 정확하더라도, 사전에 등록된 엔지니어의 스마트폰 OTP 앱(예: Google Authenticator)에 6자리 인증 코드를 입력하라는 추가 인증 창을 띄운다.
4. **접속 실패:** 공격자는 엔지니어의 스마트폰을 물리적으로 소유하고 있지 않으므로 OTP 코드를 입력할 수 없어 최종 접속에 실패한다.

● 기대 효과

- **비인가 원격 접근 차단:** 비밀번호가 유출되더라도 공격자는 2차 인증 수단(OTP)이 없어 시스템에 최종적으로 접근할 수 없다. 이를 통해 원격 접근 경로를 통한 핵심 시스템 침해 위협을 효과적으로 차단한다.

- **보안 책임성 강화:** 모든 원격 접근은 '아는 것(패스워드)'과 '가진 것(OTP 기기)' 두 가지 요소를 모두 검증 받아야 하므로, 보안 수준이 대폭 향상된다.

그림 4-1 ▶ MFA 적용을 통한 비인가 원격접근 차단



4.2 접근·권한 통제: 랜섬웨어의 내부망 확산(Lateral Movement) 방지를 위한 네트워크 분할

● **관련 보호기술:** 접근통제-02 (네트워크 분리 및 통제)

● **관련 솔루션:** 01-5 네트워크 보안 (방화벽)

● **위협 시나리오 (Threat Scenario)**

한 선박에서 선원들이 사용하는 복지용 인터넷망(IT망)과 항해/기관 제어를 위한 운용망(OT망)이 VLAN 설정 없이 동일한 네트워크 스위치를 사용하고 있었다. 선원 한 명이 악성 첨부파일이 담긴 피싱 이메일을 열어 랜섬웨어에 감염되자, 해당 악성코드는 네트워크 검색을 통해 빠르게 내부로 전파(Lateral Movement)되어 중요 자산인 전자해도표시시스템(ECDIS)까지 감염시키고 화면을 잠가버렸다. 이로 인해 선박은 항해 정보를 상실하고 운항이 중단되는 심각한 위기에 처한다.

● **Best Practice (해결 방안)**

조선소는 설계 단계부터 IACS UR E26 2.1에 따라 네트워크 분리 아키텍처를 적용하고, 해운사는 이를 운영한다.

1. **물리적/논리적 분리:** IT망과 OT망을 위한 스위치를 물리적으로 분리하거나, VLAN 기능을 사용하여 하나의 스위치 내에서 브로드캐스트 도메인을 나눈다.

- VLAN 10: IT Zone (선원 PC, 복지용 Wi-Fi)
- VLAN 20: OT Zone - Navigation (ECDIS, GPS, Radar)
- VLAN 30: OT Zone - Propulsion (기관 제어, 센서)

2. **경계 방화벽 설정:** 각 VLAN 간의 모든 통신은 반드시 방화벽을 거치도록 라우팅 경로를 설정한다.

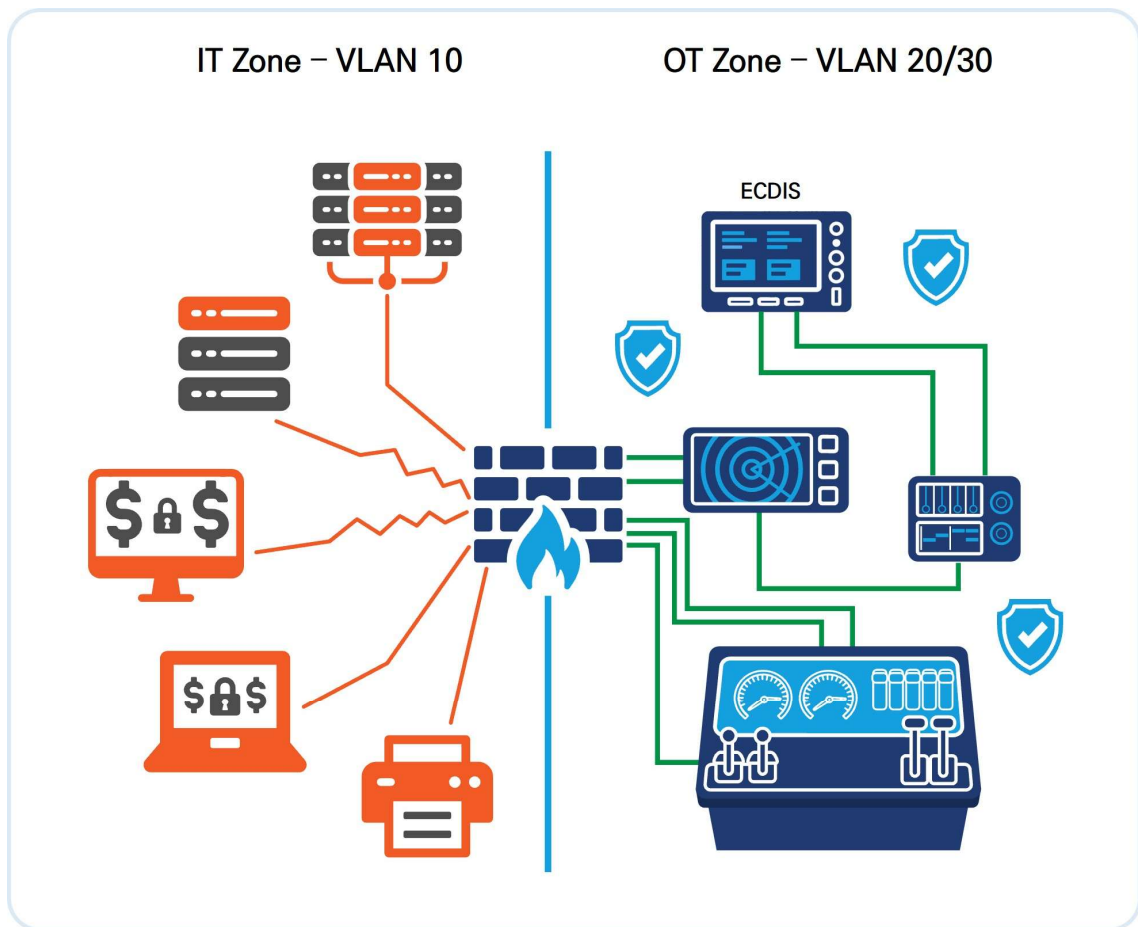
3. **접근 정책 수립(Rule-set):** 방화벽에 'Deny All'을 기본 정책으로 설정하고, 반드시 필요한 통신만 명시적으로 허용하는 화이트리스트 정책을 적용한다.

- Allow: [육상 해도 업데이트 서버 IP] → (Port: 443)
- Deny: VLAN 10 (IT Zone) → VLAN 20/30 (OT Zones) (All traffic)

● **기대 효과**

- **피해 확산 방지:** IT망에서 발생한 랜섬웨어 감염이 방화벽의 Deny 정책에 의해 차단되어 OT망으로 전파되지 않는다.
- **핵심 기능 가용성 보장:** 선박의 핵심 기능인 항해 및 기관 제어 시스템의 안전성과 가용성을 보장하여 운항 연속성을 유지할 수 있다.

그림 4-2 ▶ 경계 방화벽을 통한 랜섬웨어 확산 방지



1

2

3

4

5

6

4.3 암호화: 중간자 공격(MITM) 방지를 위한 운항 데이터 전송 암호화

● **관련 보호기술:** 암호화-01 (전송 데이터 암호화)

● **관련 솔루션:** 01-4 가상 사설망 (VPN)

● **위협 시나리오 (Threat Scenario)**

A 해운사는 최신 LNG 운반선의 연료 효율을 최적화하기 위해, 선박의 엔진 출력, 연료 소모율(SFOC) 등 핵심 데이터를 VSAT 위성 통신을 통해 육상 관제센터로 실시간 전송 받고 있다. 이 데이터가 별도의 암호화 없이 평문으로 전송되고 있어, 경쟁사나 악의적 공격자가 위성 통신 신호를 가로채 (Eavesdropping) 운항 효율 및 항로 등 민감한 영업 비밀을 탈취하거나, 중간에서 데이터를 위변조 (Man-in-the-Middle Attack)하여 잘못된 의사결정을 유도할 수 있는 심각한 위협에 노출되어 있다.

● **Best Practice (해결 방안)**

선박과 육상 관제센터 간에 Site-to-Site IPsec VPN 터널을 구축하여 모든 통신을 암호화한다.

1. **아키텍처 설계:** 선박과 육상 네트워크 경계에 각각 VPN 게이트웨이 기능이 있는 차세대 방화벽(NGFW)을 설치한다.

[선박 내부망] ↔ [선박 방화벽/VPN GW] - (위성 통신 구간: 암호화 터널) → [육상 방화벽/VPN GW] ↔ [육상 관제센터]

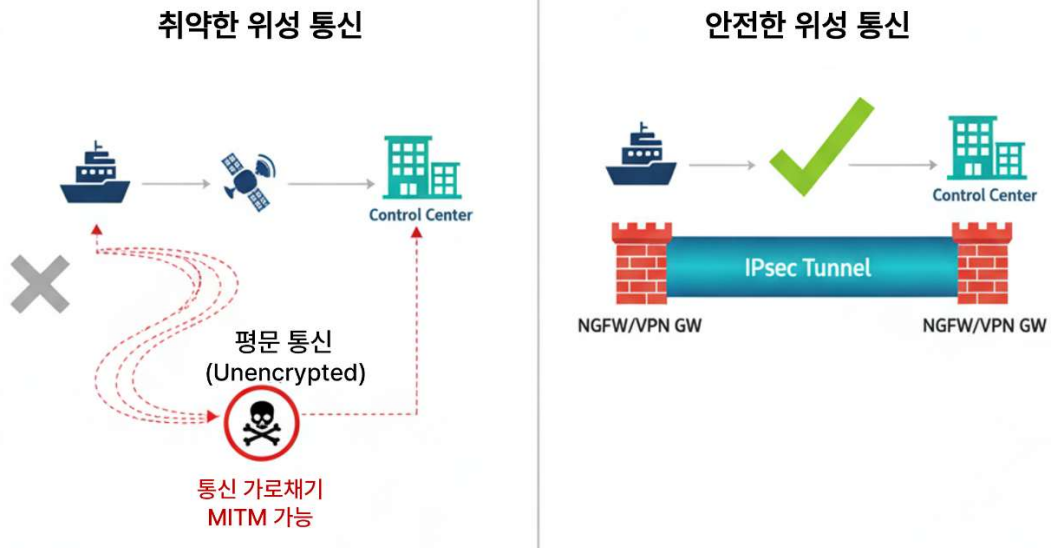
2. **강력한 VPN 정책 적용:** 터널 프로토콜은 IKEv2, 암호화 알고리즘은 AES-256, 무결성 알고리즘은 SHA-256, 키 교환을 위한 Diffie-Hellman Group은 14 이상을 사용하여 키 교환 과정의 보안을 강화한다.

3. **데이터 전송 흐름:** 선박의 데이터 수집 서버가 육상으로 데이터를 전송하면, 선박의 VPN 게이트웨이가 이 트래픽을 감지하여 정책에 따라 암호화 및 캡슐화하여 위성 통신망으로 보낸다. 육상의 VPN 게이트웨이는 이를 수신하여 복호화한 후, 내부 관제센터 서버로 안전하게 전달한다.

● **기대 효과**

- **기밀성 보장:** 모든 운항 데이터가 강력한 암호화 알고리즘으로 보호되어, 위성 통신 구간에서 탈취되더라도 내용을 해독할 수 없다. 이를 통해 영업 비밀과 민감 정보 유출을 원천적으로 차단한다.
- **무결성 보장:** IPsec 프로토콜에 포함된 무결성 검증 메커니즘을 통해 데이터가 전송 중에 변조되지 않았음을 보장한다. 이로써 데이터의 신뢰성을 확보하고 잘못된 의사결정을 방지한다.

그림 4-3 ▶ 안전한 위성통신



1

2

3

4

5

6

4.4 부인방자: GPS 스푸핑 의심 사고의 명확한 원인 규명

○ **관련 보호기술:** 부인방자-01 (로그 생성 및 보호), 부인방자-02 (무결성 검증)

○ **관련 솔루션:** 05-2 모니터링 및 로그분석 솔루션 (ESM/SIEM)

○ **위협 시나리오 (Threat Scenario)**

한 컨테이너선이 항만 접근 중 계획 항로를 비정상적으로 이탈하는 사고가 발생했다. 당직 항해사는 "GPS 신호가 불안정했다"고 주장하고, 항만 관제센터(VTS)는 "관제 지시를 따르지 않았다"고 주장한다. 외부의 GPS 스푸핑 공격인지, 장비 결함인지, 내부자의 조작 또는 실수인지에 대한 객관적 증거가 없어 책임 소재가 불분명하고, 이로 인해 막대한 법적·재정적 분쟁이 예상된다.

○ **Best Practice (해결 방안)**

선박 내에 중앙 로그 관리 시스템(SIEM)을 구축하고, 사고 조사팀이 로그 기반 포렌식 분석을 수행한다.

1. **아키텍처 설계:** 선박 내 중요 시스템(GPS 수신기 1/2, ECDIS, Radar, 방화벽 등)의 모든 로그를 실시간으로 선내 보안 구역에 설치된 SIEM 서버로 전송하여 통합 관리한다. 모든 시스템은 선내 NTP 서버와 시간을 동기화한다.

2. **포렌식 분석 절차:**

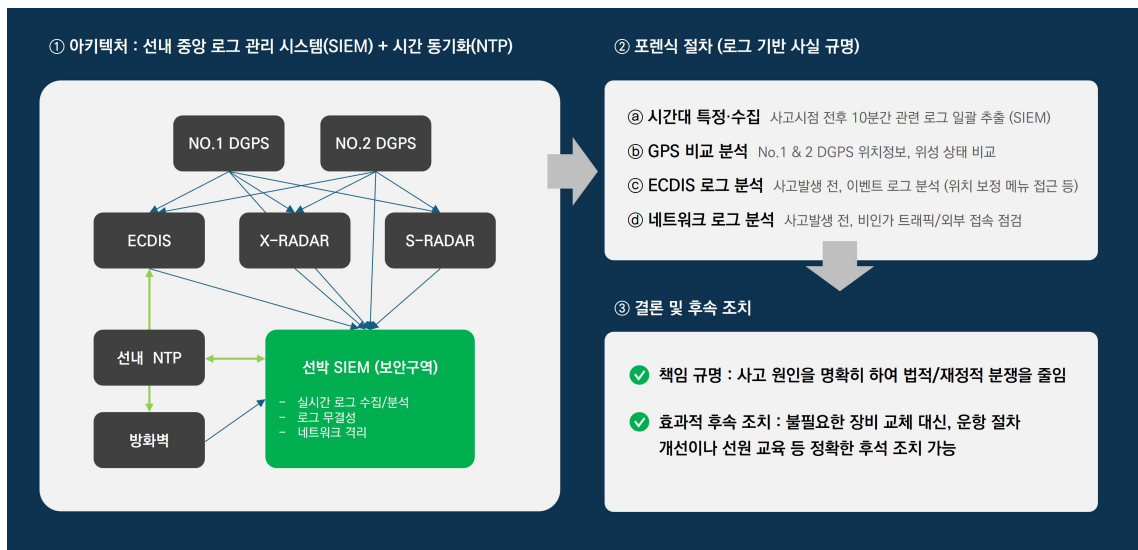
- **1단계 (시간대 특정 및 데이터 수집):** 사고 발생 시점을 기준으로 전후 10분간의 모든 관련 시스템 로그를 SIEM에서 추출한다.
- **2단계 (GPS 로그 분석):** 독립적으로 작동하는 GPS 수신기 1번과 2번의 위치 정보, 신호 세기, 수신 위성 개수 로그를 비교 분석한다. (분석 결과: 두 수신기 모두 정상 신호 수신, 경고 로그 없음)
- **3단계 (ECDIS 로그 분석):** ECDIS의 운영자 활동 로그를 정밀 분석한다. (분석 결과: 사고 발생 2분 전, 당직 항해사 계정으로 '수동 위치 보정(Manual Position Fix)' 명령어가 입력된 명확한 기록 발견)
- **4단계 (네트워크 로그 분석):** 방화벽 로그 분석 결과, 해당 시간대에 비정상적인 외부 접속 시도나 의심스러운 트래픽은 없었다.

3. **결론 도출:** 로그 분석 결과, 사고의 원인은 외부 공격이나 장비 결함이 아닌, 내부자의 수동 조작이었음이 명확히 입증된다.

○ **기대 효과**

- **부인방지 및 책임 규명:** 위변조가 불가능하게 저장된 로그는 "당직 항해사가 시스템을 수동으로 조작했다"는 사실을 부인할 수 없는 증거로 작용하여, 사고의 원인을 명확히 규명하고 책임 소재를 가릴 수 있다.
- **효과적인 후속 조치:** 정확한 원인 분석을 통해, 불필요한 장비 교체 대신 브릿지 시스템 운영 절차 재점검 및 선원 대상 집중 교육이라는 효과적인 후속 조치를 시행할 수 있다.

그림 4-4 ▶ 선박 사이버 사고 포렌식



1

2

3

4

5

6

4.5 가용성: 주 ECDIS 시스템 장애 대응 모의 훈련

● **관련 보호기술:** 가용성-01 (시스템 이중화), 가용성-02 (백업 및 복구)

● **관련 솔루션:** 해당 없음 (CSMS-사이버보안 관리체계)

● 위협 시나리오 (Threat Scenario)

C 해운사는 실제 항해 중인 선박의 브릿지팀을 대상으로 사이버 복원력(Cyber Resilience)을 점검하고자 한다. 제한 수로 항해 중, 주 No.1 ECDIS가 랜섬웨어에 감염되어 화면이 잠기는 상황이 발생했다. 가장 큰 위협은 네트워크를 통해 악성코드가 No.2 ECDIS(예비)까지 확산(Lateral Movement)되어 전자해도 시스템 전체가 마비되는 것이다. 브릿지팀이 당황하여 감염 시스템의 네트워크 분리 및 예비 시스템의 안전성 확인 절차 없이 선불리 대응할 경우, 전자항해 시스템을 완전히 상실하여 좌초나 충돌 사고로 이어질 수 있다.

● Best Practice (해결 방안)

실제와 같은 사이버 공격 대응 및 재해복구 모의훈련을 계획하고 실행한다.

1. 계획 (Plan):

- **목표:** No.1 ECDIS 랜섬웨어 감염 시, 즉시 ①**감염 시스템을 네트워크에서 분리**하고, ②**예비 ECDIS의 안전성을 확인**한 후 항해 시스템을 완전히 전환한다.
- **범위:** 당직 중인 브릿지팀(선장, 당직항해사, 조타수)
- **장소:** 주변에 위협 요소가 없는 외해(Open Sea)에서 실시.

2. 실행 (Do):

- **1단계 (훈련 시작 선포):** 선장이 브릿지 내 모든 인원에게 "지금부터 ECDIS 랜섬웨어 대응 모의훈련을 시작한다"고 명확히 알린다.
- **2단계 (사이버 공격 상황 부여):** 선장이 No.1 ECDIS의 모니터에 "랜섬웨어 감염" 화면을 묘사한 가림막을 씌워 공격 상황을 부여한다.
- **3단계 (선원 조치):**
 - ① **즉각적인 상황 보고:** 당직 항해사는 "No.1 ECDIS 랜섬웨어 감염 의심" 상황을 즉시 선장에게 보고한다.
 - ② **감염 시스템 네트워크 분리:** 지체 없이 물리적으로 No.1 ECDIS의 네트워크(LAN) 케이블을 분리하여 악성코드의 내부망 확산을 차단한다.
 - ③ **예비 시스템 안전성 점검:** 예비 ECDIS에 비정상적인 동작이나 경고가 없는지 면밀히 점검하고, GPS, Gyro 등 모든 센서 데이터가 정상 수신되는지 확인한다.

3. 점검 (Check):

- 선장은 훈련 시작부터 ①**네트워크 분리**, ②**안전성 점검**, ③**안정적인 항해 상태 확인**까지의 총 시간을 측정한다.

- 감염 시스템의 네트워크 분리 절차를 정확히 수행했는지를 중점적으로 관찰하고 기록한다.
- 브릿지팀의 의사소통, 절차 준수 여부, 문제점 등을 기록한다.

4. 조치 (Act):

- 훈련 종료 후 강평회를 통해 잘된 점과 개선점(특히, 사이버 공격 인지 및 초기 대응 절차)을 논의한다.
- 목표 시간(예: RTO 3분) 달성 여부를 평가하고, 미비점(예: 네트워크 포트 위치 미숙지)에 대한 추가 교육 계획을 수립하거나 선내 사이버 보안 비상 대응 절차를 개정한다.

기대 효과

- **사이버 복원력 강화:** 단순 장애 대응을 넘어, 랜섬웨어와 같은 악성코드 공격 시 피해 확산을 막고 핵심 기능을 유지하는 **사이버 복원력(Cyber Resilience)**을 실질적으로 강화한다.
- **업무 연속성 확보:** 실제 사이버 공격 발생 시 훈련된 절차에 따라 신속하게 위협을 격리하고 안전한 예비 시스템으로 전환하여 항해 업무의 연속성을 확보한다.
- **인적 역량 강화:** 반복적인 훈련을 통해 선원들이 사이버 비상 상황에서도 당황하지 않고 침착하게 대응할 수 있는 역량을 내재화한다.

그림 4-5 ▶ OT 시스템 랜섬웨어 대응



4.6 관리체계: 해운사의 CSMS 도입 및 이행

○ 관련 보호기술: 관-01, 관-02, 관-03

○ 관련 솔루션: 06-3 선박 사이버보안 (사이버보안 교육)

○ 위협 시나리오 (Threat Scenario)

25척의 선박을 보유한 D 해운사는 기존에 개별 선박별로 IT 담당자가 보안을 관리하여 일관성이 부족했고, IMO의 사이버 리스크 관리 지침을 충족한다는 객관적인 증거를 제시하기 어려운 상태였다. 이로 인해 ISM Code 감사 시 중대 부적합(Major Non-conformity)을 받아 선박의 운항 허가가 정지될 수 있는 규제 미준수 위험과, 전사적인 사고 대응 능력 부재라는 문제에 직면했다.

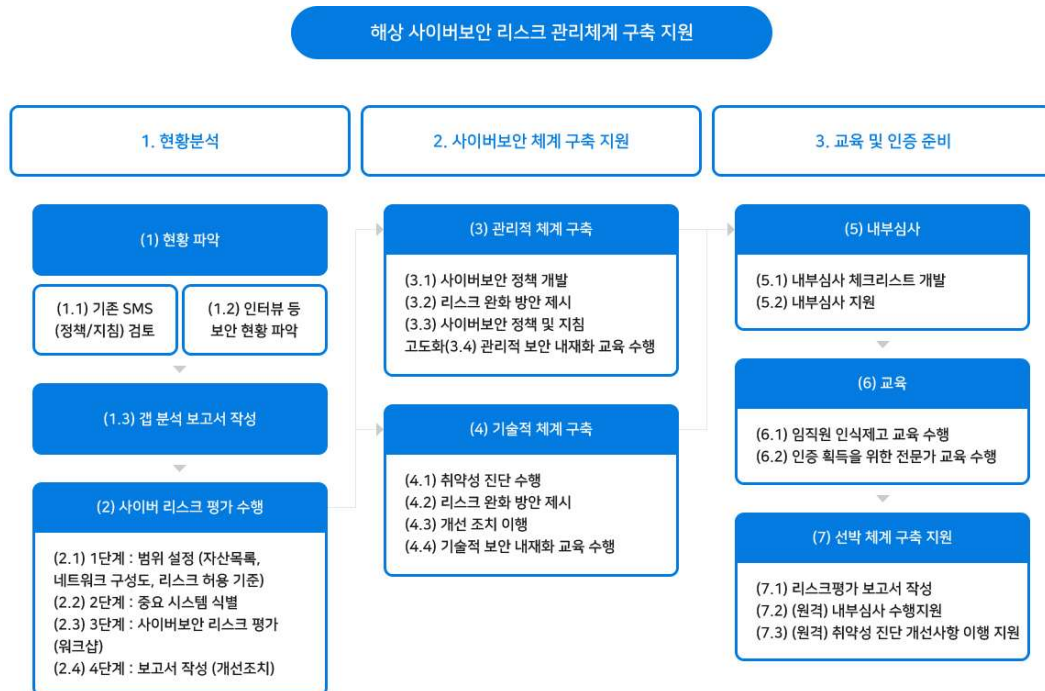
○ Best Practice (해결 방안)

경영진의 승인 하에 6개월간의 전사적 CSMS 구축 프로젝트를 PDCA 사이클에 따라 추진한다.

1. 1단계: 기반 구축 (1~3개월, Plan)

- **거버넌스 수립**: 해사본부장을 CISO로 임명하고, 관련 부서로 구성된 '사이버보안 위원회'를 발족한다.
- **전사 위험 평가**: 외부 전문 기관과 협력하여 선종별 대표 선박에 대한 리스크 평가를 수행한다.
- **정책 및 지침 제정**: 위험 평가 결과를 바탕으로 전사 사이버보안 정책 및 10여 종의 세부 지침(접근통제, 패치관리 등)을 개발하고 경영진의 승인을 받는다.

그림 4-6 ▶ 한국선급_해상 사이버보안 리스크 관리체계 구축 방법



출처 : 한국선급 사이버안전기술팀

2. 2단계: 실행 및 내재화 (4~9개월, Do)

- **보호 대책 이행:** 위험 처리 계획에 따라 우선순위가 높은 과제(예: OT-IT망 분리, 원격접속 MFA 도입)부터 예산을 투입하여 이행한다.
- **교육 및 훈련 프로그램 가동:** 전 선원 및 육상 직원을 대상으로 온라인 보안 교육을 실시하고, 분기별로 피싱 메일 모의훈련을 수행하여 보안 인식을 제고한다.
- **사고 대응팀(CERT) 공식화:** 비상대응조직을 공식 발족하고, 랜섬웨어 감염 시나리오 기반의 도상 훈련을 실시한다.

3. 3단계: 검증 및 개선 (10~12개월, Check & Act)

- **내부 감사 실시:** 감사팀이 CSMS 정책 및 지침이 현장에서 잘 준수되고 있는지 3척의 샘플 선박을 대상으로 내부 감사를 실시한다.
- **경영진 검토:** CISO는 내부 감사 결과, 훈련 결과, 위험 평가 결과 등을 종합하여 경영진에게 보고하고, 차년도 보안 투자 예산을 확보한다.
- **지속적 개선:** 감사에서 발견된 미비점(예: 백업 데이터 관리 부실)을 시정 조치하고, 관련 절차를 개정하여 전 선대에 전파한다. CSMS를 기존의 SMS 문서체계에 공식적으로 통합하여 매년 검토하고 개선하는 사이클을 정착시킨다.

기대 효과

- **규제 준수 및 증명:** ISM 감사 시 체계적으로 수립되고 운영되는 CSMS 기록(정책, 위험평가 보고서, 감사 결과 등)을 제시하여 규제 요구사항을 충족함을 명확히 증명할 수 있다.
- **전사적 보안 수준 상향 평준화:** 모든 선박과 조직에 일관된 보안 정책과 절차가 적용되어, 가장 취약한 연결고리를 제거하고 전사적인 보안 수준을 높인다.
- **사전 예방적 보안 문화 정착:** 일회성 대응이 아닌, 'Plan-Do-Check-Act' 순환 모델을 통해 위협을 사전에 예측하고 지속적으로 개선하는 성숙한 보안 문화를 조직에 내재화한다.

그림 4-7 ▶ 해양수산부, 해사 사이버보안 관리체계 구축 시범사업 결과



출처: 해양수산부, 해사 사이버안전 관리 강화 방안 연구 2024

자체평가를 위한 보안점검 체크리스트

5.1 인증 (Authentication)	64
5.2 접근/권한 통제 (Access/Privilege Control)	65
5.3 암호화 (Encryption)	65
5.4 부인방지 (Non-repudiation)	66
5.5 가용성 (Availability)	67
5.6 관리체계 (Management System)	67

※ 체크리스트 활용 안내

본 장에서 제공하는 스마트선박 보안점검 체크리스트는 『스마트선박 보안모델』의 보안 요구사항과 IACS UR E26/E27 등 국제 규정을 기반으로 개발된 실용적인 감사 도구이다. 이 체크리스트는 단순한 점검 목록을 넘어, 조직의 현재 보안 수준을 객관적으로 진단하고 개선 영역을 식별하며, 내부 및 외부 감사에 대비하기 위한 체계적인 프레임워크를 제공한다.

각 점검 항목은 구체적인 '확인 방법'과 필요한 '증빙' 예시를 포함하고 있어, 감사 수행자가 일관된 기준으로 평가를 진행하고, 피감사자는 어떤 증거 자료를 준비해야 하는지 명확히 인지할 수 있다. 이를 통해 조직은 스스로의 사이버 복원력 상태를 정량적으로 평가하고, 지속적인 보안 강화 활동의 기반으로 삼을 수 있다.

5.1 인증 (Authentication)

ID	점검 항목	확인 방법	관련 요구사항	점검 결과	증빙
CHK-인-01	육상에서의 원격 접속 및 선내 중요 시스템(ECDIS, IAS 등) 접근 시 다중 인증(MFA)이 적용되고 있는가?	- 원격접속/VPN·중요 시스템 로그인 화면 MFA 요구 시험 - 세션 타임아웃/원격세션 종료·ID 무효화 동작 검증	• 인-02, 03 • E26 2.6 • E27 31, 35,36,37,40,41		- 원격 접속 정책 문서 - MFA 솔루션 정책 스크린샷 - 세션 종료 로그
CHK-인-02	모든 사용자 및 기기에 고유 식별자가 부여되고, 안전한 비밀번호 정책(길이, 복잡도, 주기 등)이 적용 및 강제되고 있는가?	- 계정·패스워드 정책, AD GPO/PAM 설정 확인 - 초기 패스워드 강제 변경·공용계정 금지 확인	• 인-01, 05 • UR E27 1,2,3,4,5,7,33		- 패스워드 정책 문서 - AD GPO/PAM 설정 화면

5.2 접근/권한 통제 (Access/Privilege Control)

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK-접-01	서버실, 통신실 등 중요 구역에 대한 물리적 접근이 통제되고 있으며, 사용하지 않는 네트워크 포트는 비활성화 또는 차단되어 있는가?	- 통제 구역 시건 장치 상태 및 출입 기록부 현장 확인 - 스위치 설정에서 미사용 포트 shutdown 여부 확인 - 물리적 포트 블로커 사용 현황 확인	• 접-03, 09 • E26 2.1, 2.2, 2.4		- 출입 관리 대장 사본 - 스위치 설정 파일
CHK-접-02	중요 업무망(OT)과 일반 업무망(IT)은 물리적 또는 논리적(VLAN)으로 분리되어 있으며, 경계 구간은 방화벽으로 통제되는가?	- 네트워크 구성도 (물리/논리) - 스위치 VLAN 설정 및 라우팅 테이블 확인 - IT-OT 경계 방화벽 정책(Rule-set) 검토 (deny by default 룰셋)	• 접-03, 04 • E26 2.1, 2.2 • E27 18, 24		- 네트워크 구성도 - 방화벽 정책 (비실행) 네트워크 차단 - 예외 허용 사유서·만료 일 의무화
CHK-접-03	사용자 역할(선장, 기관장 등)에 따라 시스템 접근 권한이 차등 부여되고, 최소 권한 원칙이 준수되고 있는가?	- 역할 기반 접근 제어 (RBAC) 정책 - 시스템별 사용자/그룹 권한 설정 내역 확인 (AD, Linux 등) - 역할별 계정으로 실제 로그인하여 권한 테스트	• 접-08 • E26 2.4 • E27 8		- RBAC 정책 매트릭스 문서 (업무분리) - 시스템별 권한 설정 - 주기적 권한 재검토(하선 자 삭제 등)

5.3 암호화 (Encryption)

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK-암-01	선박-육상 간 원격 접속 및 민감 데이터 전송 시, VPN 등 검증된 암호화 통신(TLS 1.2 이상, AES-256 이상)이 적용되고 있는가?	- VPN 설정(프로토콜, 암호화 알고리즘) 확인 - 웹 서버의 TLS 프로토콜 및 암호화 스위트 설정 확인 - 네트워크 패킷 분석을 통한 암호화 여부 검증	• 암-02 • E26 2.5, 2.6 • E27 17, 21, 22		- VPN 정책 - TLS1.3 적용 및 취약점 진단 결과 - 무선WPA3/802.1X 적용

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK- 암-02	VDR 데이터, 시스템 로그, 백업 데이터, 로그인 인증 정보 등 민감한 저장 데이터는 암호화되어 있으며, 암호키는 안전하게 분리 보관되는가?	- 디스크 암호화(BitLocker, LUKS) 설정 확인 - 백업 솔루션의 암호화 정책 설정 확인 - 암호키 관리 정책 문서 및 키 관리 시스템(HSM, KMS) 접근 통제 내역 검토	• 암-01,03 • E26 5.2 • E27 21, 22, 38		- 키와 데이터 분리 보관 - 접근 로그 SIEM 연계 - 백업 정책 스크린샷 - 오프라인 백업 암호화

5.4 부인방지 (Non-repudiation)

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK- 부-01	주요 시스템의 사용자 접속, 설정 변경 등 중요 행위에 대한 로그가 생성되고 중앙 로그 서버(SIEM)로 전송되는가?	- 각 시스템의 로깅 설정(로깅 레벨, 대상 등) 확인 - 중앙 로그 관리 시스템(SIEM)의 로그 수집 현황 검토 - 로그 전송 실패 시 경보 체계 확인	• 부-01, 02, 03, • E26 3.1 • E27 13, 14, 15, 16, 23		- 시스템별 로깅 설정 가이드 - 전송실패 알람 내역 - 로그 저장 파티션 분리/임계치 알람
CHK- 부-02	모든 시스템의 시간은 신뢰할 수 있는 선내 NTP 서버와 동기화되고 있는가?	- 선내 NTP 서버 구성 및 GPS 수신 상태 확인 - 각 시스템의 NTP 클라이언트 설정(서버 주소) 확인 - 여러 시스템의 로그 시간을 비교하여 동기화 여부 확인	• 부-04, • E27 16		- NTP 구성도 - 시스템별 시간 동기화 설정 스크린샷
CHK- 부-03	수집된 로그는 위변조 및 삭제가 불가능하도록 보호 조치가 적용되어 있으며, 법적 요구 기간(해당 시) 동안 보관되는가?	- 로그 저장소 접근 권한 설정 검토 (읽기 전용) - 로그 파일 해시 값 생성 및 검증 절차 확인 - 로그 보관 정책 문서 및 실제 보관 상태 확인	• 부-05, • E27 14, 15, 23		- 로그 관리 정책 문서 - 로그 무결성 검증 결과 보고서 - 자동 로테이션 +알림

5.5 가용성 (Availability)

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK-가-01	중요 데이터 및 시스템에 대한 백업 정책이 수립되어 있고, 정기적으로 백업이 수행되고 있는가?	- 백업 정책 문서(대상, 주기, 보관 위치 등) 검토 - 백업 솔루션의 작업 로그를 통한 백업 성공 여부 확인 - 백업 원칙 준수 여부 확인 (오프사이트 백업 포함)	• 가-01 • E26 5.1, 5.2 • E27 26, 27		- 백업 정책 문서 - 최근 1개월 백업 작업 결과 로그
CHK-가-02	재해 복구 계획(DRP)이 문서화되어 있으며, 정기적인 복구 테스트 및 모의 훈련을 통해 실효성을 검증하고 있는가?	- 재해 복구 계획(DRP) 문서 검토 - 최근 수행된 복구 테스트 결과 보고서 검토 (RTO/RPO 달성 여부 포함) - 재해 복구 모의 훈련 계획 및 결과 보고서 검토	• 가-01 • E26 5.1, 5.3		- 재해 복구 계획 (DRP) - DR 모의 훈련 결과 보고서
CHK-가-03	안전 운항에 필수적인 시스템은 대체전원이 확보되어 있는가?	- 시스템 구성도를 통한 대체전원 구성 확인 - 장애 발생 시 자동 절체 (Failover) 기능 테스트 결과 검토 - 이중화된 전원 공급 장치 (UPS) 구성 및 테스트 결과 확인	• 가-02 • E27 20, 28		- HA(High Availability) 구성도 - 장애 복구 테스트 결과 보고서(정전 후 자동 서비스 활성화, 안전 출력상태)

5.6 관리체계 (Management System) 체크리스트

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK-관-01	전사 사이버보안 정책 및 세부 지침이 수립되어 있고, 최고경영진의 승인을 받았으며, 정기적으로(연 1회 이상) 검토되는가?	- 사이버보안 정책 및 지침 문서 검토 - 회의록 등 경영진 검토 및 승인 증거 확인 - 정책 개정 이력 확인	• 관리-01 • E26 사이버 복원력 프로그램 (CSRP) • IMO MSC. 428(98)		- 사이버보안 정책문서 - 사이버보안 위원회 회의록

ID	점검 항목	확인 방법	참조	점검 결과	증빙
CHK-관-02	선박 자산에 대한 정기적인 위험 평가(연 1회 이상)가 수행되고, 그 결과에 따라 보호 대책이 식별 및 이행되고 있는가?	- 위험 평가 방법론 및 절차 문서 검토 - 최근 위험 평가 결과 보고서 및 위험 처리 계획서 검토 - 위험 처리 계획의 이행 현황 및 결과 추적	• 관-02, • E26 사이버 복원력 프로그램 (CSRP) • IMO MSC. 428(98)		- 위험 평가 보고서 - 위험 처리 계획 및 이행 현황표
CHK-관-03	모든 선원 및 관련 임직원을 대상으로 정기적인(연 1회 이상) 사이버보안 교육 및 훈련이 실시되고 있는가?	- 연간 보안 교육 및 훈련 계획서 검토 - 교육 이수자 명단 및 훈련 결과(예: 피싱 메일 훈련 결과) 보고서 확인 - 교육 자료 및 평가 내용 검토	• 관-03, 06 • E26 사이버 복원력 프로그램 (CSRP) • IMO MSC. 428(98)		- 연간 사이버 보안 교육 계획 - 모의훈련 결과
CHK-관-04	공급망(조선소, SI, 제조사) 계약 시 보안 요구사항이 명시되고, 납품되는 제품에 대한 보안 검수 절차가 있는가?	- 표준 계약서 내 보안 관련 조항 검토 - 기자재/SW 도입 시 보안 검토 및 인수 테스트 절차서 검토 - 주요 공급업체/제품에 대한 보안 수준 평가 결과 확인	• 관리-05 • E26 사이버복원력 프로그램 (CSRP) • IMO MSC. 428(98)		- 공급 계약서 - SW 인수 테스트/보안성 검토 결과

1. 스마트선박 보안 솔루션 맵 및 해설	70
2. IACS UR E26/E27 요구사항-보호조치 연계표	77
3. 스마트선박 보안모델 적용 사례집	80
4. 용어 정의	170



1 스마트선박 보안 솔루션맵 및 해설

0 보안 솔루션 맵



보안 솔루션

01. 네트워크 보안

01-1. 네트워크 접근제어(NAC) 솔루션

넷맨	Smart NAC
베이스인네트웍스	imRAD N1
스콤정보통신	IPScan NAC
시큐센	DynaPath
시큐어레터	Anyclick AUS
아이앤아이맥스	LANKeeper
에어큐브	Wireless LAN(5G) Identity Suite
엔트로링크	PPX-AnyLink
엠엘소프트	Tgate
휴네시온	i-one NAC

01-2 무선 네트워크 보안 솔루션

삼성전자	WES Express
시큐아이	BLUEMAX WIPS
시큐어레터	DeepTrustAIR
심플솔루션	SecuAir WIPS
코닉글로리	TESS AIRTMS
트러스트에스	AirTMS
퓨처시스템	WeGuardiaTM WIPS

01-3 계정/접근권한 관리 솔루션

넷앤드	HIWARE
디에스멘토링	Chakan IDM
소프트프릭	i-SeMOS
시큐러스	CIEAM
시큐브	iGRIFFIN
에스지앤	SecureGuard IAM
엘에스웨어	Omni-IM

01-4 가상 사설망(VPN)

노르마	Q Care Connect
-----	----------------

수산아이앤티	eWalker SSL VPN
시큐리티플랫폼	AxioVPN
시큐위즈	SecuwaySSL U
안랩	TrusGuard SSL VPN
앤솔루션	NetSplitter
엠진	QUANTWALL
에이엔알	TS-Way
엑스게이트	AXGATE SSL VPN
지란지교에스앤씨	F5 APM
펜타시큐리티	Cloudbric VPN
퓨처시스템	WeGuardiaTM sslplus
지니언스	SSL PNS
프라이빗테크놀로지	PRIBIT Connect
XN시스템즈	Neoconnect

01-5 방화벽(네트워크 방화벽, UTM, NGFW 등 포함)

넥스지	NexG FW
두루안	ShadowWall
시큐아이	BLUEMAX NGF
엑스게이트	AXGATE NGFW
엔피코어	npFirewall
원스	Sniper NGFW
유솔정보통신	방화벽
퓨처시스템	WeGuardiaTM FW
피플러스	AXGATE Series
한국통신인터넷기술	iWall
한비로	NetScreen UTM
XN시스템즈	Neobox

01-6 웹방화벽(WAF)

모니터랩	APPLICATION INSIGHT WAF
수산아이앤티	eWalker WAF
시큐아이	AIWAF

1

2

3

4

5

6

시큐온클라우드	DeepFinder WAF
유솔정보통신	웹방화벽
지란지교에스앤씨	F5 AWAFF
파이오링크	WEBFRONT-K
펜타시큐리티	WAPPLES

01-7 침입탐지시스템(IDS)

삼성 SDS	Darktrace EIS
ATOMICORP	OSSEC
CISCO	Snort (오픈소스)
Hillstone	SBDS
NETSCOUT	Omnis Enterprise IDS
Suricata	Suricata (오픈소스)

01-8 침입차단시스템(IPS)

넷코아테크	NET-Insider
시큐아이	BLUEMAX IPS
안랩	Ahnlab AIPS
엑스게이트	AXGATE IPS
원스	Sniper ONE-i
티앤디소프트	TnD-MIBS
TREND MICRO	TippingPoint Threat Protection System

01-9 네트워크 모니터링 시스템 (NMS)

그루네트웍스	와츠업골드
솔텍	솔텍
와치텍	와치텍
와탭랩스	NPM
지케스	NMS
Fiberroad	WBNMS
Hytera	TETRA NMS
ManageEngine OpManager	ManageEngine OpManager
Nagios	Nagios Network Analyzer
Ntop	ntopng

Observium	Observium
PAESSLER	PRTG Network Monitor
Solarwinds	Network Performance Monitor
zabbix	zabbix

02. 시스템(단말) 보안

02-1 악성코드/랜섬웨어 대응 솔루션

나무소프트	FilingBox MEGA V2
드림시큐리티	Magic mVaccine
라운시큐어	TouchEn mVaccine
롯데이노베이트	SecuFy White
세이퍼존	Anti-RansomWare
소만사	Webkeeper
시큐리온	OnAV
시큐센	Applron Vaccine
시큐어링크	RansomKeeper
씨엠테스	랜섬디엠지 프로
안랩	AhnLab V3 Endpoint Security 9.0
에브리존 터보백신	터보백신
에브리존 화이트디펜더	WhiteDefender
에스엠테크놀로지	DocStory
에스지에이피에스	VirusChaser
엔에스에이치씨	Droid-X
이노티움	Ransom Cruncher
이스트시큐리티	알약
지란지교시큐리티	새니톡스
지행아이티	mpProtect
플라리스오피스	V-Guard
하우리	바이로봇 시큐리티

02-2 지능형 지속공격대응(APT)

시큐레터	MARS V2
안랩	AhnLab MDS
에스에스알	MetiEye

엔피코어	ZombieZERO EDR
원스	Sniper APTX-T
유엠브이기술	ShellMonitor
한우리	바이로봇 APT Shield 2.0

02-3 엔드포인트 탐지 및 대응(EDR)

소만사	Privacy-1
안랩	AhnLab EDR
에스엠테크놀러지	DocStory
이스트시큐리티	알약 EDR
지니언스	Genian EDR
트루컷시큐리티	trueEP

03. 정보유출 방지

03-1 데이터 유출 방지 솔루션(DLP)

마크애니	Privacy SAFER
세이퍼존	Multi-OS DLP
세토피아	SafePC Enterprise
소만사	Mail-i
솔루피아	ESCORT
수산아이엔티	eWalker DLP
시큐센	Applron
엔트랙시스템	nTracker Enterprise 7
와이즈하브시스템즈	GRADIUS DLP
워터월시스템즈	WaterWall DLP
잉카인터넷	TACHYON UMS 4.0
조은아이앤에스	Blue X-ray DLP
지란지교소프트	OfficeKeeper
지란지교시큐리티	다큐원
컴트루테크놀러지	설록홈즈 PC정보보안
코소시스코리아	Endpoint Portector 5
크리니티	MAILBREAKER
킹스정보신	KESS Guard Zone
한컴위드	Hancom SoliDocs

03-2 보안 USB

디지털센스	보안USB(Smartsecure-USB)
세이퍼존	보안 USB
소프트와이드 시큐리티	암호화 보안USB
스마트키퍼	USB 포트락
워터월시스템즈	WaterWall USB
잉카인터넷	nProtect Defenstick 32GB
채울	uToken combo 2.1

04. 암호/인증

04-1. 인증 솔루션(2factor 인증, MFA 인증)

넷앤드	Mobile OTP
드림시큐리티	Magic MFA
라운시큐어	TouchEn Wiseaccess
라톤테크	Rathon-SSO
반디에스앤씨	Bandi SSO
센스톤	OTAC Dynamic Token
스파이스웨어	Spiceware One ZTS
시큐러스	CISSO
시큐브	SECUBE Q인증
시큐브	SecuSign
에스지앤	SecureGuard OTP
유비엔티스랩	Pass-Ni SSO
이니텍	INISAFE Nexess
이셋	Secure Authentication
케이사인	KSignAccess for SSO
한컴위드	Safeldentity
AWS	AWS Identity and Access Management(IAM)
CISCO	DUO
HID	HID Approve™
IBM	IBM Security Verify
LastPass	LastPass MFA
Microsoft	Azure Active Directory
Okta	Workforce Identity Cloud
Ping Identity	PingOne

삼성 SDS	SingleID
04-2. 전송구간 암호화(SSL)	
다우기술	SSL 인증서
드림시큐리티	Magic TLS
모니터랩	AISVA
수산아이엔티	ePrism SSL VA
아이넷피아커뮤니케이션	Comodo
엑스게이트	AXGATE SSL INSIDE
예스닉	보안서버인증서
상상너머	GoGetSSL Domain SSL
파인앤서비스	Sectigo Basic DV
플랜티넷	OfficeGuard SV
카페24	SSL 스탠다드
트레이드사인	보안서버(SSL) 인증서
한국기업보안	GlobalSign Alpha SSL
한국전자인증	SSL 인증서
한비로	Positive SSL.
한컴위드	Hancom xConnect

05. 보안관리

05-1. 취약점 진단 솔루션	
나일소프트	Secuguard NSE
넷맨	Smart SIG
노르마	AtEar
노바소프트	취약점 통합관리 포털(V-TRON)
세이퍼존	PC보안평가
슈어소프트테크	STATIC
스패로우	DAST
시큐아이	BLUEMAX CLIENT
아카이브테크놀로지	Code Insure
안랩	ESA(EPP Security Assessment)
에스에스알	SolidStep CCE
에스에스앤씨	Nexplant OT-Viewer
엘에스웨어	SecuMS

엠시큐어	vFinder
인섹 시큐리티	AppScan
정보라인	BigLook
지니언스	Genian GPI
지란지교에스앤씨	VADA
지인소프트	Comvoy S+
지티원	SecurityPrism
코드마인드	CODEMIND
쿠크	Cybellum
트리니티소프트	CODE-RAY XG
한국선급	KR-Tester

05-2. 모니터링 및 로그분석 솔루션(ESM/SIEM)

나일소프트	LogCops
넷크루즈	BigEye
디에스멘토링	Chakan SAC
브레이즈컴퍼니	Zenius SIEM
시큐레이어	eyeCloudSIM
시큐브	LogGRIFFIN
시큐아이	BLUEMAX TAMS
시큐어시스템즈	SECURE ORCHESTRA
싸이버원	PROM SIEM
씨큐비스타	NextGen NDR
안랩	AhnLab TMS
에스지에이솔루션즈	EnterpriseCastle
엑스게이트	AXGATE TMS
엘에스웨어	Omniguard USAM
와이즈하브시스템즈	WiseBEAM
와치택	WatchLog
웨어밸리	Log Catch
위즈코리아	WEEDS BlackBox Suite
이글루코퍼레이션	SPiDER TM
이너버스	LogCenter
인스피언	BizInsider PLUS
케이엑스넥스지	NexG ESM

코낙글로리	TESS TMS
쿤텍	AEGIS
쿼드 마이너	Network Blackbox
쿼리시스템즈	OTIE
파이오링크	TiController
퓨처시스템	WeGuardiaTM ITM
피애피시큐어	INFOSAFER

05-3. 패치 관리 솔루션(PMS)

세이퍼존	보안패치
아데나소프트	SW원격배포
아이티스테이션	Top Aegis PRS
안랩	AhnLab EPM
에스지에이네트웍스	PatchChaser
엔엔에스피	nNetTrust
이스트시큐리티	알약 패치관리(PMS)
지안소프트	ComVoy PMS
하우리	ViRobot PMS

05-4. 백업/복구 솔루션

글루시스	Acronis
넷앤시큐	ARCH5
두루안	ShadowBackup
시큐플렉스	PC-SECURITY
씨엠에스	트라이 HA / 트라이 백업 솔루션
유엔아이소프트	BX Appliance™
이스트소프트	랜섬쉴드
핀테크	WORM Storage
파수닷컴	Wrapsody

06. 선박 사이버보안

06-1. 선박 사이버보안 솔루션

쿤텍	TeraGRID for Maritime
한화시스템	SecuAider
이글루코퍼레이션	SPiDER OT for Maritime

CyberOwl	Medulla
CYDOME	Cydome EverShield

06-2. 사이버보안 관제 및 운영 (SOC)

쿤텍	TeraGRID for Maritime
이글루코퍼레이션	SPiDER OT for Maritime
CYDOME	Cydome 24/7 SOC Managed Services
PORT-IT	VANIR COMPLETE

06-3. 선박 사이버보안 교육

한국선급(이러닝)	해사 사이버보안 교육
한국선급(오프라인)	사이버복원력 교육
ABOAMARE	Maritime Cyber Security Introduction Course
BSTC	해상 사이버 보안
Cyber Risk GmbH	해양 산업을 위한 사이버 보안 교육
GALLAGHER MARINE ACADEMY	바다에서의 사이버 위험
GLASSGOW maritime academy	해상 사이버 보안 훈련(MACSET)
LIBEROGROUP	해양 사이버 보안 인식 교육 과정
MAERSK TRAINING	STCW ISPS 보안 인식 e러닝
Marinerskills	해상 사이버 보안
Maritime Academy Training	해양 사이버 보안
MITAGS	해양 사이버 보안 훈련
NEMO	해양 사이버 보안 필수 사항
Ocean Learning Library	사이버 보안 인식 교육 과정
ROOD BOVEN GROEN	해상 보안 교육 과정(STCW)
Rushing Marine	보안 교육
Seably	해양 사이버 보안 인식 교육
SQEMARINE	사이버 보안 인식 교육 과정
SQLearn	선박 승무원을 위한 사이버 보안 인식 교육
STCWDirect	해양 사이버 보안 인식
The Nautical Institute	선원을 위한 해양 사이버 인식
VIRSEC	선원을 위한 사이버 보안 인식

표 6-1 ▶ 스마트선박 보안솔루션 해설표

분류	코드	솔루션 명칭	주요 기능
1. 네트워크 보안	01-1	네트워크 접근제어 솔루션 (NAC)	비인가/취약 단말의 네트워크 접속 차단 및 격리
	01-2	무선 네트워크 보안 솔루션 (WIPS)	비인가 AP 탐지 및 차단, 무선 트래픽 분석
	01-3	계정/접근권한 관리 솔루션 (IAM/PIM)	계정 라이프사이클 관리, 권한 신청/승인, 접근 제어
	01-4	가상 사설망 (VPN)	공용망을 통한 통신 구간 암호화 터널링
	01-5	방화벽 (UTM, NGFW)	네트워크 구역 간 접근 통제, 트래픽 필터링
	01-6	웹 방화벽 (WAF)	웹 애플리케이션에 대한 공격(SQL Injection, XSS 등) 탐지 및 차단
	01-7	침입탐지시스템 (IDS)	네트워크 트래픽을 모니터링하여 악의적인 활동 탐지 및 경고
	01-8	침입방지시스템 (IPS)	IDS 기능에 더해 탐지된 악성 트래픽을 실시간으로 차단
	01-9	네트워크 모니터링 시스템 (NMS)	네트워크 장비의 성능 및 장애 모니터링
2. 시스템(단말) 보안	02-1	악성코드/랜섬웨어 대응 솔루션 (백신)	알려진 악성코드 탐지, 치료, 예방
	02-2	지능형 지속위협 대응 (APT)	샌드박스 기반으로 알려지지 않은 악성코드 행위 분석 및 탐지
	02-3	엔드포인트 탐지 및 대응 (EDR)	단말의 상세 행위 기록 및 분석을 통한 위협 탐지 및 대응
3. 정보유출 방지	03-1	데이터 유출 방지 솔루션 (DLP)	민감 정보의 외부 유출(네트워크, USB 등) 탐지 및 차단
	03-3	보안 USB	암호화, 접근 제어 기능이 탑재된 중앙 관리형 USB
4. 암호/인증	04-1	인증 솔루션 (SSO, MFA)	통합 인증, 다중 인증(OTP, 인증서, 생체인증 등) 제공
	04-2	전송구간 암호화 (SSL/TLS)	웹 통신 등 특정 서비스 구간 암호화
5. 보안관리	05-1	취약점 진단 솔루션	시스템 및 네트워크의 보안 취약점 스캔 및 분석
	05-2	통합보안관제 솔루션 (ESM/SIEM)	다양한 시스템의 보안 로그 통합 수집, 상관관계 분석 및 관제
5. 보안관리	05-3	패치 관리 솔루션 (PMS)	OS 및 응용 프로그램의 보안 패치 중앙 관리 및 배포
	05-4	백업/복구 솔루션	데이터 및 시스템의 정기적 백업 및 신속한 복구 지원
6. 선박 특화 보안	06-1	선박 사이버보안 솔루션	선박 OT 프로토콜 분석 등 해상 환경에 특화된 보안 기능 제공
	06-2	선박 사이버보안 관제 및 운영 (SOC)	선박 보안 이벤트에 대한 24/7 전문 원격 관제 및 대응 서비스
	06-3	선박 사이버보안 교육	선원, 육상 관리자 등 역할별 맞춤형 보안 인식 교육 및 훈련

2. IACS UR E26/E27 요구사항-보호조치 연계표

본 표는 IACS 공통규칙(UR)의 주요 요구사항과 본 이행 가이드에서 제시하는 보호조치 및 관련 해설 섹션을 직접적으로 연계하여, 규제 준수를 위한 경로를 제공한다.

표 6-2▶ IACS UR E26/E27 요구사항-보호조치 연계표

IACS UR	요구사항 요약	보안모델 보호기술
E26 1.1	선박 자산 목록	- 관-01(보안정책) - 관-02(위험평가)
E26 2.1	보안 구역/네트워크 분할	접-03(보안구역/분리)
E26 2.2	네트워크 보호 안전장치	- 접-04(유해트래픽 차단), - 접-09(불필요 서비스 금지)
E26 2.3	AV/멀웨어 방지/안티스팸	접-07(AV 설치)
E26 2.4	접근통제	- 접-02(비인가접속 제한) - 접-08(관리자 역할 분리) - 인-01(계정/암호)
E26 2.5	무선 통신	- 접-05(무선 네트워크 통제) - 암-02(전송구간 암호화)
E26 2.6	원격 접근 통제	- 인-03(외부 접속 시 이중인증) - 암-01(표준암호) - 부-01(로그인/로그오프 로깅)
E26 2.7	모바일/휴대 장치 사용 통제	접-01(이동저장매체 통제)
E26 3.1	네트워크 운영 모니터링	부-01(로그인/로그오프 로깅)
E26 3.2	CBS/네트워크 검증·진단 기능	- 관-05(유지보수) - 부-01(로그인/로그오프 로깅)
E26 4.1	사고대응계획(IRP)	- 관-01(정책) - 관-06(사고대응)
E26 4.2	로컬/독립/수동 운전	- 관-06(사고대응) - 가-01(백업 및 복구)
E26 4.3	네트워크 격리	- 접-03(보안 구역) - 관-06(사고대응)
E26 4.4	최소 위험 상태	- 가-01(백업 및 복구) - 관-06(사고대응)
E26 5.1	복구 계획	- 가-01(백업 및 복구) - 관-01(보안정책)
E26 5.2	백업/복구 기능	가-01(백업 및 복구)
E26 5.3	제어된 셧다운·재설정·롤백·재시작	가-01(백업 및 복구)
E27 4.1.1	사용자 식별·인증 (총칙)	- 인-01(사용자 계정 생성 및 관리) - 인-05(패스워드 관리)
E27 4.1.2	계정 관리	인-01(사용자 계정 생성 및 관리)
E27 4.1.3	식별자 관리	인-01(사용자 계정 생성 및 관리), 접-08(관

IACS UR	요구사항 요약	보안모델 보호기술
		리자 역할 분리)
E27 4.1.4	최초 인증자 패스워드 강제 변경	• 인-05(패스워드 관리)
E27 4.1.5	인증자 관리	• 인-04(인증정보의 평문정보 하드코딩 제한) • 인-05(패스워드 관리)
E27 4.1.6	무선 접근 관리	• 접-05(무선 네트워크 통제)
E27 4.1.7	인증자 피드백	• 접-10(로그인 실패 사유 단일 메시지)
E27 4.1.8	권한부여 시행 (최소권한·직무분리)	• 접-08(관리자 역할 분리)
E27 4.1.9	무선 사용 통제	• 접-05(무선 네트워크 통제)
E27 4.1.10	휴대/모바일 장치 사용 통제	• 접-01(이동저장매체 통제)
E27 4.1.11	모바일 코드(ActiveX 등) 자동 실행 제한	• 접-09(불필요 서비스 금지)
E27 4.1.12	세션 잠금	• 접-06(로그오프 또는 세션종료)
E27 4.1.13	감사가능 사건 (로그 생성)	• 부-01(로그인/로그오프 로깅), • 부-02(관리자/운영자 로깅) • 부-03(계정/권한 관리 내역 로깅)
E27 4.1.14	감사로그 저장 용량 관리 및 경보	• 부-05(로그 정보 위/변조 방지)
E27 4.1.15	감사로그 처리 실패 시 대응 (경보 등)	• 부-05(로그 정보 위/변조 방지)
E27 4.1.16	타임스탬프 (시간 동기화)	• 부-04(시간 동기화)
E27 4.1.17	통신 무결성	• 암-02(전송구간 암호화)
E27 4.1.18	악성코드로부터 보호	• 접-07(AV 설치)
E27 4.1.19	보안 기능(AV, 접근제어 등) 검증	• 관-05(유지보수)
E27 4.1.20	시스템 장애 시 결정론적 출력 (안전모드)	• 가-01(백업 및 복구)
E27 4.1.21	정보 기밀성 (저장 데이터)	• 암-03(사용자 인증 정보 암호화)
E27 4.1.22	검증된 암호화 알고리즘 사용	• 암-01(표준 암호화 준수)
E27 4.1.23	감사로그 접근성 (읽기 전용)	• 부-05(로그 정보 위/변조 방지)
E27 4.1.24	서비스 거부(DoS) 보호	• 접-04(유해 트래픽 차단)
E27 4.1.25	자원 관리 (보안 기능 자원 사용 제한)	• 관-05(유지보수)
E27 4.1.26	시스템 백업	• 가-01(백업 및 복구)
E27 4.1.27	시스템 복구 및 재구성	• 가-01(백업 및 복구)
E27 4.1.28	대체 전원 (가용성)	• 가-02(대체 전원)
E27 4.1.29	네트워크 및 보안 구성 설정	• 관-02(보안설정)
E27 4.1.30	최소화 기능	• 접-09(불필요한 서비스 금지)
E27 4.1.31	인간 사용자에게 대한 MFA	• 인-03(외부 접속 시 이중 인증)
E27 4.1.32	소프트웨어 프로세스·장치 식별·인증	• 인-02(업무용 단말기 인증)
E27 4.1.33	실패한 로그인 시도 제한	• 접-12(접속시도 횟수 제한)
E27 4.1.34	시스템 사용 알림	• 접-11(최종 접속시간 표시)
E27 4.1.35	비신뢰 네트워크 통한 접근 통제	• 접-02(비인가접속 제한)
E27 4.1.36	원격 접근 시 명시적 요청·승인	• 접-02(비인가접속 제한)

IACS UR	요구사항 요약	보안모델 보호기술
E27 4.1.37	원격 세션 종료	• 접-06(로그오프 또는 세션종료)
E27 4.1.38	암호 무결성 보호 (전송 데이터)	• 암-01(표준 암호화 준수) • 암-02(전송구간 암호화)
E27 4.1.39	입력값 검증 (구문, 길이, 내용)	• 관-02(보안설정)
E27 4.1.40	세션 무결성	• 접-06(로그오프 또는 세션종료) • 암-02(전송구간 암호화)
E27 4.1.41	세션 종료 후 ID 무효화	• 접-06(로그오프 또는 세션종료)

3. 스마트선박 보안모델 적용 사례집

3.1 지원 사업 개요

○ 배경

- 최근 선박 기술의 디지털 전환이 가속화되면서 통신, 항해·조타, 자동제어, 감시·보안 시스템 등 다양한 기자재가 네트워크 기반으로 운영되고 있다. 이로 인한 운항 효율성은 향상되었지만, 동시에 사이버 공격에 노출될 수 있는 범위가 확대되어 보안 위험도 증가하고 있다.
- 이러한 사이버 사고는 실제 운항 안전에 직접적인 영향을 미칠 수 있으므로 국제해사기구(IMO)와 국제선급협회(IACS UR E26/E27)는 기자재 단위의 보안 요구사항을 강화하고 있다.
- 이에 따라 본 사례집은 2024년~2025년 수행된 기자재 기업 대상 보안 컨설팅 사례 중, 기자재별로 보안 적용 효과가 명확하게 확인된 사례를 중심으로 정리하여 실무자가 시스템 개발 시 적용이 가능한 자료를 제공하고자 한다.

○ 지원 내용 및 유형

- 컨설팅 대상 기자재 유형은 다음과 같이 대분류-세부 분류가 가능하다.

기자재 유형	
▪ 네트워크 / 통신 시스템	▪ 선박 통신·데이터 송수신 장비
▪ 항해·조타 장비	▪ 조타기 제어 장치
▪ 보안·감시 시스템	▪ 통합보안관제시스템(SIEM) ▪ 선내 감시 카메라 및 녹화기(NVR)
▪ 기계·설비 제어 시스템	▪ 질소산화물 저감 장치(SCR) ▪ 선박평형수처리장치(BWTS) ▪ 보일러 자동제어 시스템 ▪ 안전·전력 모니터링 ▪ 전력/조명 자동제어 ▪ 통합 자동제어 통합 플랫폼(IAS) ▪ 엔진 구동 부품 데이터 통합 플랫폼(ECS)

- 본 사업에서는 IACS UR E27 기준으로, 선박 기자재 대상 보안 컨설팅을 지원하였다.

표 3-1▶UR E27 요구사항

구분	순번	요구사항	주요 점검 기능 항목
필수 요구 사항 신뢰 네트워 크	1	인간 사용자 식별 및 인증	로그인 기능 보안 적용 여부
	2	계정 관리	사용자 계정 관리 기능
	3	식별자 관리	계정 권한 관리 기능
	4	인증자 관리	최초 인증 사용자에게 대한 관리 기능
	5	무선 접근 관리	무선 로그인 인증 적용 여부
	6	패스워드 기반 인증 강도	패스워드 강도 검증하는 기능
	7	인증자 피드백	로그인 피드백 메시지 관리
	8	권한 부여	계정에 대한 권한 분리 가능 여부
	9	무선 사용 통제	무선 사용 제한 및 통제 기능
	10	휴대용 및 모바일 기기에 대한 사용 통제	휴대용 장치 및 모바일 장치 연결 제한
	11	모바일 코드	모바일 코드 자동 실행 방지
	12	세션 잠금	로그인 세션 연결 시간 제한
	13	감사가능 사건	감사 로그 생성 및 유형
	14	감사 저장 용량	감사 로그 저장 공간 관리 기능
	15	감사 처리 실패 대응	감사 로그 처리 실패에 대한 대응
	16	타임스탬프	감사 로그 시간 동기화 적용 여부
	17	통신 무결성	시스템 데이터 통신 구간에 암호화 적용
	18	악성코드로부터 보호	악성코드 보호 기능이 제공
	19	보안 기능 검증	시스템 보안 기능 제공
	20	결정론적 출력	비정상 작동 시 대체 기능 제공
	21	정보 기밀성	데이터 보안 표준 기술 사용
	22	암호 사용	안전한 암호화 알고리즘 사용
	23	감사 로그 접근성	감사 로그 접근 시 사용자 권한 검증
	24	서비스 거부 보호	DoS 보호 기능을 검증
	25	자원 관리	시스템 프로세스 우선순위 제한 가능 여부
	26	시스템 백업	설정 데이터 백업 기능 여부
	27	시스템 복구 및 재구성	백업된 데이터로 시스템 복구 기능 제공
	28	대체 전원	대체 전원 전환 적용 여부 검증
	29	네트워크 및 보안 구성 설정	시스템 기본 보안 강화 설정 기능 제공 검토
	30	최소화 기능	불필요한 기능 활성화에 대한 제한 기능
추가 요구 사항 비신뢰 네트워 크	31	인간 사용자에게 대한 다중 요소 인증	다중 로그인 기능 적용
	32	소프트웨어 프로세스와 기기의 식별 및 인증	신뢰 된 프로세스 및 연결 장치를 식별, 허가
	33	실패한 로그인 시도	로그인 지속적 시도 제한
	34	시스템 사용 알림	시스템 인증 전 경고 알림 메시지 표시
	35	비신뢰 네트워크를 통한 접근	비신뢰 네트워크 접근 통제
	36	명시적 접근 요청 승인	비신뢰 네트워크 접근 관리 기능
	37	원격 세션 종료	수동으로 원격 세션 종료 기능
	38	암호 무결성 보호	비신뢰 네트워크 통신에 대한 암호화 적용
	39	입력 검증	입력 데이터 검증
	40	세션 무결성	인증 세션의 무결성 여부 검증
	41	세션 종료 이후의 세션 ID 무효화	인증 세션에 대한 재사용 방지

3.2 보안 실증 사례

3.2.1 인간 사용자 식별 및 인증

🔍 점검 목적

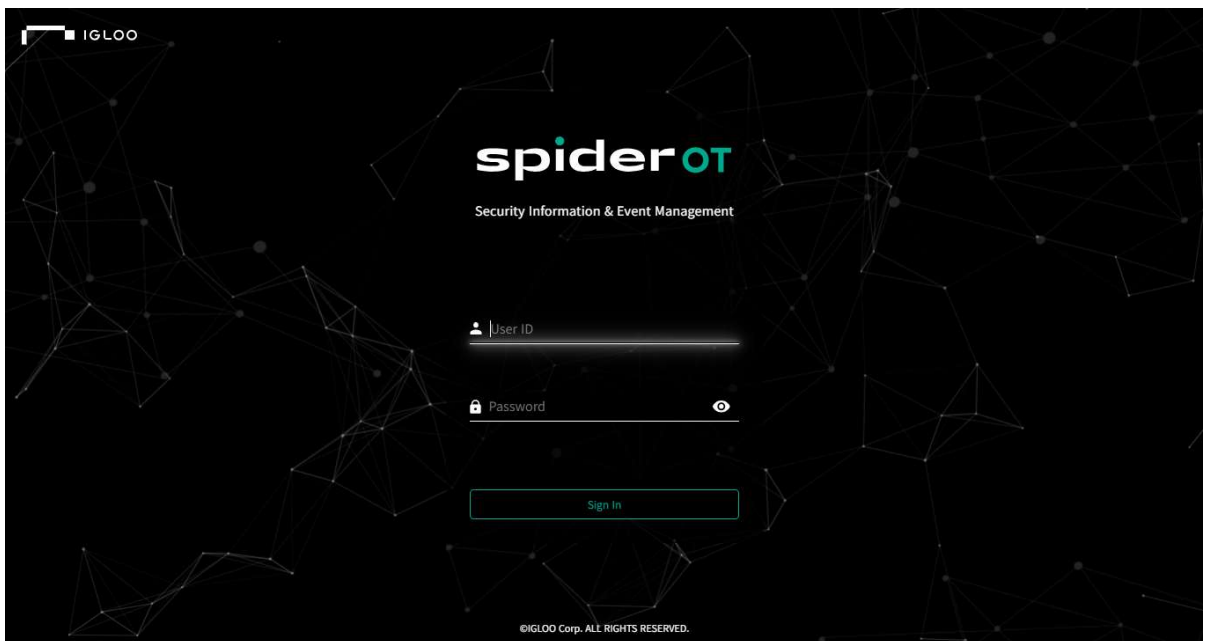
CBS에 접근하려는 모든 대상(사람, 소프트웨어 프로세스, 기기) 중 사용자(Human)의 식별 및 인증에 한정하여 보호 조치를 구현한다.

- 식별 : 사용자가 누구인지 확인할 수 있는 정보
(예시: 계정 이름(ID))
- 인증 : 식별자를 사용하는 사람이 본인임을 확인할 수 있는 정보
(예시: 비밀번호, 인증서, OTP, 생체 정보, 위치정보 등 수단)

🔍 점검 내용

- CBS 접근 시 로그인 인증 기능이 실제로 적절하게 적용되고 있는지 확인
- 여러 사용자가 동일한 ID를 사용하는 공유 계정(공용 ID)의 사용 여부 확인
- 로그인 ID 규칙 및 체계적 계정 관리 절차 존재 여부 확인

그림 3-1 ▶ 로그인 인증 기능 적용 사례



실증 사례

표 3-2 ▶ 실증 사례

내용	
우수 사례	• 모든 승무원에게 개인 계정 부여, 공유 계정 사용 금지 - CBS에 접근하는 모든 선원에게 개인 식별이 가능한 고유 계정을 부여하였다. - 과거 일부 장비에서 관행적으로 사용되던 공유 계정은 모두 폐지하고, 모든 조작과 로그인 활동이 개인별로 기록되도록 체계를 마련하였다. • 개인 계정으로 CBS 접근 시 ID/Password 인증 적용 - 모든 개인 계정 로그인 시 ID와 비밀번호 기반 인증을 필수화하였다. - 로그인 실패 시 계정 잠금 및 세션 타임아웃 등 보안 기능을 적용해 무단 접근 시도를 효과적으로 차단하였다. • 계정별 접근 이력 기록으로 책임 추적성 확보 - 각 계정의 로그인 내용, 설정 변경, 접근 이벤트 등을 감사 로그에 기록하였다.
미흡 사례	• ID/Password 기반 인증 없이 시스템 기능 접근 - 일부 시스템 기능이 개인 계정 로그인 없이 시스템 내 접근 가능한 상태로 운영되었다. - 이로 인한 선원 누구나 별도 인증 절차 없이 주요 기능을 실행할 수 있어, 비인가 접근 위험이 존재하였다. • 관리자 계정이 공유 계정으로 사용됨 - admin 등 관리자 계정이 여러 사용자 간 공유 계정으로 사용되어, 각 사용자 접근 내역과 조작 책임 등이 구분되지 않았다. - 공유 계정 사용으로 인해 책임 추적성(Accountability) 확보가 불가하고, 보안 사고가 발생 시 원인 파악이 어렵다. • 인증 구조가 단일 비밀번호(숫자 키패드)에만 의존 - 로그인 인증이 단일 비밀번호에만 의존하여, 쉽게 비밀번호 획득 후 시스템에 접근할 수 있는 문제점이 존재하였다.

개선 권고사항

- CBS 로그인 기능 의무화 및 ¹⁾MFA 적용 검토
 - CBS 접근 시 반드시 ID/Password 인증을 적용하고, 가능할 경우 다중요소 인증(MFA) 도입을 검토한다.
- 개인 계정 중심 운영 및 공유 계정 금지
 - 모든 사용자는 개인 계정만 사용하고, admin 등 공유 계정은 즉시 사용 중단한다.
- 관리자 계정 최소화 및 비밀번호 정기 변경
 - 관리자 계정은 최소 인원만 사용하도록 제한하고, 비밀번호를 정기적으로 변경해 안전성을 강화한다.

1) MFA(Multi-Factor Authentication): 사용자 인증 시 두 가지 이상의 서로 다른 인증 수단을 통해 신원을 확인하는 보안 기술

3.2.2 계정 관리

🔍 점검 목적

CBS에서 사용되는 모든 계정에 대한 관리(추가, 수정, 제거, 활성화, 비활성화 등) 기능을 구현한다.

🔍 점검 내용

- 계정 생성 · 수정 · 삭제 기능 등 계정 관리 기능의 구현 여부
 - CBS가 계정 생성 · 수정 · 삭제 기능을 제공하는지 확인하고, 변경 이력 및 권한 검증, 삭제 시 즉시 접근 차단 등 핵심 통제 기능이 적절히 구현되는지를 점검한다.

그림 3-2 ▶ 계정 생성·수정·삭제 기능 적용 사례

실증 사례

표 3-3 ▶ 실증 사례

내용	
우수 사례	- 관리자 기능을 통한 계정 생성 · 수정 · 삭제 관리 - CBS의 관리자 메뉴에서 사용자 계정을 생성, 수정, 삭제할 수 있는 기본 관리 기능을 제공하고 있다. - 계정에 대한 즉시 비활성화 적용 - 퇴선/퇴직자 계정을 즉시 비활성화할 수 있는 기능이 마련되어 있어, 실시간으로 접근 권한을 차단할 수 있다. - 비인가 접근 위험을 효과적으로 제거하며, 보안 측면에서 우수한 통제 절차로 평가된다.
미흡 사례	- 관리자 계정이 여러 사용자에게 공유되어 사용됨 - 관리자용 계정이 여러 사용자에게 제공되어 동일한 계정으로 로그인하는 관행이 확인되었으며, 누가 어떤 작업을 수행했는지 식별이 어려워 책임 추적성(Traceability) 확보 불가능하다. - 이로 인한 선원 누구나 별도 인증 절차 없이 주요 기능을 실행할 수 있어, 비인가 접근 위험이 존재하였다. - 일반 사용자 계정도 계정 생성 · 수정 · 삭제가 가능한 구조 - 일반 사용자 권한에서도 계정 생성, 수정, 삭제 기능이 활성화되어 있는 설계 문제가 확인되었다.

개선 권고사항

- 관리자 계정 역할별 구분 및 개인 계정 분리
 - 관리자 계정은 역할(Role)별로 구분하고, 각 계정을 개인별로 분리하여 운영하도록 권고한다.
 - 이를 통해 계정별 책임 추적성을 확보하고, 권한 오남용을 방지할 수 있다.
- 장기간 미사용 계정 자동 비활성화 규칙 설정
 - 90일 이상 사용하지 않은 계정에 대해 시스템에서 자동으로 비활성화되도록 규칙을 설정할 것을 권장한다.
 - 이 기능을 통해 장기 미사용 계정으로 인한 비인가 접근 위험을 최소화하고, 계정 관리 효율성을 향상할 수 있다.

3.2.3 식별자 관리

🔍 점검 목적

CBS는 필요에 따라 계정별로 직무를 분리하고(예: 관리자, 일반 사용자 등), 권한별로 프로세스 또는 서비스에 대한 접근 권한을 그룹화하여 설정할 수 있는 기능을 제공한다.

🔍 점검 내용

- 관리자와 일반 사용자를 구분하고, 역할별 그룹으로 관리할 수 있는 기능의 구현 여부를 점검
 - 관리자 · 일반 사용자 등 역할별로 구분할 수 있는지, 그리고 이러한 역할을 그룹 단위로 묶어 권한을 체계적으로 관리할 수 있는 기능을 제공하는지 확인한다.

그림 3-3 ▶ 계정 권한 관리 기능 적용 사례

User/Permission Management				
List				
Search				
Search Results Total number: 3 Counts				
No	User ID	Username	Permissions Settings	Log Source Group Name
1	igloosec	igloo	총괄관리자	전체
2	test313	test313	그룹관리자	AGENT
3	user1	user1	그룹관리자	

🔍 실증 사례

표 3-4 ▶ 실증 사례

내용	
우수 사례	• 관리자 계정과 일반 사용자 계정을 분류하고 관리자 계정을 최소 인원으로 제한 - admin, operator 등 역할(Role) 기반으로 관리자 계정을 구분하여 운영한다. - 관리자 권한이 불필요하게 확산하는 것을 방지하고, 계정별 책임과 활동 기록이 명확하게 식별될 수 있도록 관리한다. • 동일 ID의 중복 사용을 엄격히 금지 - 전체 사용자 계정에 대해 사번 기반 또는 개인 식별형 ID 체계를 적용하여 사용자 구분을 명확히 하고 있으며, 계정 공유로 인한 추적성 저하 및 보안 위험을 방지하고 있다.
미흡 사례	• 관리자 · 운영자 계정의 권한 분리 없이 모든 사용자 공유 사용 - 일부 일반 사용자가 admin, operator 등 관리자 권한 계정을 공동으로 사용하고 있는 것으로 확인되었으며, 개인 식별 불가능한 공유 계정 사용은 책임 추적성을 저해하며, 관리 권한의 오남용 및 비인가 설정 변경 위험을 높이는 문제점이 있다.

- 기본 제공 및 사용하지 않는 관리자 계정 활성화 상태로 방치
 - 시스템 구축 시 제공되는 기본 계정 관리자 계정과 장시간 사용하지 않는 관리자 계정이 비활성화되지 않고 그대로 활성화 상태로 남아 있는 것이 확인되었다. 이는 외부 공격자가 가장 먼저 노리는 계정 유형으로, 별도 보호 조치 없이 유지되는 경우 비인가 접근 및 시스템 장악 위험을 증가시킨다.

❁ 개선 권고사항

- 이름 또는 직무 기반의 표준화된 ID 부여 규칙 적용
 - 계정 생성 시 사용자 이름 또는 직무(Role) 기반 규칙을 적용하여 ID를 체계적으로 부여하도록 개선할 것을 권고한다.
 - 일관된 ID 부여 규칙을 적용하면 사용자 혼선 및 계정 중복 생성 가능성을 줄일 수 있으며, 감사 로그 분석 시 개인 식별과 추적성과 투명성이 향상된다.

3.2.4 인증자 관리

◉ 점검 목적

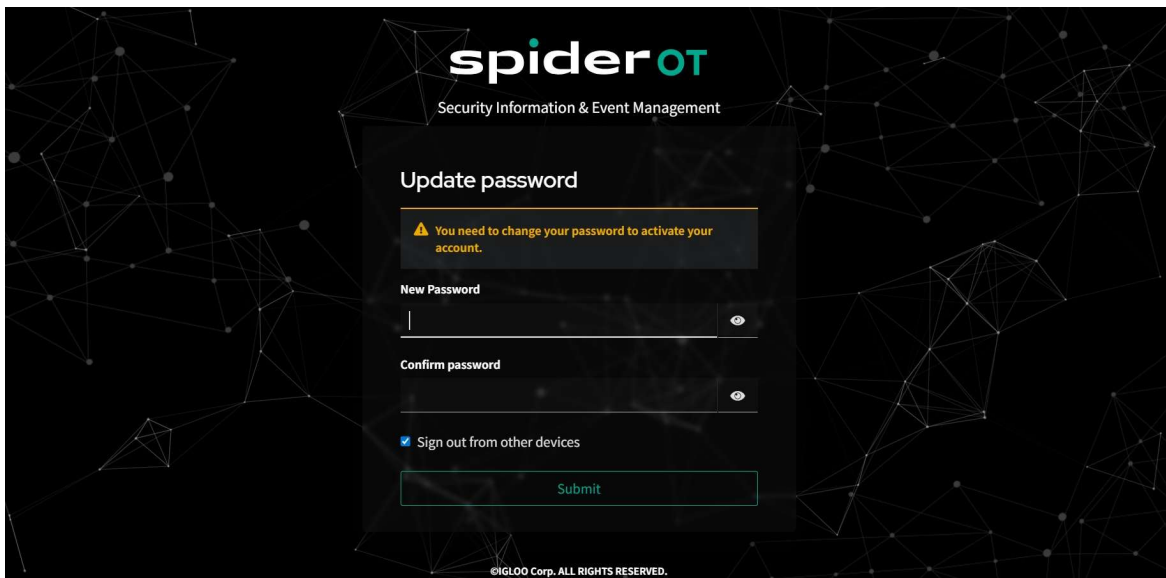
CBS는 최초 인증자에 대한 보안관리를 위해 아래의 기능을 제공해야 한다.

- 최초 인증자에 대해 강제 패스워드 변경을 적용
- 패스워드는 주기적으로 변경할 수 있도록 지원해야 하며, 암호화하여 저장하도록 보안 기능을 적용해야 한다.

◉ 점검 내용

- 최초 계정 생성 후 로그인 시 패스워드 강제로 변경 후 사용
 - 최초 제공된 기본 패스워드를 지속해서 사용할 경우, 이를 악용하여 악의적인 행위자가 CBS에 접근할 수 있으므로 이를 차단해야 한다.
- 모든 계정의 패스워드는 주기적 강제 변경 후 사용하도록 기능을 구현
 - 패스워드 사용 기간은 기본적으로 90일을 권고하나, 불가피한 사유로 불가능할 경우 내부 운영 방침에 따라 기간을 설정하고 이를 기록한다.

그림 3-4 ▶ 최초 로그인 인증 및 패스워드 사용 기간 만료 계정 강제 변경 적용 사례



◉ 실증 사례

표 3-5 ▶ 실증 사례

내용	
우수 사례	• 최초 로그인 시 비밀번호 강제 변경 기능 적용 - 신규 계정 또는 초기화된 계정으로 최초 로그인할 경우, 사용자가 비밀번호를 변경해야만 시스템 접근이 가능하도록 강제 설정되어 있다. 이를 통해 기본 패스워드 사용으로 인한 계정 탈취 위험을 방지하고, 초기 인증 정보의 안전성을 확보하였다.

	• 기본 관리자 계정(admin)의 명칭 변경 적용 - 시스템 기본 제공 관리자 계정인 admin 계정을 별도의 이름으로 변경하여 운영하고 있다. 이는 공격자들이 일반적으로 시도하는 기본 계정 기반 침입 시도를 효과적으로 차단할 수 있는 보안 강화 조치이다.
미흡 사례	• 최초 로그인 시 비밀번호 변경 강제 기능 미구현 - 신규 계정 또는 초기화된 계정이 최초 로그인할 때, 사용자가 비밀번호를 강제로 변경하도록 요구하는 기능이 적용되지 않았다. 이는 기본 패스워드나 알려진 초기 비밀번호가 장기간 사용될 가능성이 있으며, 계정 탈취 위험을 초래한다. • 기본 관리자 계정명(admin) 사용 - 시스템 설치 시 제공되는 기본 관리자 계정명(admin)이 변경되지 않은 채 사용되고 있다. 기본 계정명은 공격자들이 가장 먼저 시도하는 대상이므로, 계정명 변경 없이 운영되는 경우 무차별 대입 공격 및 인증 우회 시도의 위험이 증가한다.

개선 권고사항

- 최초 로그인 시 비밀번호 변경 의무화 적용
 - 신규로 생성된 계정이나 초기화된 계정은 최초 로그인 시 반드시 비밀번호를 변경하도록 강제해야 한다. 이를 통해 기본 패스워드가 장기간 사용되는 문제를 방지하고, 초기에 유출될 가능성이 있는 비밀번호를 즉시 제거함으로써 계정 안전성을 높일 수 있다.
- 기본 제공 계정의 비활성화 또는 변경을 통한 보안 강화
 - 시스템 설치 시 제공되는 기본 계정(admin 등)은 공격 대상이 되기 쉬우므로, 운영 환경에서는 계정을 비활성화하거나 별도의 이름으로 변경하여 사용하는 것을 권고한다.
- 비밀번호 주기적 변경 강제(90일 주기)
 - 관리자 및 일반 사용자 계정에 대해 90일 주기의 비밀번호 변경 정책을 적용하여, 장기간 동일 비밀번호 사용으로 인한 계정 탈취 위험을 최소화해야 한다.

3.2.5 무선 접근 관리

🔍 점검 목적

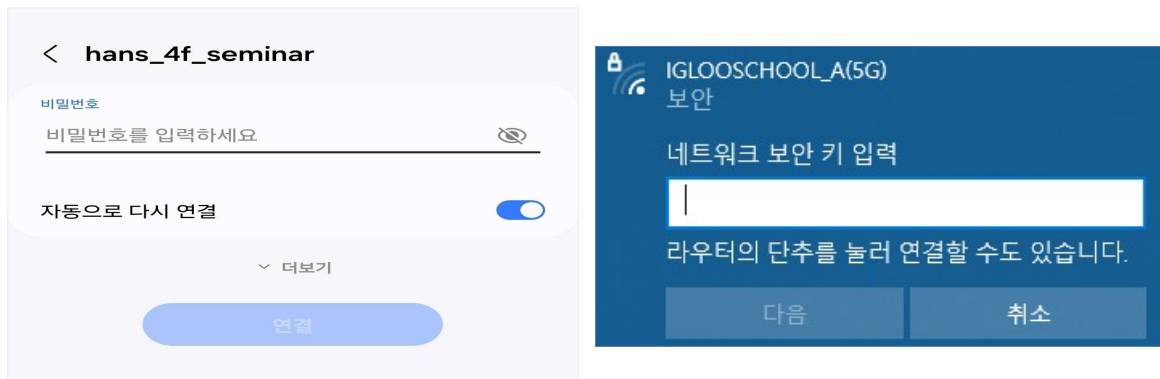
CBS는 무선 통신 서비스 기능을 제공하는 제품의 경우, 연결되는 모든 사용자와 장치 등을 식별 및 인증한 후 무선 서비스를 제공해야 한다.

- 이 요구사항은 CBS가 무선 네트워크 통신을 사용하는 경우에만 적용

🔍 점검 내용

- CBS가 무선 통신 기능 존재 여부 확인
 - 시스템 내부 또는 연결 장비에 Wi-Fi, Bluetooth, LTE 등 무선 모듈이 내장되어 있는지 확인하고, 필요하지 않은 모듈은 비활성화하여 잠재적 공격 경로를 차단한다.
- 무선 AP(Access Point) 활성화 여부 점검
 - 장비 또는 네트워크에 무선 AP 기능이 활성화되어 있는지 확인한다. 불필요한 AP는 보안 위험성이 높으므로 즉시 비활성화하고, 운영 중인 AP는 암호화 · 인증 설정이 기능이 있는지 점검한다.

그림 3-5 ▶ 무선 기능 연결 인증 적용 사례



🔍 실증 사례

표 3-6 ▶ 실증 사례

내용	
우수 사례	• 무선 연결 시 Password 기반 인증 적용 - 해당 CBS는 무선 네트워크에 접속할 때 반드시 Password 기반 인증 절차를 거치도록 구성되어 있다. 이를 통해 무선 구간에 대한 무단 접속을 효과적으로 차단하고, 승인된 사용자만 네트워크를 이용할 수 있도록 통제하고 있다. • 무선 AP 운영 시 2)WPA 이상 보안 인증 방식 적용 - 무선 AP는 WPA/3)WPA2 이상의 보안 프로토콜을 적용하여 운영되고 있다. 과거 취약한 4)WEP 방식이나 오픈(Open) 네트워크를 사용하지 않음으로써, 무선 구간에서 발생할 수 있는 패킷 스니핑, 무단 접속, 인증 우회 등 다양한 보안 위협을 감소시킬 수 있다.

미흡 사례	• 무선 AP에서 기본 SSID 그대로 노출 - 무선 AP가 제조사 기본 SSID로 운영되고 있어, 외부 연결이 노출될 위험이 존재한다. 기본 SSID는 공격 대상 식별이 쉬워, 보안상 변경이 필요한 항목이다. • 암호화 방식이 WEP 또는 OPEN 상태로 운영 - 무선 구간에서 취약한 암호화 방식을 사용하거나, 암호화 없이 OPEN 상태로 운영되고 있다. 이는 무선 구간의 데이터 탈취·위변조·비인가 접속 위험을 증가시키는 보안 취약점이다. • 무선 AP 인증 비밀번호의 취약 - 무선 인증 비밀번호가 단순 문자열, 짧은 길이 등으로 구성된 취약 암호로 설정되어 있어 무차별 대입 공격이나 추측을 통한 비인가 허용이 가능하다.
--------------	---

개선 권고사항

- 6)WPA3 또는 최소 WPA2로 보안 인증 강화
 - 무선 AP 인증 기술은 WPA3를 우선 적용하고, 장비 호환이 어려운 경우에도 최소 WPA2를 적용하여 강력한 암호화 기반의 무선 보안을 확보하도록 권고한다.
- 무선 네트워크 SSID 숨김 처리
 - SSID를 숨김으로 설정하여 외부에서 무선 네트워크를 쉽게 식별할 수 없도록 하고, 무단 연결 시도를 감소시키는 것이 바람직하다.

2) WPA: 초기 무선랜 보안 기술로 취약점이 많아 사용하지 않아야 함
 3) WPA2: WPA를 대체하며 AES 암호화를 도입하여 더 강력한 보안을 제공
 4) WEP: 초기 무선랜 보안 기술로 취약점이 많아 사용하지 않아야 함
 5) SSID: 무선 네트워크를 식별하고 구별하게 해주는 역할을 하는 Wi-Fi 네트워크의 고유한 이름
 6) WPA3: WPA2의 취약점을 보완하기 위해, 비밀번호가 쉬운 경우에도 오프라인 사전 공격을 방어할 수 있는 새로운 인증 방식

3.2.6 패스워드 기반 인증 강도

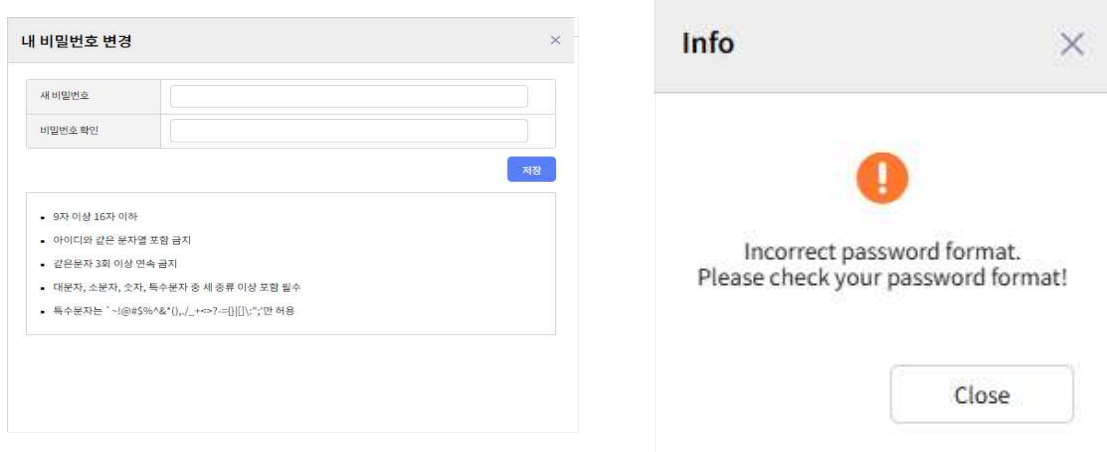
🔍 점검 목적

CBS는 패스워드 설정 및 저장 시 강도 검증(최소 길이와 다양한 문자 유형)을 제공해야 한다.

🔍 점검 내용

- 패스워드 정책 적정성 및 강제 기능 적용 여부 확인
 - 패스워드 최소 길이 기준이 충족되는지 확인한다.
 - 패스워드에 대문자, 숫자, 특수문자 등 문자 조합 규칙이 적용되는지 점검한다.

그림 3-6 ▶ 패스워드 입력 검증 기능 적용 사례



🔍 실증 사례

표 3-7 ▶ 실증 사례

내용	
우수 사례	• 최소 길이 8자 이상 강제 기능 적용 - 시스템에서는 패스워드 최소 길이를 8자 이상으로 설정하여, 짧은 패스워드로 인한 무차별 대입 공격 위험을 낮추고 계정 보안 수준을 강화하고 있다. • 대문자 · 소문자 · 특수문자 · 숫자 조합 필수 적용 - 패스워드 생성 시 반드시 대문자, 소문자, 특수문자, 숫자를 포함해야 하도록 구성하여, 단순 문자열 기반 사용을 방지하고 패스워드 복잡도를 강화하고 있다. • 패스워드 변경 시 강도 검사 적용 - 사용자 패스워드 변경 시, 입력된 패스워드에 대한 강도를 검사하여 취약하거나 단순한 패스워드는 설정할 수 없도록 제한한다.
미흡 사례	• 7자 이하 비밀번호 사용 - 패스워드가 7자 이하의 짧은 길이로 설정되어 있어 기무차별 대입 공격 및 8)사전 대입 공격에 쉽게 노출될 수 있는 취약한 상태로 운영되고 있다.

- 단일 문자 종류로 구성된 패스워드 사용
 - 패스워드가 숫자만 또는 영문 소문자만 등 단일 문자 유형으로만 구성되어 있어 복잡도가 매우 낮고, 공격자가 손쉽게 추측하거나 크래킹할 수 있는 위험이 존재한다.

● 개선 권고사항

- 패스워드 길이를 최소 8~9자 이상으로 상향 적용
 - 사용 중인 패스워드 정책을 강화하기 위해, 모든 계정에 대해 패스워드 최소 길이를 8~9자 이상으로 상향 적용할 것을 권고한다. 이는 짧은 패스워드 사용으로 인한 무차별 대입 공격 및 사전 공격 위험을 효과적으로 줄일 수 있다.
- 패스워드 재사용 금지 규칙 기능 적용
 - 과거에 사용했던 패스워드를 다시 사용할 수 없도록 재사용 금지 규칙을 적용하여, 동일한 패스워드 반복 사용으로 발생할 수 있는 계정 탈취 위험을 예방한다.
- 정기적인 패스워드 변경 주기(90일) 기능 적용
 - 모든 사용자 계정에 대해 90일 주기의 패스워드 변경 정책을 적용함으로써 장기간 동일 패스워드가 유지되는 것을 방지하고, 계정 보안을 주기적으로 강화하도록 한다.
- 패스워드 복잡성 검사 기능 적용
 - 대문자·소문자·숫자·특수문자 조합 여부 등을 자동으로 검사하는 패스워드 복잡성 검사 기능을 도입해 취약한 패스워드가 설정되는 것을 사전에 차단하도록 권고한다.

7) 무차별 대입 공격: 가능한 모든 비밀번호·키 조합을 자동으로 반복 입력하여 시스템을 강제로 침입하려는 공격 방식
8) 사전 대입 공격: 사전에 준비된 비밀번호 목록(단어·패턴 등)을 이용해 순차적으로 로그인 시도를 수행하는 공격 방식

3.2.7 인증자 피드백

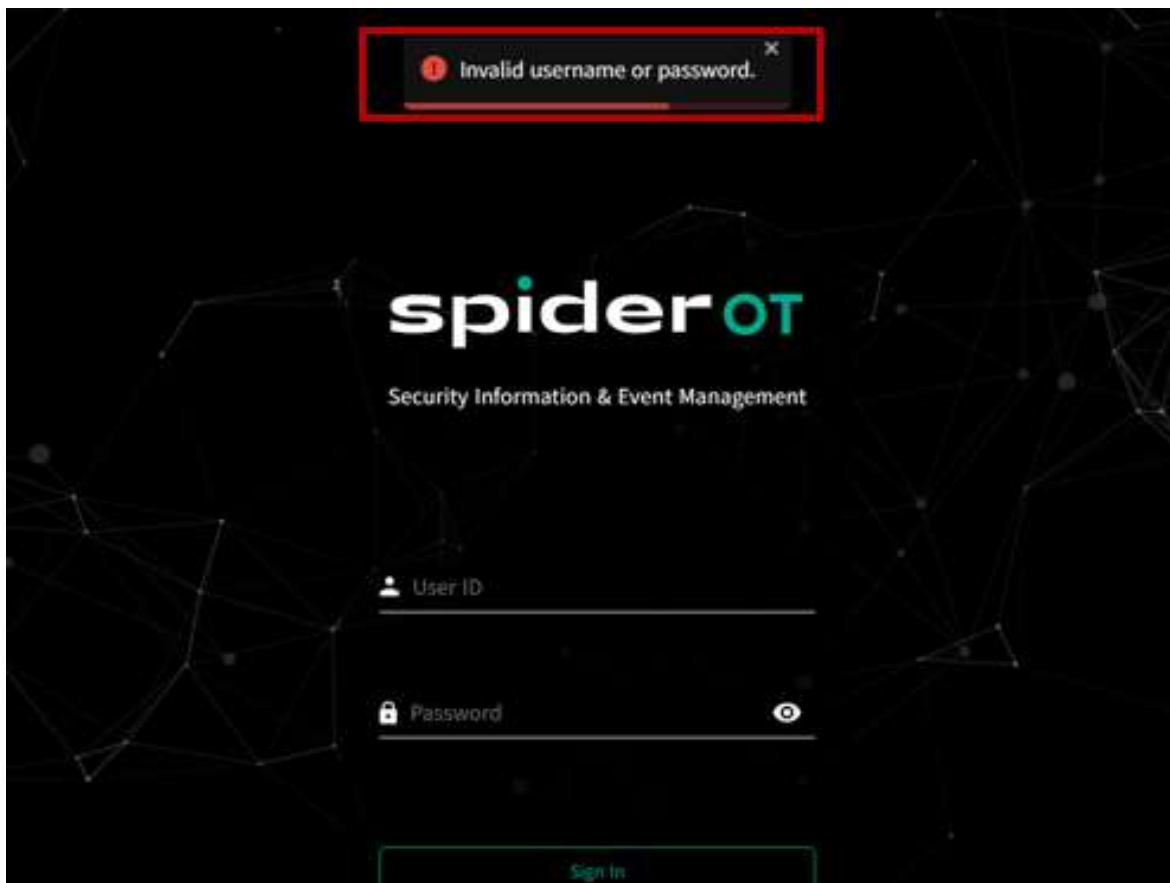
🔍 점검 목적

CBS는 인증 과정 중에 피드백을 사용자에게 잘 보이지 않도록 해야 한다.

🔍 점검 내용

- 로그인 실패 메시지 및 오류 응답 방식 점검
 - 로그인 실패 시 시스템이 출력하는 오류 메시지 표기 방식을 확인한다.
 - 존재하지 않는 사용자 ID 입력 시 출력되는 메시지가, 패스워드가 틀렸을 때 표시되는 메시지와 구분되어 제공 여부를 점검한다.
 - ID 오류와 패스워드 오류가 서로 다른 메시지로 구분될 경우, 공격자에게 사용자 존재 여부 정보를 제공할 수 있으므로 주의가 필요하다.

그림 3-7 ▶ 인증자 피드백 메시지 적용 사례



실증 사례

표 3-8 ▶ 실증 사례

내용	
우수 사례	• 단일 오류 메시지 방식 적용 - 시스템 로그인 실패 시 “사용자 이름 또는 비밀번호가 올바르지 않습니다.”와 같이 ID 오류·비밀번호 오류를 구분하지 않는 단일 메시지를 사용하고 있다. 이는 외부 공격자가 ID 존재 여부를 추측하지 못하도록 막는 효과적인 보안 방식이다. • ID 존재 여부 노출 방지 - 존재하지 않는 사용자 ID를 입력했을 때도 동일한 오류 문구를 표시하도록 설정되어 있어, 공격자가 ID를 추론하거나 무차별 대입 공격을 시도할 때 계정 추정이 불가능하다.
미흡 사례	• 존재하지 않는 사용자임을 명확히 알려주는 메시지 제공 - 시스템에서 존재하지 않는 ID로 로그인 시도를 할 경우, “존재하지 않는 사용자입니다.”와 같은 구체적 오류 메시지를 제공하고 있다. 이러한 메시지는 공격자에게 해당 ID의 존재 여부를 확인할 수 있는 단서를 제공하여, 계정 유추가 가능하며 사이버 공격에 악용될 가능성이 있다. • 패스워드 오류를 별도 메시지로 제공 - 로그인 시 패스워드가 틀리는 경우 “패스워드가 틀렸습니다.” 등 원인을 특정하는 메시지를 출력하고 있어, 공격자가 ID는 유효하고 패스워드만 틀린 상태임을 쉽게 파악할 수 있다. 이는 인증 단계에서의 정보 노출로 이어지며, 무차별 대입(Brute-force) 공격 시도를 더 정교하게 만들 수 있다는 점에서 보안상 미흡한 운영 사례이다.

개선 권고사항

- 인증 실패 메시지를 단일 문구로 통합 적용
 - 로그인 실패 시 “사용자 이름 또는 패스워드가 올바르지 않습니다.”와 같은 통합 메시지를 사용하도록 권고한다.
- 존재하지 않는 ID에도 동일 메시지 출력
 - 등록되지 않은 ID 입력 시에도 동일한 실패 메시지를 출력하여, ID 존재 여부를 외부에서 확인할 수 없도록 보호해야 한다.
- 피드백 최소화 원칙 준수
 - 오류 사유를 세부적으로 안내하지 않고, 최소한의 정보만 제공하는 보안 기본 원칙을 따르도록 개선을 권고한다.

3.2.8 권한 부여

🔍 점검 목적

모든 CBS의 인터페이스에서 사용자의 권한은 직무 분리와 최소 권한 원칙에 따라 할당되어야 한다.

🔍 점검 내용

- 사용자의 업무(직무)에 따른 접근 권한 분류 체계의 수립 여부와 담당 업무별 권한 차등 부여 여부를 확인
 - 사용자는 역할에 필요한 파일과 폴더에 대한 접근을 제한해야 한다.
 - 사용자에게는 자신의 책임을 이행하는데 필요한 최소한의 권한만 부여해야 한다.
 - 사용자의 책임에 따라 역할을 할당하고, 해당 역할에 따라 권한을 부여해야 한다.
 - 권한이 남용되지 않도록 단일 사용자에게 권한이 집중되지 않도록 확인한다.

그림 3-8▶ 사용자 직무별 기능 접근 제한 적용 사례

More Info

Authority Name: test318

Menu 1	Selection Menu	Authority	Screen Availability
Intelligence	Log Search	☒ Check	☒ ON
Asset	Audit log status	☐ Check	☐ OFF
Security Monitoring			
Search			
Dashboard			
Report			
Detection Rule Management			
Collection Management			
Data Management			
Reference Data			
Operations Management			

Save

🔍 실증 사례

표 3-9▶ 실증 사례

내용	
우수 사례	• 관리자(Admin)·운영자(Operator)·조회(Viewer) 역할 명확 분리 - 시스템에서 사용자 역할을 관리자, 운영자, 조회 전용 등으로 구분하여 운영하고 있으며, 역할별로 기능이 명확히 제한되어 있다. 이를 통해 불필요한 권한 노출을 방지하고, 사용자별 접근 범위를 체계적으로 관리할 수 있다.

	• 운영자 계정은 설정 변경 권한 없이 모니터링 전용으로 운영 - 운영자(Operator) 계정에는 시스템 설정 변경 권한을 부여하지 않고, 장비 상태 확인 및 모니터링 기능만 제공되도록 구성되어 있다. 이로써 운영 중 실수나 오남용으로 인한 설정 변경 위험을 줄이고, 시스템 안정성을 높이는 역할 기반 접근제어(RBAC)의 사례로 평가된다.
미흡 사례	• 모든 계정이 관리자 권한을 보유 - 시스템 내 생성된 모든 계정이 관리자(Admin) 권한을 동일하도록 보유하고 있어, 역할에 따른 권한 구분이 전혀 이루어지지 않은 상태로 확인되었다. 이로 인한 일반 사용자나 조회 전용 계정도 주요 설정 변경, 구성 수정 등 고위험 작업을 수행할 수 있어 권한 오남용 및 시스템 손상 위험이 증가한다. • Viewer 계정도 설정 변경 기능 사용 가능 - 조회(Viewer) 목적의 계정임에도 불구하고, 설정 변경 및 제어 기능이 활성화되어 있다. 이는 역할 기반 접근제어(RBAC)가 적용되지 않은 전형적인 문제로, 모니터링 전용 사용자에게 불필요한 권한이 부여되는 보안 취약점이다. 해당 구조는 사용자 식별 및 책임 추적을 어렵게 만들 뿐만 아니라, 실수나 악의적 변경으로 이어질 가능성도 높다.

🔍 개선 권고사항

- 관리자 계정 최소화 및 역할 분리 적용
 - 시스템 내 관리자 권한을 보유한 계정은 필수 인원으로만 제한하고, 역할에 따라 관리자(Admin) / 운영자(Operator) / 조회(Viewer) 권한을 명확히 분리하도록 권고한다. 이를 통해 과도한 권한 부여로 발생할 수 있는 설정 변경, 오남용, 비인가 조작 위험을 효과적으로 차단할 수 있다.
- 불필요한 권한 제거 및 운영자 권한 최소화
 - 운영자 계정에는 장비 모니터링 등 업무 수행에 필요한 최소한의 기능만 부여하고, 설정 변경·계정 관리와 같은 고위험 기능은 관리자 권한으로만 제한해야 한다. 이를 통해 전체 계정의 권한 수준을 적정하게 유지하고 시스템 보안성을 강화할 수 있다.

3.2.9 무선 사용 통제

◉ 점검 목적

CBS에서 무선 통신 서비스 기능을 제공하는 경우, 연결된 사용자, 소프트웨어, 장비를 식별하고, 사용을 허가하거나 제한할 수 있는 기능을 제공해야 한다.

- 이 요구사항은 CBS가 무선 네트워크 통신을 사용하는 경우에만 적용

◉ 점검 내용

- CBS에 무선 통신 사용 시 무선 접속 보안 관리 여부 점검
 - 무선 연결에 대해 9)MAC 기반 제한, 허용 리스트 관리 등 무선 접속 권한 통제 기능이 적용되고 있는지 점검한다.

그림 3-9 ▶ 무선 연결 단말 식별 기능 적용 예시



◉ 실증 사례

표 3-10 ▶ 실증 사례

내용	
우수 사례	• 등록 MAC 주소만 접근 허용 - 무선 접속 시 사전에 등록된 MAC 주소만 연결을 허용하는 방식으로 운영하여, 불특정 장비의 무단 접속을 원천 차단하고 무선 네트워크 접근 통제를 강화하였다. • 무선 포트 비활성 및 AP 기능 없음 - 장비의 무선 모듈(와이파이/블루투스)을 비활성화하고 AP 기능을 사용하지 않아, 무선 기반 공격 가능성을 최소화하였다.

9) MAC: 네트워크 인터페이스를 식별하기 위해 장치에 부여되는 고유한 하드웨어 주소.

미흡 사례

- 무선 AP가 기본 패스워드 상태로 활성화됨
 - 기본 패스워드를 변경하지 않고 그대로 사용하고 있어, 외부 공격자가 손쉽게 접근할 수 있는 환경이 유지되고 있다.
- 무선 SSID 접속 시 추가 제한 없이 즉시 연결 가능
 - SSID를 입력하면 별도의 인증 절차나 접근 제한 없이 바로 연결되는 구조로 운영되고 있어, 무단 접속 및 네트워크 침입 위험성이 높다.

❶ 개선 권고사항

- 무선 접속이 필요한 장비만 MAC 기반으로 허용
 - 무선 기능을 사용하는 장비는 사전에 등록된 MAC 주소만 접근하도록 제한하여, 불필요한 무선 접속을 원천적으로 차단할 것을 권고한다. 이를 통해 비인가 장비의 무선 네트워크 접근을 방지하고, 무선 구간 보안성을 강화할 수 있다.
- 무선 AP 사용 시 WPA3 또는 최소 WPA2 이상 적용
 - 무선 AP를 사용하는 경우, 인증 및 암호화 수준을 WPA3 또는 최소 WPA2 이상으로 설정하여 보안성을 확보해야 한다. 이는 무선 통신 구간에서 발생할 수 있는 도청, 비인가 접속을 방지하는 보안 조치이다.

3.2.10 휴대용 및 모바일 기기에 대한 사용 통제

🔍 점검 목적

CBS에서 휴대용 장치 및 모바일 장치(예: USB, 스마트폰, 태블릿, 노트북 등) 연결을 제공하는 경우, 연결 및 데이터 전송을 통제해야 한다.

- 단, 휴대용 장치, 노트북, 모바일 장치의 사용이 없는 경우에는 적용되지 않음

🔍 점검 내용

- USB 포트 제어 여부 점검
 - CBS 또는 장비에서 논리적/물리적으로 USB 포트의 사용을 통제할 수 있는지 확인한다.
- 모바일 장비 연결 제한 여부 점검
 - 스마트폰·태블릿 등 모바일 장비의 연결을 논리적/물리적으로 제한하거나 차단할 수 있는 기능이 제공되는지 확인한다.
- 외부 저장장치 자동 실행(auto-run) 차단 여부
 - USB 등 외부 저장장치 연결 시 자동 실행 기능이 차단되어 있는지 확인한다.

그림 3-10 ▶ 물리적 포트 제어 적용 사례



🔍 실증 사례

표 3-11 ▶ 실증 사례

내용	
우수 사례	• USB 포트는 관리자 승인 시에만 임시 활성화(물리적·논리적 통제 적용) - CBS의 USB 포트는 기본적으로 비활성화되어 있으며, 필요시 관리자 승인 후 일정 시간 동안만 임시 활성화가 가능하도록 운영된다. 이를 통해 불필요한 외부 저장장치 연결을 차단하여 악성코드 유입과 정보 유출 위험을 줄이는 통제가 구현되어 있다. • 외부 저장장치의 자동 실행 기능 비활성화 적용 - 자동 실행(auto-run) 기능이 비활성화되어 있어, 외부 장치 삽입만으로 실행 파일이 자동 실행되는 보안 문제점을 제거하였다.

미흡 사례	• 모든 USB 포트가 상시 개방됨 - CBS의 USB 포트가 지속적으로 활성화된 상태로 운영되고 있으며, 관리자 승인 없이도 누구나 외부 저장장치·모바일 장비 등을 연결할 수 있다. 이는 악성코드 유입, 비인가 파일 반입·반출 등 보안 사고로 이어질 가능성이 높은 취약한 운영 방식이다. • USB 자동 실행(auto-run) 기능 허용 - 외부 저장장치 연결 시 자동으로 실행되는 자동 실행 기능이 차단되지 않은 상태로 확인되었다. 해당 기능은 악성코드 또는 위험한 실행 파일이 사용자 개입 없이 자동 실행될 수 있어, 선박 네트워크 환경에서 대표적인 보안 위험 요소로 지적된다.
-------	---

개선 권고사항

- USB 포트 통제 강화를 위한 물리적 차단 또는 보안 프로그램 적용
 - USB 포트는 기본적으로 비활성화하거나 물리적 차단 조치를 적용하고, 필요한 경우에만 관리자 승인 후 제한적으로 사용할 수 있도록 보안 프로그램(포트 제어·차단 장치 등)을 도입할 것을 권장한다.
- 외부 장비 연결 전 악성코드 검사 의무화
 - 외부 저장장치 및 모바일 장비를 연결하기 전에 반드시 악성코드 검사를 수행하도록 절차를 마련하고, 이를 준수하도록 운영하여 악성코드 유입 위험을 최소화해야 한다.
- 자동 실행(auto-run) 기능 차단 정책 적용
 - USB 등 외부 장치 연결 시 자동 실행 기능이 작동하지 않도록 시스템 차원의 차단 정책을 적용해, 의도치 않은 실행 및 악성코드 감염을 근본적으로 방지할 것을 권고한다.

3.2.11 모바일 코드

🔍 점검 목적

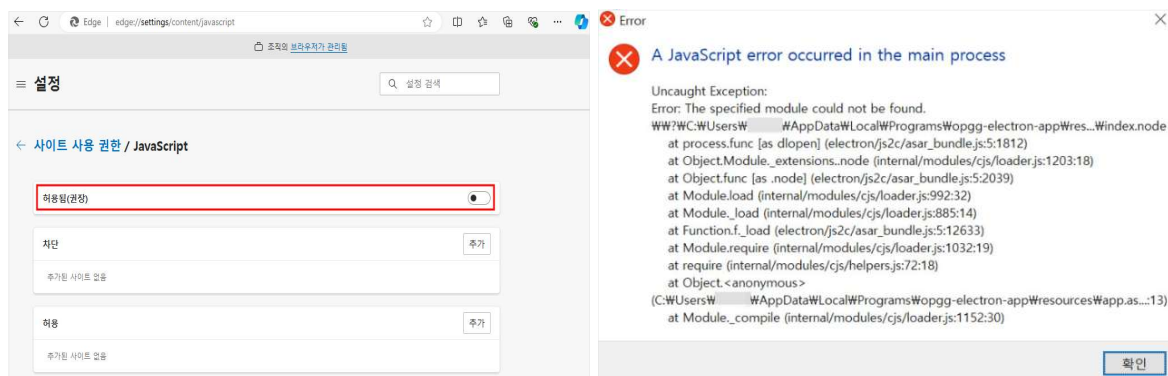
CBS는 자바스크립트, ActiveX 및 PDF와 같은 모바일 코드의 사용을 통제해야 한다.

- 단, CBS에 운영체제(OS)가 없거나, 웹브라우저 접근이 불가능한 경우, 이 요구사항이 적용되지 않을 수 있으며, 대책에 대한 설명을 요구할 수 있음

🔍 점검 내용

- 모바일 코드(Javascript 등) 자동 실행 여부 및 보안 통제 적용 여부 점검
 - CBS 내에서 10)JavaScript, 11)ActiveX, 12)VBScript 등 모바일 코드가 자동 실행 여부를 확인한다.
- 위험한 코드 실행을 차단하기 위한 보안 설정(스크립트 차단, 실행 제한 등)이 적용되어 있는지 점검한다.

그림 3-11 ▶ 모바일 코드 실행 차단 적용 사례



🔍 실증 사례

표 3-12 ▶ 실증 사례

내용	
우수 사례	• 모바일 코드(Javascript 등) 실행 기능 없음 - CBS 내 웹 인터페이스 또는 UI 구성 요소에서 모바일 코드(Javascript, ActiveX 등) 실행 기능을 제공하지 않아, 외부 스크립트 기반 공격 가능성이 원천 차단되어 있다. • 스크립트 실행 시 자동 차단 기능 적용 - 스크립트 파일 또는 위험도가 높은 코드가 실행 시도될 경우, 시스템에서 자동으로 차단되도록 설정되어 있다. 이를 통해 악성 스크립트 수행, 무단 코드 삽입 등 모바일 코드 기반 공격을 효과적으로 방지하고 있다.
미흡 사례	• 스크립트 실행 시 즉시 실행 가능

10) JavaScript: 웹 페이지에서 동적 기능과 상호작용을 구현하기 위해 사용되는 대표적인 스크립트 언어

11) ActiveX: 주로 Internet Explorer 환경에서 애플리케이션 기능을 확장하기 위해 사용되던 실행 컴포넌트 기술

12) VBScript: Microsoft 환경에서 사용되는 간단한 스크립트 언어로, 웹 페이지 자동화 작업 등에 활용되던 기술

- CBS 내에서 JavaScript 등 모바일 코드가 별도 검증 없이 즉시 실행되는 구성이 확인되었다. 이 경우 악성 스크립트가 포함된 콘텐츠 실행 시 보안 위협이 발생할 수 있으며, 코드 기반 공격에 취약한 환경으로 평가된다.
- 코드 실행 시 검증 절차 부재
- 스크립트·모바일 코드 실행 전에 무결성 확인, 사용자 승인, 경고 알림 등 사전 검증 절차가 전혀 적용되지 않아, 악성코드가 그대로 시스템에서 실행될 가능성이 존재한다. 이는 보안사고 발생 시 위험 확산을 가속할 수 있는 취약 요소다.
- 다운로드 파일 자동 실행 설정 활성화
- 다운로드 된 파일이 사용자 승인 없이 바로 실행될 수 있는 기능이 활성화되어 있어, 악성 파일 다운로드 시 즉시 실행되는 보안 위협이 존재한다. 이러한 기능은 기본적으로 비활성화되어야 한다.

❁ 개선 권고사항

- 모바일 코드 자동 실행 기능 차단
 - CBS 내에서 JavaScript 등 모바일 코드가 자동으로 실행되지 않도록 기본 차단 기능을 적용해야 한다. 이를 통해 외부 웹 콘텐츠나 다운로드 파일을 통해 악성 스크립트가 실행될 가능성을 최소화할 수 있다.
- 스크립트 실행은 필요시 관리자 권한만 허용
 - 업무 수행에 필요한 경우에만 관리자가 직접 승인하거나 관리자 권한으로 실행할 수 있도록 제한한다. 일반 사용자 계정에서는 스크립트 실행 권한을 부여하지 않아 비인가 코드 실행 위험을 효과적으로 방지할 수 있다.

3.2.12 세션 잠금

🔍 점검 목적

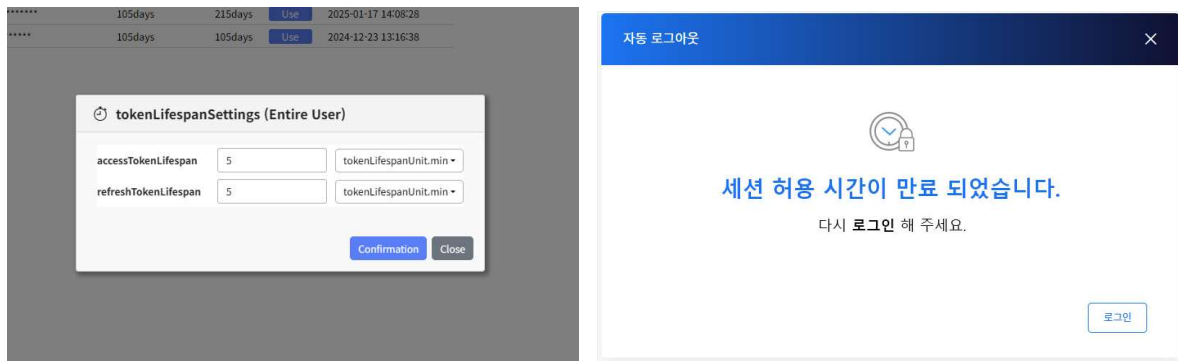
CBS는 설정된 비활성 시간 이후 또는 수동 세션 잠금이 활성화되는 경우 추가 접근을 방지해야 한다.

- 단, 비상 상황에서 즉시 운영자의 대응이 필요한 CBS의 경우 이 요구사항이 적용되지 않을 수 있음

🔍 점검 내용

- 자동 잠금 기능 및 시간 설정 여부 점검
 - 일정 시간 비활성 시 화면 자동 잠금 기능이 구현되어 있는지 확인한다.
 - 자동 잠금 시간 설정(예: 5분, 10분 등) 기능이 제공되는지 확인한다.

그림 3-12 ▶ 세션 잠금 기능 적용 사례



🔍 실증 사례

표 3-13 ▶ 실증 사례

내용	
우수 사례	• 5분 이상 입력이 없는 경우 자동 잠금 기능 적용 - CBS는 사용자가 일정 시간(5분) 동안 입력을 하지 않으면 자동으로 화면이 잠금 되도록 설정되어 있다. 이를 통해 사용자가 자리를 비운 동안 발생할 수 있는 무단 조작 및 비인가 접근을 효과적으로 차단하고 있다. • 잠금 해제 시 비밀번호 요구 기능 적용 - 잠금 해제 시 반드시 사용자 비밀번호를 다시 입력하도록 구성되어 있어, 계정 소유자 본인만 작업을 재개할 수 있도록 통제한다. 이 기능은 세션 하이재킹 방지 및 사용자 인증 강화 측면에서 효과적으로 방지하고 있다.
미흡 사례	• 자동 잠금 기능이 '없음'으로 운영됨 - CBS가 일정 시간 비활성 상태가 되어도 자동으로 잠금 되지 않아, 자리 비움 시 화면과 기능이 그대로 노출되는 보안 취약점이 확인되었다. • 자동 잠금 시간이 30분 이상으로 과도하게 길게 설정됨 - 자동 잠금 기능이 존재하더라도 30분 이상으로 설정되어 있어, 사실상 잠금 기능이 유효하게 작동하지 않는 수준으로 보안성이 저하된 사례이다.

- 잠금 해제 시 인증 절차가 요구되지 않음
- 잠금 해제 시 패스워드 입력 등 인증 과정 없이 즉시 접근이 가능한 상태로 운영되어, 무단 접근 및 사고 위험이 증가하게 된다.

🔗 개선 권고사항

- 자동 잠금 시간을 5~10분 이내로 설정
 - CBS 비활성 상태가 일정 시간(5~10분)을 초과하는 경우 자동으로 잠금 되도록 설정하여, 무단 접근 및 방치 화면 노출로 인한 보안 위험을 최소화해야 한다.
- 모든 사용자 계정에 잠금 기능 강제 적용
 - 관리자·운영자·일반 사용자 등 모든 계정에 자동 잠금 정책을 적용하고, 예외 계정을 두지 않도록 운영함으로써 시스템 전반의 접근 보안 수준을 강화할 것을 권고한다.

3.2.13 감사 가능 사건

🔍 점검 목적

CBS는 최소한 다음 사건에 대한 보안 관련 감사 기록을 생성해야 한다.

- 접근 통제, 운영체제 사건, 백업 및 복구 사건, 설정 변경, 통신 손실

🔍 점검 내용

- 감사 로그 저장 항목의 정의 및 기록 여부 점검
 - CBS에 접근 통제, 운영체제 사건, 백업 및 복구 활동, 설정 변경, 통신 손실 등 주요 보안 · 운영 이벤트가 모두 로그로 기록되는지 확인한다.
 - 저장되는 감사 로그의 범위, 보존 기간 등에 대해 적절하게 운영되고 있는지 점검한다.

그림 3-13 ▶ 감사 로그 기능 적용 사례

감사로그 현황

상태: 전체 | 작업대상: 전체 | 작업일자: 최근 1일 | 작업자 ID: | 검색: | CSV

No	상태	작업대상	작업일자	작업명	작업자 ID	작업자 IP	작업내용
> 1	SUCCESS	권술	2024-08-21 15:27:36	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 2	SUCCESS	권술	2024-08-21 15:27:32	Login	CONSOLE	192.168.70.52	Login [igloosec]
> 3	SUCCESS	권술	2024-08-21 14:06:08	Logout	CONSOLE	192.168.50.68	Logout [igloosec]
> 4	SUCCESS	권술	2024-08-21 13:59:15	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 5	SUCCESS	권술	2024-08-21 13:57:59	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 6	SUCCESS	권술	2024-08-21 13:48:54	Delete	igloosec	192.168.70.52	Delete 사용자관리_en [[검색 허용 IP 주소:]], 역할 명: 계정="igloo_old", 이메일 주소="igloo_old@igloo.co.kr", 로제일="ko_KR", 전화번...
> 7	SUCCESS	권술	2024-08-21 13:48:49	MoveMenu	igloosec	192.168.70.52	MoveMenu [settings]:[settings user]
> 8	SUCCESS	권술	2024-08-21 13:44:59	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 9	SUCCESS	권술	2024-08-21 13:44:57	Login	CONSOLE	192.168.70.52	Login [igloosec]
> 10	SUCCESS	권술	2024-08-21 13:44:22	MoveMenu	igloosec	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 11	SUCCESS	권술	2024-08-21 13:44:21	Login	CONSOLE	192.168.70.42	Login [igloosec]
> 12	SUCCESS	권술	2024-08-21 13:43:51	Logout	CONSOLE	192.168.50.68	Logout [igloo_old]
> 13	SUCCESS	권술	2024-08-21 13:43:48	MoveMenu	igloo_old	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 14	SUCCESS	권술	2024-08-21 13:43:40	MoveMenu	igloo_old	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 15	SUCCESS	권술	2024-08-21 13:43:39	Login	CONSOLE	192.168.70.42	Login [igloo_old]
> 16	SUCCESS	권술	2024-08-21 13:43:31	Logout	CONSOLE	192.168.50.68	Logout [igloosec]
> 17	SUCCESS	권술	2024-08-21 13:42:46	MoveMenu	igloosec	192.168.70.42	MoveMenu [settings]:[settings user]
> 18	SUCCESS	권술	2024-08-21 13:42:35	MoveMenu	igloosec	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 19	SUCCESS	권술	2024-08-21 13:42:34	Login	CONSOLE	192.168.70.42	Login [igloosec]
> 20	SUCCESS	권술	2024-08-21 13:42:29	Logout	CONSOLE	192.168.50.68	Logout [igloosec]
> 21	SUCCESS	권술	2024-08-21 13:41:56	Update	igloosec	192.168.70.42	Update 사용자관리_en []
> 22	SUCCESS	권술	2024-08-21 13:41:47	Update	igloosec	192.168.70.42	Update 사용자관리_en []
> 23	SUCCESS	권술	2024-08-21 13:41:35	Update	igloosec	192.168.70.42	Update 사용자관리_en []

페이지당 항목 수: 100 | 전제 2 페이지 중 1 | 페이지 (181 항목)

🔍 실증 사례

표 3-14 ▶ 실증 사례

내용	
우수 사례	• 접근 통제, 운영체제 이벤트, 백업·복구, 설정 변경, 통신 손실 등 주요 사건 모두 로그로 기록 - CBS에서 사용자 접근 기록, 운영체제 발생 이벤트, 백업 및 복구 기록, 주요 설정 변경, 통신 장애와 같은 핵심 운영 사건이 빠짐없이 감사 로그로 저장되고 있다.

	• 저장되는 감사 로그의 항목 정의가 명확하게 문서화 - 로그에 기록되는 항목(이벤트 유형 · 발생 조건 · 저장주기 · 보관 기간 등)에 대한 정의가 명확하게 정리되어 있어, 관리자가 이를 기준으로 로그를 해석·검증할 수 있다.
미흡 사례	• 로그인 실패 기록 누락 - CBS의 로그인 실패 이벤트가 감사 로그에 기록되지 않아, 비인가 접근 시도를 탐지하거나 추후 분석하는데 어려움이 발생한다. • 관리자 설정 변경 기록 누락 - 관리자가 수행한 주요 설정 변경 사항이 로그에 저장되지 않는 것으로 확인되었다. 설정 변경에 대한 이력 미기록은 책임 추적성을 약화하며, 정책 위반 · 오류 조치 발생 시 원인 분석이 불가능해지는 문제점으로 이어진다. • 감사 기능 비활성화 - CBS 자체의 감사 기능이 비활성 상태로 운영되고 있어, 전체 활동에 대한 로그 수집과 보안 모니터링이 이뤄지지 않는 상태이다. 이는 감사 체계가 사실상 작동하지 않는 것으로, 사이버보안 측면에서 심각한 문제점에 해당한다.

개선 권고사항

- 필수 감사(log) 항목 정의 및 표준화
 - 접근 통제, 정책 변경, 시스템 이벤트 등 반드시 기록해야 하는 필수 감사 항목을 명확히 정의하여 시스템 설정에 반영하도록 권고한다.
- 관리자 정책 변경 시 반드시 로그 생성되도록 설정
 - 관리자 권한으로 수행되는 주요 설정 변경은 무조건 감사 로그에 자동 기록되도록 시스템 정책을 강화해야 한다.
- 로그 기록 누락 발생 시 알림 기능 활성화
 - 감사 항목이 정상적으로 기록되지 않거나 로그 저장 오류가 발생한 경우, 즉시 관리자에게 알림이 전달되도록 설정할 것을 권고한다.

3.2.14 감사 저장 용량

◉ 점검 목적

CBS는 유사시 책임 추적을 위해 주요 이벤트가 누락 되지 않도록 감사 로그 파일의 크기 및 보관 기간을 적절하게 유지하는 기능을 설정해야 한다.

◉ 점검 내용

- 로그 저장 공간의 용량에 대해 정의가 되어 있는지 점검
 - CBS가 감사 로그 · 이벤트 로그 보관을 위해 필요한 최소/권장 저장 용량을 명확히 정의하고 있는지 확인한다. 용량 부족 시 로그 누락 또는 순환(overwrite) 발생 여부도 함께 점검한다.
- 로그 저장 용량 모니터링 여부가 가능한지 점검
 - 로그 저장 영역의 사용량 모니터링 기능이 제공되는지, 임계치 도달 시 알림 기능이 있는지 확인한다.

그림 3-14 ▶ 감사 로그 저장 용량 및 알림 기능 적용 사례

The screenshot displays the '시스템설정' (System Settings) interface. On the left, under '시스템 설정' (System Settings), the '데이터베이스 용량 관리' (Database Capacity Management) section is highlighted with a red box. It shows '현재 사용률' (Current Usage) at 0.97%, '사용률 알림 설정' (Usage Alert Setting) at 40% (labeled '% 초과'), and '삭제 기준 설정' (Deletion Criteria Setting) at 50% (labeled '% 초과'). On the right, under '서비스 연동 설정' (Service Integration Settings), the 'SMS' and '메일' (Email) sections are highlighted with a red box. The SMS section includes '담당자명' (Responsible Name) as '이글루' and '전화번호' (Phone Number) as '0234528814'. The Email section includes '담당자명' (Responsible Name) as '이글루' and '메일 주소' (Email Address) as 'igloo@igloo.co.kr'.

◉ 실증 사례

표 3-15 ▶ 실증 사례

내용	
우수 사례	• 특정 별도 공간에 로그 저장 용량 관리 - 로그는 운영 데이터와 분리된 전용 저장 공간에 관리되어, 시스템 성능 저하나 기록 누락 위험 없이 안정적으로 보관되고 있다. • 저장 공간 80% 이상 시 관리자에게 자동 알림 - 로그 저장 영역의 사용량이 80%를 초과하는 경우 자동으로 관리자에게 알림이 전송되도록 설정되어 있어, 용량 부족으로 인한 로그 손실을 사전 예방할 수 있는 구조가 마련되어 있다.

미흡 사례	• 용량 기반 저장인 아닌 특정 라인(line) 수 기준 저장 구조 - 로그 저장 구조가 스토리지 용량이 아닌 라인 수 기준으로 제한되어 있어, 실제 시스템 사용량 증가 시 로그가 조기 삭제될 가능성이 높다. 이는 보안 감사의 신뢰성을 떨어뜨리는 문제점이다. • 저장 공간 부족 시 알림 기능 부재 - 로그 저장 공간이 감소해도 관리자에게 알려주는 알림 기능이 구현되어 있지 않아, 로그 누락 위험을 사전에 인지할 수 없는 상태다. 그 결과 보안 사고에 대비한 선제 대응이 어려워지는 문제점이 존재한다. • 저장 공간 부족으로 최근 로그만 남는 상황 발생 - 로그 저장 공간이 충분히 확보되지 않아, 최근 로그만 보존되는 상태가 확인되었다. 이는 감사 이력 누락과 사고 분석 불가 등 보안상 심각한 위험을 초래한다.
---------------------	---

🔗 **개선 권고사항**

- 로그 저장 전용 공간 분리 및 충분한 용량 확보
 - 로그 데이터가 다른 시스템 저장 영역과 충돌하지 않도록 전용 저장 공간을 분리하고, 장기간(6개월 이상) 로그를 안정적으로 보관할 수 있도록 충분한 용량을 확보하는 방향으로 개선을 권고한다.
- 로그 저장 공간 부족 시 관리자 경보 기능 구축
 - 저장 공간이 부족해지면 시스템이 자동으로 관리자에게 경보(알림)를 발송하도록 기능을 개발·적용할 것을 권고한다. 이를 통해 로그 누락, 덮어쓰기 등 보안사고 예방이 가능하며, 저장 공간 관리의 신뢰성을 높일 수 있다.

3.2.15 감사 처리 실패 대응

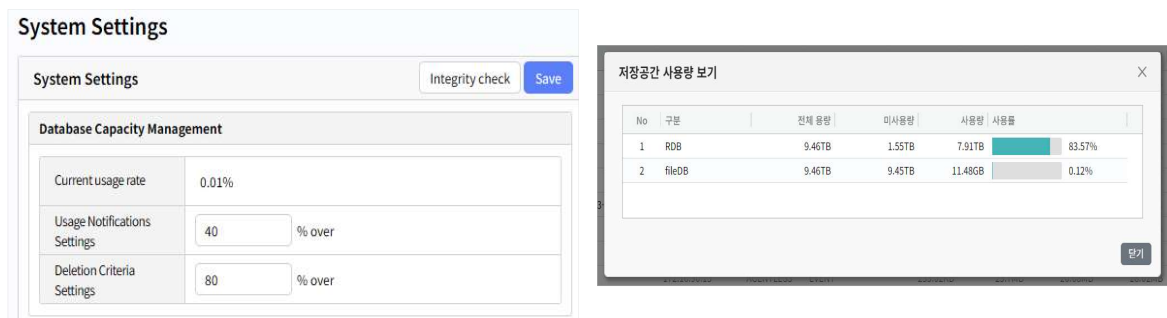
◉ 점검 목적

CBS는 감사 처리 실패 시 중요한 서비스 및 기능의 손실을 방지하는 기능을 제공해야 한다.

◉ 점검 내용

- 로그 순환 정책(Rotation) 사용 여부 점검
 - 로그 파일 크기 또는 기간 기준으로 자동 회전(Rotation) 기능이 적용되어 있는지 확인한다. 오래된 로그를 안전하게 보관하거나 별도 저장소로 이관하는 기능이 운영되는지 확인한다.
- 감사 기능 중지 시 즉시 경고 여부 점검
 - 시스템 내 감사 기능(Audit Log)이 비활성화되거나 중지되는 경우, 이를 즉시 관리자에게 알림 또는 경고로 통보하는 기능이 있는지 확인한다.

그림 3-15 ▶ 감사 로그 처리 실패 관리 기능 적용 사례



◉ 실증 사례

표 3-16 ▶ 실증 사례

내용	
우수 사례	• 감사 서비스 중단 즉시 관리자 알림 - CBS의 감사(Audit) 기능이 중지되거나 오류가 발생할 경우, 즉시 관리자에게 알림이 전달되도록 설정되어 있다. • 오래된 로그 자동 압축 또는 외부 저장소로 자동 이동 보관 - 로그 파일이 증가하더라도 저장 공간을 효율적으로 사용할 수 있도록 오래된 로그는 자동으로 압축하거나 외부 저장소로 이전하도록 구성되어 있다. 이 기능은 로그 보존 기간을 늘리고 저장 공간 부족 문제를 예방하는데 효과적이다.
미흡 사례	• 로그 순환(Rotation) 기능 미적용 - 로그 순환 정책이 설정되어 있지 않아, 로그 파일이 지속적으로 누적되며 저장 공간 부족 및 시스템 성능 저하 위험이 발생할 수 있다.

	• 로그 저장 용량 상태 모니터링 부재 - 로그 저장 공간의 사용량을 주기적으로 확인하는 기능이 없고, 저장 공간 부족 상황을 사전에 감지하지 못해 로그 유실 가능성이 존재한다. • 감사 기능 비활성화 상태에 대한 관리자 알림 및 모니터링 기능 없음 - 감사 기능이 비활성화되거나 중단되더라도 관리자에게 경고 메시지나 알림이 전달되지 않아, 장기간 감사 기능이 꺼진 상태로 방치될 위험이 있다.
--	---

개선 권고사항

- 용량 초과 방지 알림 기능 적용
 - 로그 저장 공간이 임계치에 도달하기 전에 관리자가 즉시 인지할 수 있도록 저장 용량 초과 방지 알림 기능을 적용할 것을 권고한다. 이를 통해 로그 손실되는 위험을 예방할 수 있다.
- 감사 오류 감지 기능 적용
 - 감사 기능이 비정상적으로 중단되거나 오류가 발생했을 때 즉시 관리자에게 통보되는 감사 오류 감지 및 알림 기능을 적용할 것을 권장한다. 이를 통해 감사 기능 무력화, 로그 미기록 등의 문제를 조기에 인지하고 대응할 수 있다.

3.2.16 타임스탬프

🔍 점검 목적

CBS는 감사 로그 기록 시 타임스탬프 정보를 포함해야 한다.

🔍 점검 내용

- 장비 시스템 시간이 표준시(13)NTP)와 동기화되는지 확인
 - CBS가 NTP 시스템 또는 내부 기준 시간과 정확하게 동기화되는지 점검한다.
 - 시간 오차가 있는 경우 로그 · 이벤트 기록의 신뢰성이 저하될 수 있으므로 동기화 기능의 가능 여부를 확인한다.
- 로그에 기록된 타임스탬프의 일관성 여부 점검
 - 장비 로그에 기록되는 시간 정보가 일관되게 유지되는지 확인한다.

그림 3-16 ▶ 감사 로그 타임스탬프 기능 적용 사례

감사로그 현황

상태 전체 작업대상 전체 작업일자 최근 1일 작업자 ID 검색 CSV

No	상태	작업대상	작업일자	작업명	작업자 ID	작업자 IP	작업내용
> 1	SUCCESS	콘솔	2024-08-21 15:27:36	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 2	SUCCESS	콘솔	2024-08-21 15:27:32	Login	CONSOLE	192.168.70.52	Login [igloosec]
> 3	SUCCESS	콘솔	2024-08-21 14:06:08	Logout	CONSOLE	192.168.50.68	Logout [igloosec]
> 4	SUCCESS	콘솔	2024-08-21 13:59:15	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 5	SUCCESS	콘솔	2024-08-21 13:57:59	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 6	SUCCESS	콘솔	2024-08-21 13:48:54	Delete	igloosec	192.168.70.52	Delete 사용자관리_en [[입속 허용 IP 주소=], 역할 명=, 계명="igloo_old", 이메일 주소="igloo_old@igloo.co.kr", 로제일="ko_KR", 전화번...
> 7	SUCCESS	콘솔	2024-08-21 13:48:49	MoveMenu	igloosec	192.168.70.52	MoveMenu [settings]:[settings user]
> 8	SUCCESS	콘솔	2024-08-21 13:44:59	MoveMenu	igloosec	192.168.70.52	MoveMenu [services]:[spot dashboard]
> 9	SUCCESS	콘솔	2024-08-21 13:44:57	Login	CONSOLE	192.168.70.52	Login [igloosec]
> 10	SUCCESS	콘솔	2024-08-21 13:44:22	MoveMenu	igloosec	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 11	SUCCESS	콘솔	2024-08-21 13:44:21	Login	CONSOLE	192.168.70.42	Login [igloosec]
> 12	SUCCESS	콘솔	2024-08-21 13:43:51	Logout	CONSOLE	192.168.50.68	Logout [igloo_old]
> 13	SUCCESS	콘솔	2024-08-21 13:43:48	MoveMenu	igloo_old	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 14	SUCCESS	콘솔	2024-08-21 13:43:40	MoveMenu	igloo_old	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 15	SUCCESS	콘솔	2024-08-21 13:43:39	Login	CONSOLE	192.168.70.42	Login [igloo_old]
> 16	SUCCESS	콘솔	2024-08-21 13:43:31	Logout	CONSOLE	192.168.50.68	Logout [igloosec]
> 17	SUCCESS	콘솔	2024-08-21 13:42:46	MoveMenu	igloosec	192.168.70.42	MoveMenu [settings]:[settings user]
> 18	SUCCESS	콘솔	2024-08-21 13:42:35	MoveMenu	igloosec	192.168.70.42	MoveMenu [services]:[spot dashboard]
> 19	SUCCESS	콘솔	2024-08-21 13:42:34	Login	CONSOLE	192.168.70.42	Login [igloosec]
> 20	SUCCESS	콘솔	2024-08-21 13:42:29	Logout	CONSOLE	192.168.50.68	Logout [igloosec]
> 21	SUCCESS	콘솔	2024-08-21 13:41:56	Update	igloosec	192.168.70.42	Update 사용자관리_en []
> 22	SUCCESS	콘솔	2024-08-21 13:41:47	Update	igloosec	192.168.70.42	Update 사용자관리_en []
> 23	SUCCESS	콘솔	2024-08-21 13:41:35	Update	igloosec	192.168.70.42	Update 사용자관리_en []

페이지당 항목수: 100 전체 2 페이지 중 1 페이지 (181 항목)

🔍 실증 사례

표 3-17 ▶ 실증 사례

내용	
우수 사례	• NTP 서버와 동기화 적용

13) NTP(Network Time Protocol): 네트워크상의 장비들이 정확하고 동일한 시간으로 동기화되도록 해주는 시간 동기화 프로토콜

	- CBS 시간이 표준시(NTP 서버)와 자동으로 동기화되도록 설정되어 있어, 시간 오차 없이 안정적으로 운영되고 있다. • 타임스탬프가 UTC+09 기준으로 일관성 있게 기록 - 로그에 기록되는 모든 타임스탬프가 동일한 시간대(UTC+09) 기준으로 저장되어, 감사·분석 시점에서 시간 불일치나 혼선이 발생하지 않는다.
미흡 사례	• CBS 시간이 표준시 대비 ± 10분 이상 오차 - CBS의 시스템 시간이 실제 표준시와 크게 차이가 나 운영 기록과 이벤트 분석 시 혼선을 초래하며, 로그 기반 조사가 어려워지는 문제가 발생한다. • 로그별 타임스탬프가 일관되지 않음 - 동일 CBS 내에서도 로그마다 기록 시간이 불규칙하게 표시되어 이벤트 순서 파악이 어려우며, 보안 사고 분석 시 정확성이 저하된다. • NTP(Network Time Protocol) 설정 미구성 - 시간 동기화를 위한 NTP 서버 설정이 이루어지지 않아 장비 간 시간 불일치가 지속적으로 발생하고 있어, 전체 시스템의 시간 신뢰성이 저하된 상태이다.

개선 권고사항

- NTP 서버 설정 적용
 - CBS 시스템 시간이 표준 시간과 항상 일치하도록 NTP 서버를 설정하여 자동 동기화 기능을 활성화할 것을 권고한다. 이를 통해 로그 타임스탬프의 정확성과 일관성을 확보할 수 있다.
- 수동 시간 변경 금지 정책 적용
 - 운영자 또는 외부 사용자가 장비 시간을 임의로 변경하지 못하도록 수동 시간 변경 기능을 비활성화하고, 관리자 승인 절차를 별도로 마련할 것을 권장한다. 시간 변경 제한은 감사 로그의 신뢰성을 높이는 핵심 요소이며, 보안 사고 분석에도 필수적이다.

3.2.17 통신 무결성

◉ 점검 목적

CBS는 전송되는 정보가 손상되지 않도록 보호해야 하며, 무선 통신을 제공할 때는 암호화 보안을 적용해야 한다.

- 단, Serial 링크와 같은 통신 환경에는 적용하지 않음

◉ 점검 내용

- 통신 채널 암호화 여부 점검
 - CBS 또는 시스템 간 데이터 전송 시 암호화된 통신(예: ¹⁴⁾HTTPS, ¹⁵⁾TLS, ¹⁶⁾SSH 등) 이 적용되고 있는지를 확인한다. 또한 평문 통신(¹⁷⁾HTTP, ¹⁸⁾Telnet 등) 사용 여부와 암호화 우회 가능 여부를 함께 점검하여, 전송 중 데이터가 도청·변조될 위험이 없는지 확인한다.

그림 3-17 ▶ 네트워크 통신 암호화 적용 사례

263	7.888753	192.168.40.35	172.16.90.11	TLSv1.3	571 Client Hello
266	7.891589	192.168.40.35	172.16.90.11	TLSv1.3	84 Change Cipher Spec, Application Data
273	7.893942	192.168.40.35	172.16.90.11	TLSv1.3	571 Client Hello
279	7.913601	192.168.40.35	172.16.90.11	TLSv1.3	118 Change Cipher Spec, Application Data
280	7.913709	192.168.40.35	172.16.90.11	TLSv1.3	146 Application Data

Wireshark - 패킷 141 - 이더넷 2

Handshake Protocol: Server Hello

Handshake Type: Server Hello (2)

Length: 124

Version: TLS 1.2 (0x0303)

Random: 80baf372410453324052aab586a69dc58c743479e91f8f68b8bc836cc196b0b

Session ID Length: 32

Session ID: a9bf7148e957130bc4ed65470430bf7a1a3011e67c26a6425bdfb328b2ccab20

Cipher Suite: TLS_AES_128_GCM_SHA256 (0x1301)

Compression Method: null (0)

Extensions Length: 52

Extension: supported_versions (len=2) TLS 1.3

No.: 141 - Time: 10.155788 - Source: 192.168.50.68 - Destination: 192.168.70.42 - Protocol: TLSv1.3 - Length: 440 - Info: Server Hello, Change Cipher Spec, Application Data, Application Data, Application Data

패킷 바이트 표시

닫기 도움말

- 14) HTTPS: 웹브라우저와 서버 간 데이터를 TLS로 암호화하여 안전하게 전송하는 보안 통신 프로토콜
- 15) TLS: 인터넷 통신의 기밀성·무결성·인증을 보장하기 위해 데이터를 암호화하는 보안 프로토콜
- 16) SSH: 네트워크를 통해 원격 시스템에 안전하게 접속·명령을 수행할 수 있도록 암호화된 통신을 제공하는 프로토콜
- 17) HTTP: 웹에서 데이터를 주고받기 위한 기본 프로토콜로, 암호화되지 않은 평문 통신 방식을 사용함
- 18) Telnet: 원격 시스템에 접속하기 위한 프로토콜로, 인증 정보와 명령이 암호화되지 않은 상태로 전송됨

실증 사례

표 3-18 ▶ 실증 사례

내용	
우수 사례	• 19)TLS 1.3 이상의 암호화 프로토콜 적용 - CBS 간 또는 시스템 외부와의 통신 구간에 TLS 1.3 이상의 암호화 프로토콜이 적용되어 있다. 이를 통해 데이터 전송 과정에서 발생할 수 있는 패킷 도청, 변조, 중간자 공격 등 다양한 보안 위협을 효과적으로 차단하고 있다.
미흡 사례	• 평문 통신 프로토콜 사용으로 변조 위험 존재 - Telnet, HTTP, 20)FTP 등 암호화되지 않은 프로토콜 사용한다. - 네트워크상에서 데이터가 그대로 노출될 가능성이 있으며, 공격자가 패킷을 가로채거나 변조할 위험이 크다.

개선 권고사항

- 네트워크 통신 구간은 암호화 프로토콜을 반드시 적용
 - CBS 시스템 간 데이터 송수신 시 TLS, HTTPS 등 암호화 통신 프로토콜을 의무적으로 적용하여 평문 전송으로 인한 변조·도청 위험을 제거하도록 개선할 것을 권고한다. 암호화 미적용 구간이 존재하는 경우 즉시 점검하여 안전한 프로토콜로 전환하는 것이 필요하다.

19) TLS 1.3: 인터넷 통신을 안전하게 보호하기 위해 설계된 최신 암호화 프로토콜로, 보안성과 성능을 크게 강화한 버전
20) FTP: 파일을 전송하기 위한 프로토콜로, 계정 정보와 데이터가 암호화되지 않아 보안에 취약함

3.2.18 악성코드로부터 보호

🔍 점검 목적

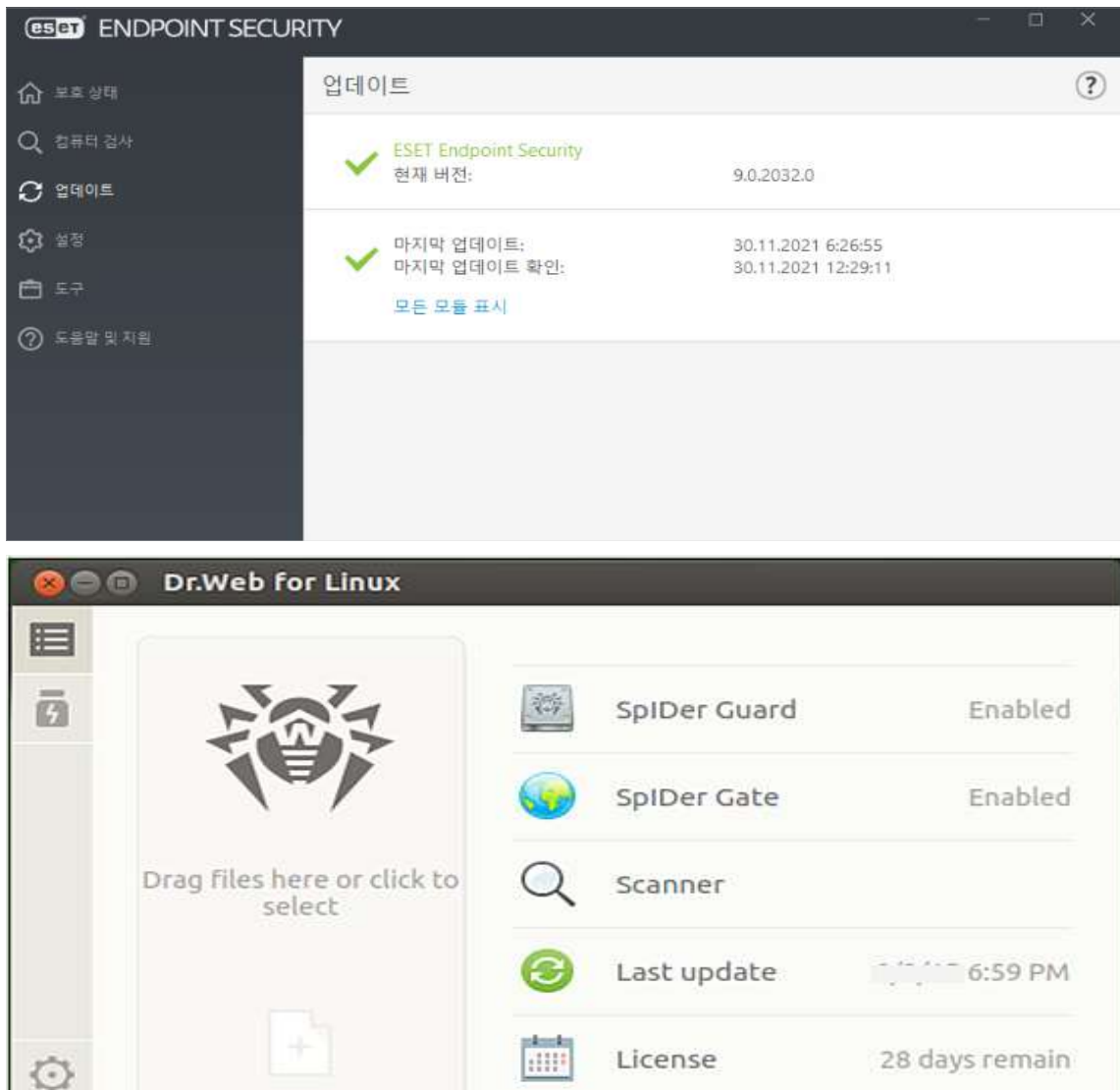
CBS는 악성코드 또는 무단 소프트웨어로 인한 영향을 예방, 탐지, 완화하기 위한 보호 기능을 제공해야 한다.

- 일반적인 운영체제(Windows, Linux, Android 등)를 사용하는 CBS에 적용

🔍 점검 내용

- 악성코드 탐지 프로그램 설치 여부 점검
 - CBS에 악성코드 탐지(백신) 프로그램이 설치되어 있는지, 실시간 감시 기능이 활성화되어 있는지, 최신 엔진 및 패턴 업데이트가 정상적으로 적용되고 있는지를 점검한다.

그림 3-18▶ 악성코드 탐지 프로그램 적용 사례(위:Windows OS / 아래:Linux OS)



실증 사례

표 3-19 ▶ 실증 사례

내용	
우수 사례	- 악성코드 백신 프로그램 설치 및 운영 - CBS에 악성코드 탐지용 백신 프로그램을 설치하여 주기적인 검사와 실시간 감시 기능을 운영하고 있다. 이를 통해 외부 저장장치 연결, 파일 다운로드 등으로 인한 악성코드 감염 가능성을 효과적으로 차단하고 있다. - 임베디드시스템 특성으로 설치 프로그램 제한 시 대체 보호 조치 운영 - 백신 설치가 어려운 임베디드 장비의 경우, 시스템 구조상 설치 가능한 프로그램이 제한되어 있으나, 대신 파일 실행 차단, 외부 장치 제한 등 장비 특성에 맞춘 대체 보안 기능을 적용하여 감염 위험을 최소화하고 있다.
미흡 사례	- 악성코드 백신 프로그램 미설치 운영 - 해당 CBS에는 악성코드 탐지 · 차단을 위한 백신 프로그램이 설치되지 않은 것으로 확인되었다. 기본적인 악성코드 감시 기능이 부재하여, 외부 저장장치 연결, 파일 전송, 네트워크를 통한 악성코드 감염 가능성을 차단하기 어려운 상태이다. 이러한 환경은 악성코드 감염 시 시스템 중단, 설정 변경, 데이터 손상 등의 위험을 초래할 수 있어 보안상 매우 취약하다.

개선 권고사항

- 악성코드 백신 프로그램 설치
 - CBS 보안 강화를 위해 악성코드 백신 프로그램을 설치하고 최신 상태로 유지할 것을 권고한다.
- 정기적 악성코드 스캔 및 점검 절차 마련
 - 주기적인 악성코드 스캔 및 점검 절차를 수립하여, 악성코드 존재 여부를 정기적으로 확인하고 즉시 대응할 수 있는 체계를 갖추도록 한다.

3.2.19 보안 기능 검증

🔍 점검 목적

CBS는 보안 기능이 의도한 대로 작동하는지 검증을 지원하고, 유지보수 중 이상이 발생하는 경우 이를 보고하는 기능을 제공해야 한다.

🔍 점검 내용

- 안티바이러스 프로그램의 실시간 탐지 기능 제공 여부 확인
 - CBS에 설치된 안티바이러스(AV)가 실시간 탐지(Real-time Scan) 기능을 지원하며, 악성코드 실행 · 전파를 즉시 차단할 수 있는지를 점검한다.
- 인가받지 않은 계정 로그인 시도에 대한 감사 로그 기록 여부 점검
 - 허가되지 않은 계정 또는 잘못된 인증 정보를 이용한 로그인 시도가 발생할 경우, 감사 로그에 정확히 기록되는지 확인한다.
- 감사 로그의 무결성 보장을 위한 읽기 전용 로그 정책 적용 여부 점검
 - 감사 로그가 읽기 전용(Read-only)으로 보호되어 있으며, 사용자 또는 관리자에 의해 임의 수정 또는 삭제 불가능하도록 설계되어 있는지를 점검한다.

그림 3-19▶EICAR 테스트 예시



그림 3-20▶백신 프로그램 실시간 탐지 화면 예시

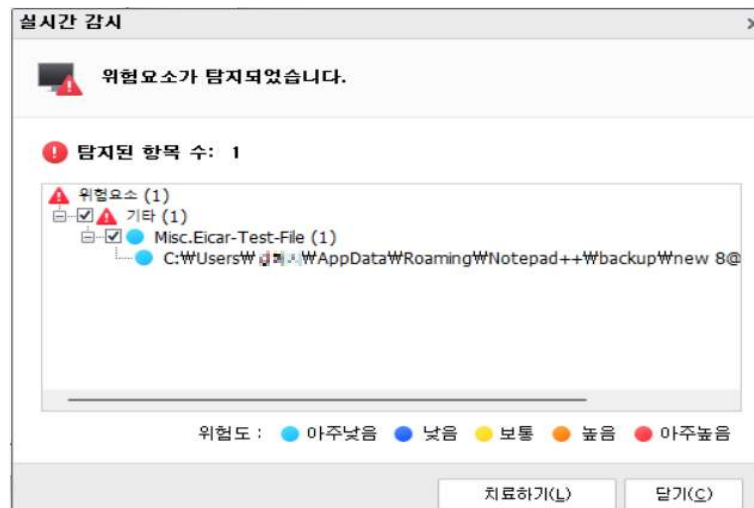


그림 3-21 ▶ 감사 로그 뷰어 기능만 제공 적용 사례

감사로그 현황							
상태	전체	작업대상	전체	작업일자	최근 1일	작업자 ID	검색
No	상태	작업대상	작업일자	작업명	작업자 ID	작업자 IP	작업내용
> 1	SUCCESS	콘솔	2024-08-23 15:15:55	MoveMenu	igloosec	192.168.70.42	MoveMenu [services]:[system-audit-log]
> 2	SUCCESS	콘솔	2024-08-23 15:02:18	MoveMenu	igloosec	192.168.70.42	MoveMenu [services]:[spot-dashboard]
> 3	SUCCESS	콘솔	2024-08-23 15:02:17	Login	CONSOLE	192.168.70.42	Login [igloosec]
> 4	SUCCESS	콘솔	2024-08-23 14:55:57	Logout	CONSOLE	192.168.50.68	Logout [igloo]
> 5	SUCCESS	콘솔	2024-08-23 14:55:52	MoveMenu	igloo	192.168.70.42	MoveMenu [services]:[spot-dashboard]
> 6	SUCCESS	콘솔	2024-08-23 13:39:34	MoveMenu	igloo	192.168.70.42	MoveMenu [services]:[spot-dashboard]
> 7	SUCCESS	콘솔	2024-08-23 13:39:32	Login	CONSOLE	192.168.70.42	Login [igloo]

실증 사례

표 3-20 ▶ 실증 사례

내용	
우수 사례	• 안티바이러스 프로그램의 실시간 악성코드 탐지 기능 활성화 - 설치된 안티바이러스 프로그램이 최신 패턴 기반으로 실시간 탐지 기능을 제공하여, 악성코드 유입 또는 실행 시 즉시 차단할 수 있는 보호 체계를 갖추고 있다. • 감사 로그는 읽기 전용으로 운영되며 수정·삭제가 불가능한 구조 - 감사 로그는 CBS 내부에서 오직 조회(View)만 가능하고, 사용자가 임의로 삭제하거나 수정할 수 없도록 설계되어 있다. 이를 통해 감사 기록의 무결성과 신뢰성을 보장하며, 안전한 감사 환경을 제공한다.
미흡 사례	• 실시간 악성코드 패턴 탐지 기능 미지원 프로그램 사용 - CBS에서 안티바이러스 프로그램이 동작하더라도 실시간 탐지 기능이 제공되지 않아, 악성코드 유입 시 즉각적인 탐지 및 차단이 이루어지지 않는 문제가 확인되었다. 이로 인한 감염 확산 위험성이 높아지고 대응 시간이 지연될 수 있다. • 미등록 계정 로그인 시도에 대한 감사 로그 미기록 - 등록되지 않은 계정이 로그인 시도를 했음에도 불구하고 해당 이벤트가 감사 로그에 기록되지 않는 것으로 확인되었다. 이는 비인가 접근 탐지가 불가능해지고, 공격 전 조짐을 식별할 수 없는 보안 문제로 이어진다. • 감사 로그에 삭제 및 수정 기능 존재 - 감사 로그 기능에 로그 삭제 또는 수정이 가능한 기능이 있어, 내부 또는 외부 공격자가 기록을 임의로 조작할 수 있는 문제점이 존재한다. 감사 로그는 원칙적으로 읽기 전용(READ-ONLY)으로 운영되어야 하며, 해당 구조는 무결성을 보장하지 못하는 상태이다.

개선 권고사항

- 행위 기반의 악성코드 탐지 보안 프로그램(EDR) 도입 권고
 - 기존 단순 백신(Anti-Virus) 수준의 탐지 기능에서 벗어나, 행위 기반 위협 탐지·분석이 가능한 ²¹⁾ EDR(Endpoint Detection & Response) 프로그램 도입을 권고한다. EDR은 악성코드뿐 아니라

21) EDR(Endpoint Detection & Response): PC·서버 등 단말에서 위협을 실시간 탐지·분석하고 자동 대응까지 수행하는 보안 프로그램

비정상 프로세스, 내부 이상 징후, 원격 공격 시도 등 고급 위협에 대한 실시간 대응이 가능하여 시스템 보안성을 크게 향상될 수 있다.

- 로그인 시도 및 접근 이벤트의 전면 기록
 - 관리자 · 일반 사용자 · 외부 계정 등 모든 로그인 시도에 대해 성공/실패 여부를 포함한 이벤트를 감사 로그로 기록하도록 설정해야 한다. 이를 통해 비인가 접근 탐지 및 사고 대응 속도를 높일 수 있다.

3.2.20 결정론적 출력

🔍 점검 목적

CBS는 전원 이상 등으로 인해 비정상 작동이 발생할 경우를 대비하여 대체 기능을 제공해야 한다. 상태에 대한 예시는 다음과 같다.

- 무전원 상태, 마지막 알려진 값 또는 고정값

🔍 점검 내용

- 출력값 정의 및 적용 여부 점검
 - CBS에서 사용되는 출력값(Output Value)이 명확히 정의되어 있는지 확인하며, 설정된 출력값이 실제 장비 동작 및 화면 표시 · 알람 등과 일치하게 적용되는지 점검한다.
- 시스템 재기동 시 자동 복구 여부 점검
 - 장비 재부팅(전원 재인가, 시스템 재시작) 후 설정된 출력값, 제어 파라미터, 운영 상태가 자동으로 복구되는지 확인한다.
 - 재기동으로 인한 초기화로 동작 값이 임의 변경되거나 손실되는 현상이 없는지 점검한다.

그림 3-22 ▶ 재부팅 후 자동 서비스 활성화 기능 사례

```
root@igloo:/SIEM_DATA/parser/exd-owl-parser-data-0/syslog_evt_file/192.168.50.48
Context: default      <0> all      <ctrl-d> Delete      <shift-f> Port-Forward
Cluster: default      <1> exd      <d> Describe    <r> Restart
User: default         <2> default  <e> Edit       <s> Scale
K9s Rev: v0.27.4      <?>        <l> Help       <y> YAML
K8s Rev: v1.24.13+k3s1
CPU: 6%               <p>         <p> Logs Previous
MEM: 33%

-----o-e-(-l)-l-----Deployments(all) [45]-----
NAMESPACE NAME READY UP-TO-DATE
ai ai-apiserver 1/1 1
ai ai-loader 1/1 1
ai ai-mapper 1/1 1
ai ai-predictor 1/1 1
analyzer api 1/1 1
analyzer core 1/1 1
analyzer flink-kubernetes-operator 1/1 1
cattle-fleet-local-system fleet-agent 1/1 1
cattle-fleet-system fleet-controller 1/1 1
cattle-system gitjob 1/1 1
cattle-system rancher 1/1 1
cattle-system rancher-webhook 1/1 1
cert-manager cert-manager 1/1 1
cert-manager cert-manager-cainjector 1/1 1
cert-manager cert-manager-webhook 1/1 1
clickhouse clickhouse-operator-altinity-clickhouse-operator 1/1 1
```

🔍 실증 사례

표 3-21 ▶ 실증 사례

내용	
우수 사례	• CBS 복구에 필요한 출력값 정의 및 적용 - CBS 운영에 필요한 핵심 출력값(Output Parameters)을 사전에 정의하고, 해당 값들이 장비 내에 정상적으로 적용되도록 구성되어 있다. 이를 통해 장애나 설정 초기화 발생 시에도 필요한 기준값이 유지되어 안정적인 시스템 운영이 가능하다. • CBS 재기동 시 이전 상태로 자동 재시작 - CBS가 재부팅되더라도 운영 중이던 상태를 자동으로 복원하여 재시작하도록 구성되어 있다.

미흡 사례	• 복원에 필요한 출력값 정의가 없음 - CBS가 재기동 되거나 오류 발생 후 복구될 때 필요한 출력값(Output Value)에 대한 정의가 마련되어 있지 않아, 장비가 어떤 상태로 복원되어야 하는지 기준이 부재한 상황이다. 이는 복구 과정에서 잘못된 동작이 발생할 가능성을 높인다. • CBS 재기동 시 출력값 초기화 - 재부팅이 발생하는 경우 장비 출력값이 기본값으로 초기화되어, 운영 중이던 실제 설정이나 상태가 유지되지 않는 문제가 확인되었다. • CBS 재기동 후 이전 상태 복구 기능 부재 - 재기동 이후 장비가 재부팅 이전의 상태로 자동 복구되지 않고, 사용자가 다시 설정을 입력해야만 정상 동작이 가능하다. 이러한 구조는 비상 상황에서의 복구 시간 증가의 원인이 된다.
---------------------	--

🔗 개선 권고사항

- 출력값 복원을 위한 백업 데이터 별도 제공
 - 출력값 복원에 필요한 데이터는 시스템 내부 또는 별도 저장소에 안전하게 백업해 두고, 재기동 시 이를 기반으로 자동 복원이 가능하도록 구성할 것을 권장한다. 이를 통해 장애 발생 시 안정적이고 예측 가능 상태로 복구할 수 있다.
- CBS 재기동 시 모든 서비스 자동 시작 적용
 - CBS가 재부팅되더라도 주요 서비스가 자동으로 재시작되도록 설정하여, 장비 중단 시간을 최소화하고 정상 동작을 신속하게 복구할 수 있도록 개선을 권고한다.
- 복원되는 출력값은 명확한 기준으로 정의
 - CBS 재기동 후 복구되어야 하는 출력값(Output Value)을 명확히 정의하고, 해당 값이 일관되게 적용되도록 설정하여 재기동 시 예상치 못한 초기화나 상태 불일치가 발생하지 않도록 관리해야 한다.

3.2.21 정보 기밀성

🔍 점검 목적

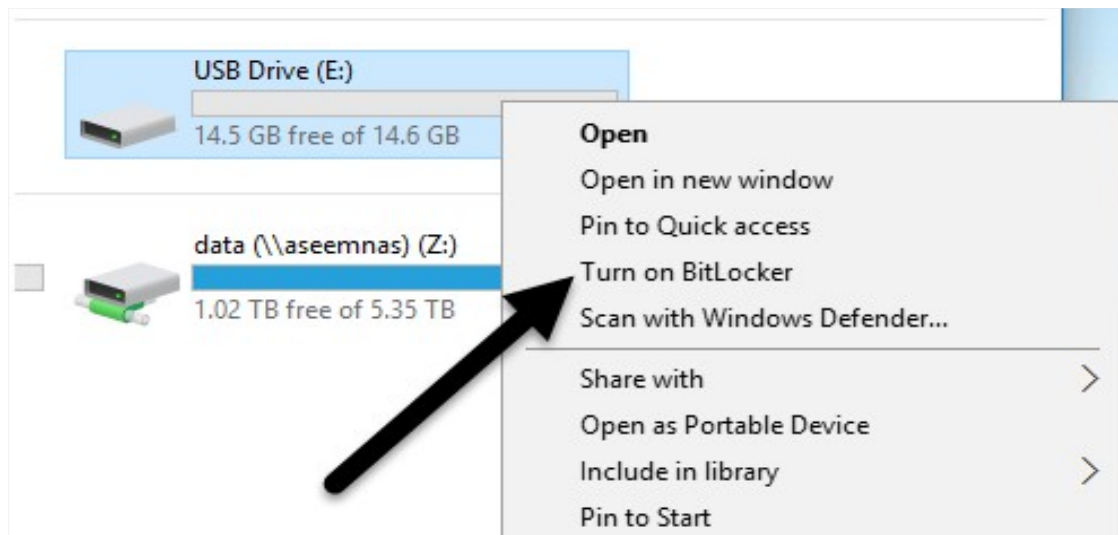
CBS는 사용하지 않거나 전송 중인 정보에 대해 명시적인 읽기 권한이 필요한 경우, 해당 정보의 기밀성을 보호하는 기능을 제공해야 한다.

- 무선 네트워크의 경우 전송 중인 모든 정보의 기밀성을 보호하기 위해 암호화 메커니즘을 사용해야 한다.
- 단, Serial 링크와 같은 통신 환경에는 적용하지 않음

🔍 점검 내용

- 저장 데이터에 대한 암호화 기술 적용 여부 점검
 - CBS 내부에 저장되는 자료 및 운영 데이터 등이 암호화된 형태로 보관되는지를 확인한다. 저장 데이터가 평문으로 보관되는 경우 탈취 · 조작 위험이 존재하므로 암호화 여부가 핵심 점검 항목이다.
- 전송 데이터에 대한 암호화 기술 적용 여부 점검
 - 장비 간 데이터 송수신, 원격 접속, 관리 인터페이스 등 통신 구간에서 TLS 등 암호화 프로토콜이 적용되는지 점검한다.

그림 3-23 ▶ 윈도우 22)BitLocker 설정 화면 예시



22) BitLocker: Windows 환경에서 디스크 전체를 암호화해 데이터 유출을 방지하는 보안 기능

```

[lawrencet@tomz]~/dev/mapper
$ls -la
total 0
drwxr-xr-x 2 root root 160 Feb 15 11:30 .
drwxr-xr-x 23 root root 4560 Feb 15 11:30 ..
crw----- 1 root root 10, 236 Feb 14 08:34 control
lrwxrwxrwx 1 root root 7 Feb 14 08:34 cryptdata_NYSKa -> ../dm-0
lrwxrwxrwx 1 root root 7 Feb 14 08:34 cryptswap_OMSHW -> ../dm-2
lrwxrwxrwx 1 root root 7 Feb 14 08:34 data_GGvVM-root -> ../dm-1
lrwxrwxrwx 1 root root 7 Feb 15 11:30 luks-9d077170-ad53-4f3e-aafc-859a211a2b2d -> ../dm-4
lrwxrwxrwx 1 root root 7 Feb 14 08:35 luks-c27339de-6333-496a-a943-a8074f8f43bd -> ../dm-3
[lawrencet@tomz]~/dev/mapper
$

```

실증 사례

표 3-22 ▶ 실증 사례

내용	
우수 사례	- 저장 데이터 암호화 적용을 위한 전용 저장 공간 지정 - CBS에 자료가 저장되는 별도의 전용 저장 공간을 구성하고, 해당 저장 영역에 암호화 기술을 적용하여 운영하고 있다. 이를 통해 내부 접근 시도 등 다양한 상황에서도 데이터 노출 위험을 효과적으로 차단하고, 저장 데이터의 기밀성을 강화하였다. - 네트워크 통신 구간에 암호화 프로토콜 적용 - 장비 간 데이터 전송 과정에서는 TLS 등 암호화된 네트워크 통신 프로토콜을 적용하여 전송 데이터가 외부에서 도청되거나 변조되지 않도록 보호하고 있다. 암호화된 통신 방식을 적용함으로써 이동 중인 데이터의 안전성을 확보하고, 전송 경로에서 발생할 수 있는 보안 위험을 최소화하였다.
미흡 사례	- 저장 데이터가 암호화되지 않고 원본 형태로 저장됨 - 일부 기자재는 제한된 저장 공간, 낮은 연산 성능 등 선박용 임베디드 장비의 기술적 제약으로 인해 저장 데이터를 암호화하지 못하고 원본 형태로 보관하고 있다. 이러한 구조는 환경적 한계로 인해 발생한 것으로 보이나, 저장 데이터가 직접 노출될 가능성을 완전히 배제하기 어려워 보안상 취약점으로 평가될 수 있다. - 네트워크 통신이 평문 프로토콜 기반으로 운영됨 - 선박 내부 네트워크에서 사용되는 특정 구형 장비는 통신 규격 및 성능 한계로 인해 암호화 통신 적용이 어려워, 여전히 평문 프로토콜을 사용하는 구간이 존재한다. 이는 장비 교체 주기가 길고 제조사 지원이 제한적인 선박 환경의 특성에서 기인한 문제로 이해되나, 통신 내용이 직접 노출될 가능성이 있어 보안 관점에서는 미흡 항목으로 분류된다.

23) LUKS: Linux에서 표준으로 사용되는 디스크 전체 암호화 방식으로, 강력한 키 관리와 보안성을 제공하는 기술

○ 개선 권고사항

- 데이터 저장 시 별도 디스크 공간 분리 및 저장 데이터 암호화 적용
 - 중요 데이터는 전용 저장 영역을 분리하여 보관하고, 저장 시 암호화 기술을 적용함으로써 데이터 유출 및 무단 접근 위험을 최소화할 것을 권고한다.
- 데이터 통신 구간에 TLS 또는 ²⁴⁾VPN 기반 암호화 프로토콜 적용
 - 시스템 간 데이터 전송 과정에서는 TLS 통신 또는 VPN 암호화 터널링을 적용하여, 통신 구간에서의 도청 · 변조 위험을 방지하고 안정적인 보안 통신 환경을 구축하도록 한다.

24) VPN(Virtual Private Network): 인터넷 구간을 암호화하여 멀리 떨어진 네트워크에 안전하게 접속할 수 있게 해주는 보안 통신 기술

3.2.22 암호 사용

🔍 점검 목적

CBS에 암호화 기술이 사용되는 경우, 보안 산업 규정 및 권고에 따라서 암호 알고리즘, 키 길이 및 메커니즘을 사용해야 한다.

🔍 점검 내용

- 중요 정보 저장 데이터 암호화 방식 적용 여부 점검
 - CBS가 저장하거나 처리하는 중요 정보가 검증된 암호화 알고리즘을 기반으로 안전하게 암호화되어 저장되는지 확인한다.
- 취약 알고리즘 사용 여부 점검
 - 암호화 또는 해시 처리 과정에서 구버전 · 취약 알고리즘(MD5, SHA1, DES, RC4 등)이 사용되고 있는지 확인한다.

표 3-23 ▶ 암호화 알고리즘 예시

종류	예시
25)대칭키 암호	ARIA, SEED, LEA, HIGHT, AES, TRIPLE-DES(TRIPLE-KEY)
26)공개키 암호	RSA, ECC
27)해시	SHA2, SHA3, HMAC

그림 3-25 ▶ 패스워드 정보 암호화 알고리즘 적용 사례

user_id	user_pwd
t240717	9993638121e888345ad15f4cf59b5666e2cfce30253a1fd27de17a21e2a8e7a1c504d35fb7e9a332b5e20a7a3bf524f528ce2b1e0ce4bc552789ef6f2c9f64ee5bc8e6e69dafd22c414354a8a404ede
test313	8c8e17c78129c548488b540152ba9a687615caa79f578d7090af56e6bcfea01c106dc6b1c8144784fc07e91a9f94d4e3cded2c45aeecc8181e0374b1a661de83a4f28ce879fd0f2a84f3e7489a2228af24
test314	2b2f778d1b02015295dce05bf9ce8d7262e0b1a0ae3fab3c68158da717427cd8251bd72467002f404021c622897bb6de76f9f76b4681179a0dd6ec5144a363db947dde46dea5efb651da824dda1e0e7a
test318	f41d361258bcf3c1121849125acd18b7f1222d275a3908cbfa035245cdbc3fbad4e215fafb4b98c098d66703a01681a23bbb181bfb196e3c74ba17920bd5be0ff46e20ea930e066310b1da754747376c

🔍 실증 사례

표 3-24 ▶ 실증 사례

내용	
우수 사례	• 중요 정보 AES 기반 암호화 적용 - CBS에서 저장되거나 처리되는 중요 정보에 대해 AES 기반의 강력한 대칭키 암호화 기술이 적용되어 있다. 이를 통해 데이터 노출 및 변조 위험을 효과적으로 차단하고, 국제 표준

25) 대칭키 암호: 하나의 동일한 키로 암호화와 복호화를 모두 수행하는 암호 방식

26) 공개키 암호: 공개키로 암호화하고 개인 키로 복호화하는, 두 개의 키를 사용하는 비대칭 암호 방식

27) 해시: 임의의 데이터를 고정 길이 정보로 변환해 무결성 확인 등에 사용하는 단방향 암호 함수

	수준의 보안성을 확보하게 된다. • 최신 암호화 라이브러리 사용 - CBS는 최신 버전의 암호화 라이브러리(OpenSSL 등)를 적용하여 운영되고 있다. 구버전에서 발견된 취약점을 제거하고, 최신 암호 모듈의 보안 기능을 활용함으로써 안정성이 강화되었다.
미흡 사례	• 중요 정보 암호화 미적용(평문 저장) - CBS에 중요한 데이터가 암호화되지 않은 평문 형태로 저장되고 있어, 중요 정보 유출 위험에 직접적으로 노출된다. • 취약한 암호화 알고리즘(MD5, SHA1 등) 사용 - 중요 정보 보호에 MD5, SHA1 등 이미 취약점이 공개된 알고리즘을 사용하고 있어, 무결성 검증 및 데이터 보호 수준이 충분히 확보되지 못한 상태이다. 이러한 취약 알고리즘 사용은 사이버 공격에 취약해 보안 위협을 유발할 수 있다.

개선 권고사항

- 최신 암호화 알고리즘 기술 적용
 - CBS 내 중요 정보를 보호하기 위해 AES 등 검증된 최신 암호화 알고리즘을 적용하도록 권고한다. 최신 암호 기술을 사용함으로써 데이터 노출 및 변조 위험을 효과적으로 줄일 수 있다.
- 취약 알고리즘 즉시 삭제 및 변경 검토
 - MD5, SHA-1, DES 등 보안 취약성이 확인된 암호 알고리즘은 즉시 제거하고 사용을 중단하도록 권고한다. 취약 알고리즘이 남아 있는 경우 공격자에 의해 데이터가 손쉽게 복호화될 수 있으므로 즉각적인 조치가 필요하다.

3.2.23 감사 로그 접근성

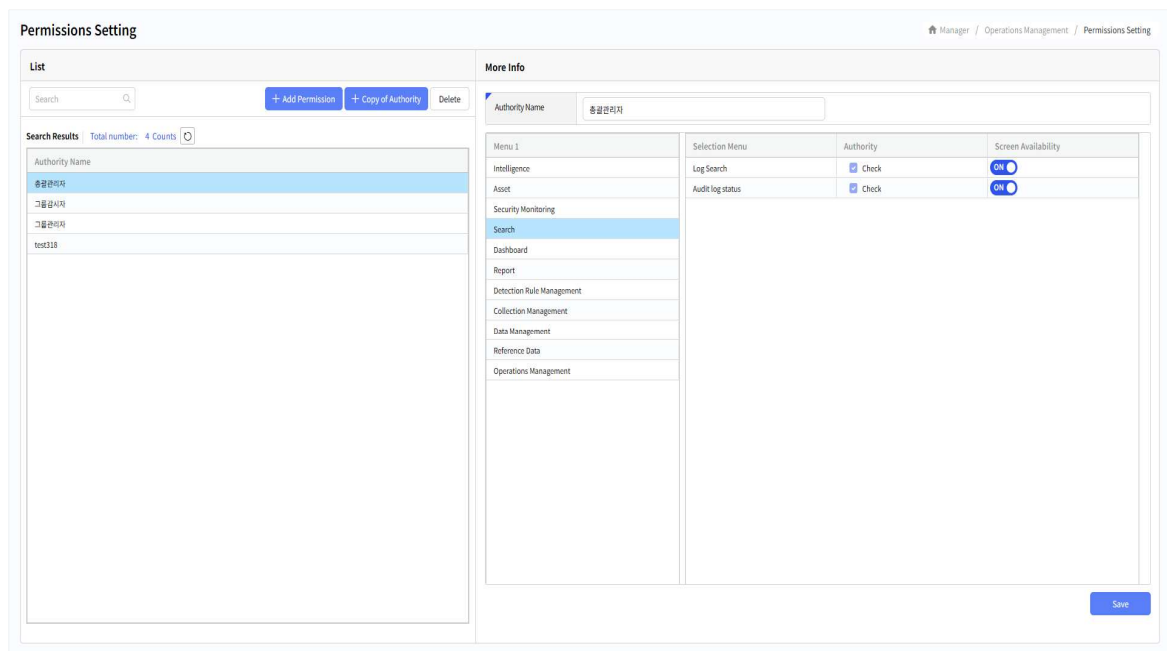
🔍 점검 목적

CBS는 허가된 사용자 또는 도구에 의해 읽기 전용 기반으로 감사 로그에 접근하는 능력을 제공해야 한다.

🔍 점검 내용

- 감사 로그 접근 권한 통제 여부 점검
 - CBS에서 감사 로그에 접근할 수 있는 사용자가 관리자 등 최소 권한자로 제한되어 있는지 점검한다. 일반 사용자 또는 불필요한 계정이 로그를 열람하거나 접근할 수 없는지 확인하며, 로그 접근 권한이 역할 기반으로 명확히 통제되고 있는지를 확인한다.
- 로그 파일 무결성 보장 여부 점검
 - 감사 로그가 임의로 수정 · 삭제되지 않도록 무결성 보호 기능이 적용되어 있는지 점검한다.

그림 3-26 ▶ 감사 로그 권한 설정 기능 적용 사례



🔍 실증 사례

표 3-25 ▶ 실증 사례

내용	
우수 사례	• 감사 로그 접근 권한 통제 적용 - CBS에서 생성되는 감사 로그에 접근할 수 있는 사용자가 관리자 계정으로 제한되어 있으며, 일반 사용자 또는 외부 계정이 로그 파일에 접근할 수 없도록 권한이 통제되어 있다. 이를 통해 무단 열람으로 인한 보안 위험을 효과적으로 차단하고 있다.

	• 로그 파일 무결성 보장 적용 - 감사 로그는 저장 과정에서 무결성 체크 기능(Integrity Check) 이 적용되어 있어, 로그 파일이 임의로 수정되거나 삭제되는 것을 방지하고 있다. 로그 변경 시도 발생 시 관리자에게 경고가 전달되어, 로그 조작 위험을 최소화하는 우수한 운영 사례로 평가된다.
미흡 사례	• 일반 사용자 계정 로그 파일 접근 가능 - 로그 접근 권한이 적절히 분리되어 있지 않아 일반 사용자도 감사 로그 파일에 접근할 수 있는 것으로 확인되었다. 이는 로그 열람을 통한 시스템 정보 노출 위험을 증가시킨다. • 로그 파일 임의 삭제 가능 - 감사 로그 파일에 대한 보호 기능이 없어, 사용자 또는 프로세스에 의해 로그가 임의로 삭제될 수 있는 취약점이 존재한다. 이는 보안사고 근거 데이터 확보를 어렵게 하며, 증거 보존 관점에서 심각한 보안 위험을 초래한다. • 로그 손상 · 로그 기록 누락 잦음 - 로그 파일의 무결성 보장 기능이 부재하여 일부 로그가 손상되거나 기록이 누락 되는 사례가 반복적으로 확인되었다. 이는 시스템 행위 기록의 신뢰성을 훼손하고, 이상 행위 보안 감사를 수행하는 데 문제점을 발생시킨다.

🔍 개선 권고사항

- 로그 접근 권한 최소화 적용
 - 감사 로그는 관리자 등 최소 권한 사용자만 접근 설정하고, 일반 사용자 계정의 조회·다운로드·삭제 권한은 차단하도록 개선한다. 이를 통해 감사 로그에 대한 비인가 접근 및 조작 위험을 방지할 수 있다.
- 로그 파일 무결성 검증 기능 도입
 - 로그 파일이 임의 삭제되거나 변조되지 않도록, 무결성 검증 기능(Hash 기반 무결성 체크 등)을 적용할 것을 권고한다. 로그 손상 · 누락이 발생하는 경우 즉시 감지 가능한 구조를 마련하여 감사 기능의 신뢰성을 확보하도록 한다.

3.2.24 서비스 거부 보호

🔍 점검 목적

CBS는 ²⁸⁾DoS 공격 시에도 중요한 기능을 유지할 수 있는 최소한의 능력을 제공해야 한다.

- DoS 공격 시 시스템이 성능 저하 기능을 작동하는 것은 허용될 수 있지만, 위험한 상황을 초래할 수 있는 방식으로 실패해서는 안 된다. CBS의 자원이 소모되는 경우와 같은 과부하 기반 DoS 이벤트를 고려해야 한다.

🔍 점검 내용

- 비정상 요청에 대한 Rate-limit 적용 여부 점검
 - CBS가 반복적이거나 비정상적인 요청에 대해 Rate-limit(요청 제한) 기능을 적용하여 과도한 요청으로 인한 서비스 지연 또는 무력화 공격(DoS) 시도를 방지하고 있는지 점검한다.
- CPU·메모리 자원 임계치 보호 여부 점검
 - 장비 또는 시스템이 CPU 및 메모리 사용량이 임계 수준에 도달했을 때 자동으로 보호 조치를 수행하는지(프로세스 조절, 경보 발생, 서비스 제한 등) 확인한다.
- 네트워크 트래픽 폭주 감지 기능 여부 점검
 - 비정상적인 네트워크 트래픽 증가(예: ²⁹⁾Flooding, ³⁰⁾Broadcast Storm 등)를 인식 · 차단하기 위한 탐지 기능이 적용되어 있는지 확인한다.

그림 3-27 ▶ DoS 공격 방어 기능 적용 사례

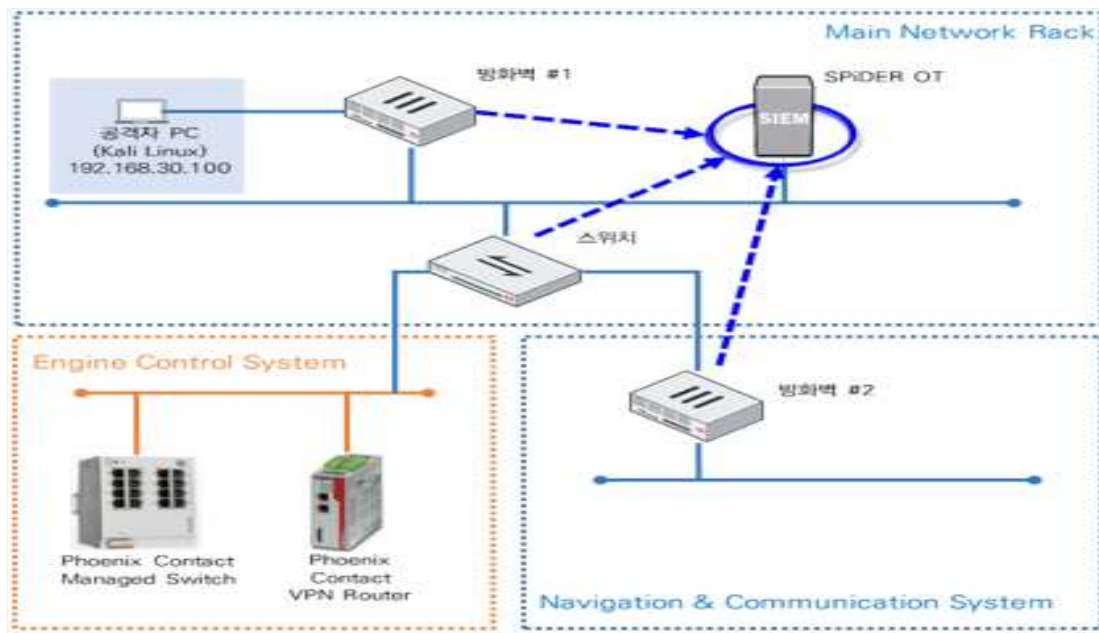


28) DoS(Denial of Service): 해커에 의해 다량의 트래픽이 특정 서버로 유입되어 시스템 및 네트워크에 가용성 서비스를 방해하는 공격

29) Flooding: 네트워크에 과도한 트래픽을 의도적으로 발생시켜 장비나 서비스를 마비시키는 공격 또는 현상.

30) Broadcast Storm: Broadcast 패킷이 통제 없이 폭증하여 네트워크 전체가 과부하로 멈추는 상태.

그림 3-28 ▶ DoS 공격 시연 구성도 사례



실증 사례

표 3-26 ▶ 실증 사례

내용	
우수 사례	- 비정상 패킷 자동 차단 기능 적용 - CBS는 기준을 초과하는 비정상 요청이나 의심 패킷을 자동으로 식별 · 차단하는 기능을 제공한다. 이를 통해 외부 공격(스캔, 반복 요청, 비정상 트래픽 등)에 대한 즉각적인 대응이 가능하며 서비스 안정성이 크게 향상된다. - 과부하 발생 시 자동 보호 모드 전환 - CPU · 메모리 사용률이 임계치를 초과하는 경우 CBS가 자동으로 보호 모드로 전환되어 자원 고갈을 방지한다. 이 기능은 정상 서비스 유지와 장애 확산 방지에 효과적이며, 트래픽 폭주 상황에서도 시스템 가용성 확보가 가능하다.
미흡 사례	- 다수 접속 시 시스템 응답 불가 - 정상적으로 많은 요청이나 동시 접속이 발생하는 경우 시스템이 즉시 응답 불가 상태로 전환되어, 정상 사용자조차 서비스를 이용할 수 없는 상황이 발생한다. 이는 Rate-limit 기능 부재와 관련된 운영상의 문제점으로 확인된다. - 과부하 상황에 대한 대처 기능 부재 - CPU · 메모리 등 자원 사용량이 임계치를 초과하더라도 자동 보호 모드나 자원 재할당 기능이 없어, 시스템 전체가 중단되는 장애로 이어질 위험성이 높다. 과부하 감지 및 대응 체계가 미비하여 서비스 안정성이 저하되는 대표적인 문제점이다.

◉ 개선 권고사항

- DoS/DDoS 대응 기능을 갖춘 보안 장비 포함 구성
 - 네트워크 구간에 DoS/DDoS 대응 기능을 포함한 보안 장비가 구성되어 있어 비정상 트래픽 및 공격 패턴을 실시간으로 탐지 · 차단할 수 있다.
 - 대량 접속, 서비스 폭주 등 과부하 상황이 발생하는 경우 자동 보호 모드로 전환되어 시스템을 안정적으로 유지하며, 서비스 중단 위험을 최소화한다.
- 비정상 접속 자동 차단 기능 적용
 - CBS는 비정상 요청이나 반복 실패 요청에 대해 자동으로 차단할 수 있는 보호 기능을 활성화해야 한다. 이를 통해 과도한 연결 시도, 인증 우회 시도 등을 조기에 차단하여 서비스 중단 및 시스템 자원 고갈 위험을 줄일 수 있다.
- 자원 모니터링 및 과부하 알림 기능 활성화
 - CPU · 메모리 · 네트워크 사용량을 지속적으로 모니터링 및 자원 임계치 도달 시 관리자에게 알림이 전달되도록 구성해야 한다. 이는 과부하 상황을 사전에 인지하고 대응할 수 있도록 하여 전체 시스템 안정성을 높이는 핵심적인 보안 강화 조치이다.

3.2.25 자원 관리

🔍 점검 목적

CBS는 자원 부족을 방지하기 위해 보안 기능의 자원 사용을 제한하는 능력을 제공해야 한다.

🔍 점검 내용

- 자원 사용량 높은 프로그램 실시간 모니터링 여부 점검
 - CBS가 CPU · 메모리 등 주요 자원 사용량이 높은 프로그램을 실시간으로 모니터링 가능한 기능을 제공하는지 점검한다. 이를 통해 과도한 자원 점유로 인한 성능 저하나 서비스 중단 위험을 사전에 감지할 수 있는지 확인한다.
- 자원 우선순위 관리 기능 존재 여부 점검
 - 중요 서비스가 안정적으로 동작하도록 프로세스 우선순위를 조정하거나 제한할 수 있는지 확인한다. 자원 부족 상황에서도 핵심 프로세스는 보호될 수 있어야 한다.

그림 3-29 ▶ 윈도우 운영체제 우선순위 적용 사례

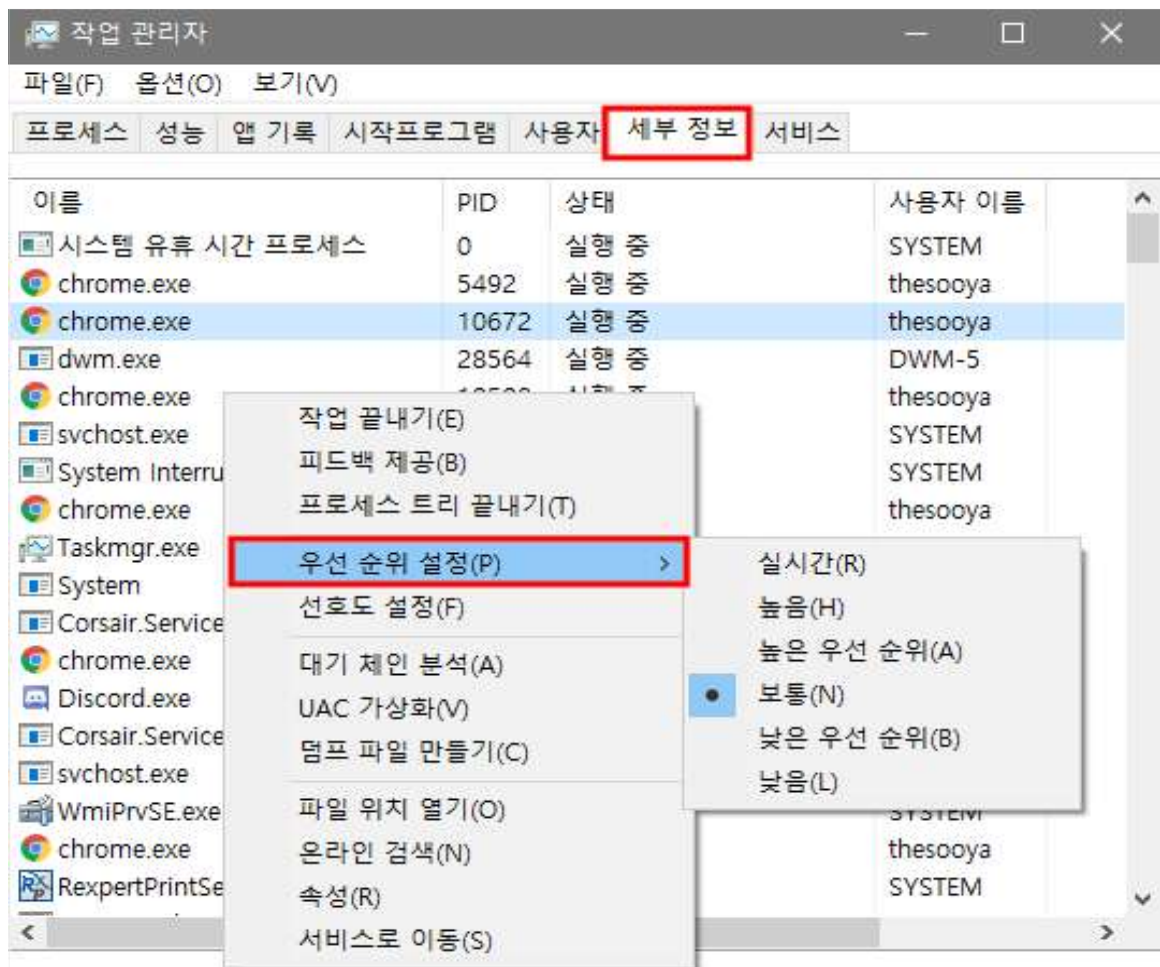


그림 3-30 ▶ 리눅스 운영체제 우선순위 적용 사례

```

top - 02:18:44 up 2:30, 2 users, load average: 1.97, 1.10, 0.50
Tasks: 152 total, 3 running, 104 sleeping, 0 stopped, 0 zombie
%Cpu(s): 99.7 us, 0.0 sy, 0.0 ni, 0.0 id, 0.0 wa, 0.0 hi, 0.3 si, 0.0 st
KiB Mem : 2040924 total, 888628 free, 375044 used, 777252 buff/cache
KiB Swap: 2017276 total, 2017276 free, 0 used. 1487720 avail Mem
  
```

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
3109	root	0	-20	4384	796	732	R	90.0	0.0	2:16.05	myprog
3110	root	10	-10	4384	804	740	R	9.6	0.0	2:31.23	yumipro
1	root	20	0	160032	9208	6640	S	0.0	0.5	0:03.95	systemd
2	root	20	0	0	0	0	S	0.0	0.0	0:00.03	kthreadd
4	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	kworker/0:0H
6	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	mm_percpu_wq
7	root	20	0	0	0	0	S	0.0	0.0	0:00.21	ksoftirqd/0
8	root	20	0	0	0	0	I	0.0	0.0	0:00.16	rcu_sched
9	root	20	0	0	0	0	I	0.0	0.0	0:00.00	rcu_bh
10	root	rt	0	0	0	0	S	0.0	0.0	0:00.00	migration/0
11	root	rt	0	0	0	0	S	0.0	0.0	0:00.04	watchdog/0
12	root	20	0	0	0	0	S	0.0	0.0	0:00.00	cpuhp/0
13	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kdevtmpfs
14	root	0	-20	0	0	0	I	0.0	0.0	0:00.00	netns
15	root	20	0	0	0	0	S	0.0	0.0	0:00.00	rcu_tasks_kthre
16	root	20	0	0	0	0	S	0.0	0.0	0:00.00	kauditd
17	root	20	0	0	0	0	S	0.0	0.0	0:00.00	khungtaskd
18	root	20	0	0	0	0	S	0.0	0.0	0:00.00	oom_reaper

실증 사례

표 3-27 ▶ 실증 사례

내용	
우수 사례	- 프로세스 자원 사용량 80% 초과 시 알림 - CBS는 실행 중인 프로세스의 CPU · 메모리 사용량을 실시간 모니터링, 특정 프로세스가 자원 사용량 80%를 초과하는 경우 관리자에게 즉시 알림을 제공하도록 구성되어 있다. 이를 통해 자원 고갈 및 서비스 지연 가능성을 사전에 감지하고 대응할 수 있다. - 정의된 자원 우선순위 관리 프로세스 존재 - 운영 중인 주요 프로세스는 중요도 기반 자원 우선순위가 사전에 정의되어 있으며, CBS는 이 기준에 따라 자원을 안정적으로 배분한다. 이를 통해 필수 기능이 과부하 환경에서도 안정성을 유지하도록 보장되고 있다. - 설계되지 않은 신규 프로세스에 대한 실행 불가 - CBS는 승인되지 않은 신규 프로세스가 실행되지 않도록 화이트리스트 기반 실행 통제 정책을 적용하고 있다. 정의되지 않은 프로그램은 자동으로 차단되므로, 불필요한 자원 점유와 악성 프로세스 실행 위험을 효과적으로 예방하고 있다.
미흡 사례	- 자원 사용량에 대한 우선순위 설정 불가 - CBS 내에서 프로세스별 자원 우선순위를 지정하거나 관리하는 기능이 없어, 특정 프로세스가 과도한 자원을 사용하더라도 우선순위 기반의 제어가 이루어지지 않는다. 이는 전체 시스템 성능 저하 및 서비스 지연으로 이어질 수 있는 문제점이다. - 프로세스 자원 사용량 초과에 대한 알림 부재 - CPU · 메모리 등 시스템 자원이 임계치를 초과하더라도 관리자에게 알림이 제공되지 않아, 장애나 과부하 상황을 조기에 인지하기 어렵다. 그 결과 비정상 프로세스나 무한 루프 등으로 인해 시스템 전체가 영향을 받을 위험이 존재한다.

◉ 개선 권고사항

- 프로세스 자원 모니터링 기능 구축
 - CBS 내 주요 프로세스의 CPU · 메모리 사용량을 실시간으로 감시할 수 있는 프로세스 자원 모니터링 기능을 구축하여 과도한 자원 점유로 인한 서비스 장애를 예방할 것을 권고한다.
- 우선순위가 정의되지 않은 프로세스 모니터링 기능 구축
 - 자원 우선순위가 사전에 설정되지 않은 신규 프로세스나 비인가 프로세스가 실행될 경우, 이를 식별하고 관리자가 확인할 수 있도록 별도의 모니터링 기능을 추가해 시스템 안정성을 강화하는 것이 바람직하다.

3.2.26 시스템 백업

🔍 점검 목적

CBS는 시스템 상태 정보를 백업하는 동안, 시스템의 정상적인 작동에 영향을 미치지 않도록 지원해야 한다.

🔍 점검 내용

- CBS의 설정 및 데이터 백업 여부 점검
 - CBS의 주요 설정값과 운영 데이터가 정기적으로 백업되고 있는지 확인한다. 또한 백업 방식, 보관 주기, 저장 위치 등이 정의되어 있는지 점검한다.
 - 백업 작업은 시스템의 정상 운영을 저해하지 않도록 운영 영향(성능 저하 · 중단) 없이 안전하게 수행되는지도 함께 확인한다.
- 외부 저장 매체 등 백업 데이터 분리 보관 여부 점검
 - 백업된 데이터가 시스템 본체와 분리된 외부 저장 매체(USB, 외장디스크, NAS 등) 또는 독립된 저장 공간에 안전하게 보관되는지 확인한다.

그림 3-31 ▶수동 백업 기능 적용 사례

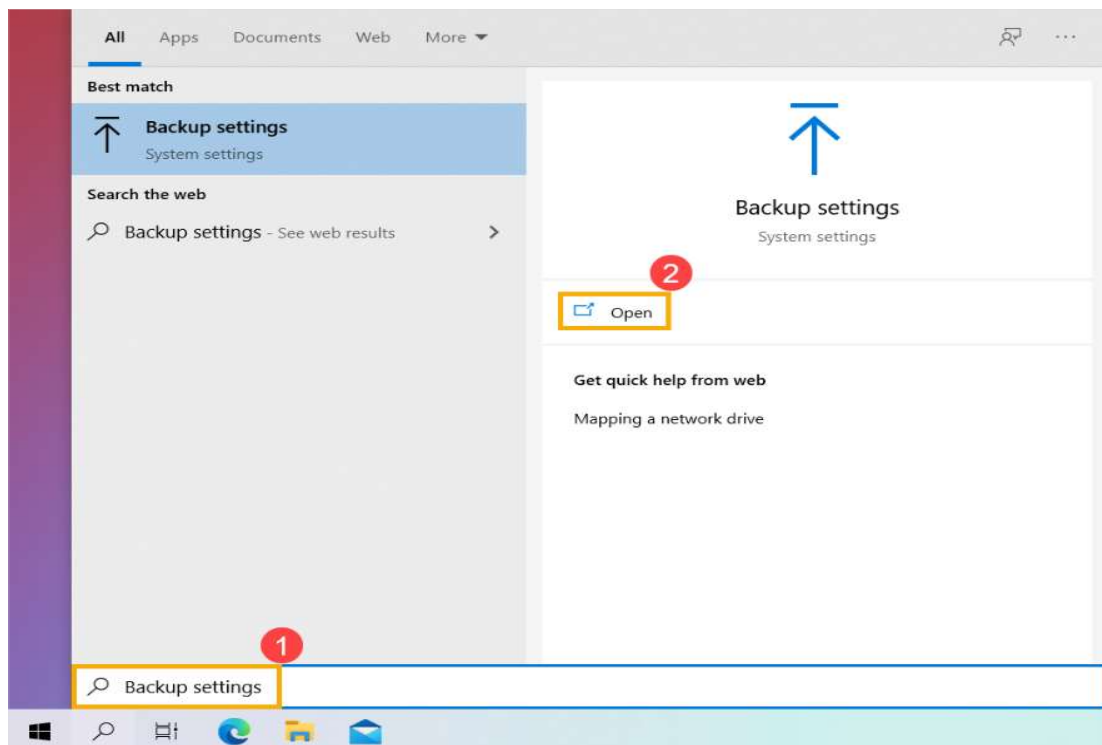


그림 3-32 ▶ 자동화 백업 기능 적용 사례

백업/삭제설정

관리자 / 데이터관리 / 백업/삭제설정

목록

Search

검색결과 총 건수: 4 건

No	대상항목	대상항목명	유형	활성화
1	ALERT	경보	BACKUP	X
2	TABLE	설정데이터	BACKUP	X
3	ALERT	경보	DELETE	X
4	CONTROLLER_TASK	제어로그	DELETE	X

상세 정보

대상항목

ALERT

대상항목명

경보

유형

BACKUP

활성화

OFF

주기

매일

수행 시간

0 시

이전 백업 결과

기록없음

이전 백업 날짜

기록없음

저장

실증 사례

표 3-28 ▶ 실증 사례

내용	
우수 사례	• 설정 백업 파일의 주기적 자동 백업 적용 - CBS의 주요 설정값과 운영 데이터가 정기적으로 자동 백업되도록 설정되어 있으며, 백업 주기와 보관 정책이 명확하게 정의되어 운영 중인 것으로 확인된다. 자동 백업 기능을 통해 장애나 오류로 인한 손실 위험을 감소시킨다. • 암호화된 외부 저장 장치에 안전하게 보관 - 백업된 설정 및 운영 데이터는 암호화된 외부 저장 장치에 별도로 보관되어 있어, CBS 내부 장애 발생 시에도 복구에 필요한 데이터를 안전하게 확보할 수 있다. 또한 백업 저장 매체는 시스템의 운영에 영향을 주지 않도록 물리적 · 논리적으로 분리된 저장소에 보관함으로써, 데이터 유출 위험을 최소화하고 복구 신뢰성을 높이는 사례로 확인된다.
미흡 사례	• 백업 기능 및 안정성 관리 부재 - CBS 내 설정값 및 운영 데이터를 보호하기 위한 백업 기능이 제공되지 않거나 활성화되어 있지 않아, 장애 · 오류 발생 시 복구가 불가능한 상태로 운영되고 있다. 이는 데이터 손실 위험을 증가시키는 주요 보안 문제점이다. • 백업 기능 실행 시 CBS 내 과부하 발생 - 백업 기능을 수동으로 실행하거나 특정 시점에 수행할 경우, CPU · 메모리 자원 사용량이 급증하여 CBS 성능 저하 또는 일시 중단이 발생하는 문제가 확인되었다. 운영 중 백업 수행이 시스템 안정성에 영향을 주는 구조는 백업 체계가 제대로 설계되지 않았음을 의미한다.

◉ 개선 권고사항

- 정기 자동화 백업 기능 적용
 - CBS 운영에 영향을 주지 않는 범위 내에서 설정값 및 운영 데이터에 대한 정기 자동 백업 기능을 활성화할 것을 권고한다. 백업 수행 시 과부하가 발생하지 않도록 일정 조정 및 자원 분배를 고려하여 백업이 안정적으로 수행되도록 구성해야 한다.
- 백업 데이터는 별도 저장 공간에 안전하게 보관
 - 백업된 데이터는 본 시스템과 분리된 별도의 저장 공간 또는 외부 저장 장치에 보관하며, 암호화 저장을 적용하여 데이터 무단 접근을 방지해야 한다. 이를 통해 주요 데이터 손실, 시스템 오류 발생 시 신속한 복구가 가능하다.

3.2.27 시스템 복구 및 재구성

🔍 점검 목적

CBS는 중단 또는 고장 후 기존 상태로 복구하거나 재구성할 수 있는 기능을 제공해야 한다.

- 단, 펌웨어로 구성된 임베디드시스템 등에는 이 요구사항이 적용되지 않을 수 있음

🔍 점검 내용

- 시스템 복구 기능 존재 여부 점검
 - CBS 장애, 설정 오류, 데이터 손상 등의 상황 발생 시 이를 원상태로 복구할 수 있는 시스템 복구 기능이 제공되고 있는지 확인한다.
- 시스템 복구 절차 문서화 여부 점검
 - 복구 과정이 내부 지침 또는 운영 문서에 절차가 작성되어 있는지, 복구 단계 · 책임자 · 복구 파일 위치 · 검증 방법 등이 명확하게 정의되어 있는지 점검한다.

그림 3-33 ▶ 자동 백업 파일 데이터 예시

```
drwxr-xr-x 2 igloo igloo 4096 Feb 19 17:00 TABLE_2024021917
drwxr-xr-x 2 igloo igloo 4096 Feb 20 17:00 TABLE_2024022017
drwxr-xr-x 2 igloo igloo 4096 Feb 22 17:00 TABLE_2024022217
drwxr-xr-x 2 igloo igloo 4096 Feb 23 17:00 TABLE_2024022317
drwxr-xr-x 2 igloo igloo 4096 Feb 24 17:00 TABLE_2024022417
drwxr-xr-x 2 igloo igloo 4096 Feb 26 17:00 TABLE_2024022617
drwxr-xr-x 2 igloo igloo 4096 Feb 28 17:00 TABLE_2024022817
drwxr-xr-x 2 igloo igloo 4096 Feb 29 17:00 TABLE_2024022917
drwxr-xr-x 2 igloo igloo 4096 Mar 1 17:00 TABLE_2024030117
drwxr-xr-x 2 igloo igloo 4096 Mar 6 17:00 TABLE_2024030617
drwxr-xr-x 2 igloo igloo 4096 Mar 7 17:00 TABLE_2024030717
```

그림 3-34 ▶ 백업 파일을 이용한 DB 재생성 적용 사례

```
-rw-r--r-- 1 igloo igloo 3130 Mar 7 17:00 agent_manager.sql
-rw-r--r-- 1 igloo igloo 2719 Mar 7 17:00 agent_proxy.sql
-rw-r--r-- 1 igloo igloo 2402 Mar 7 17:00 agent_rule.sql
-rw-r--r-- 1 igloo igloo 3181 Mar 7 17:00 agent.sql
-rw-r--r-- 1 igloo igloo 2459 Mar 7 17:00 ai_code.sql
-rw-r--r-- 1 igloo igloo 5632 Mar 7 17:00 ai_mapping_pattern.sql
-rw-r--r-- 1 igloo igloo 13632 Mar 7 17:00 ai_rule.sql
-rw-r--r-- 1 igloo igloo 2121 Mar 7 17:00 alive_check.sql
-rw-r--r-- 1 igloo igloo 3330 Mar 7 17:00 analyzer_action.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240206.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240207.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240208.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240209.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240210.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240211.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240212.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240213.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240214.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240215.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240216.sql
-rw-r--r-- 1 igloo igloo 2280 Mar 7 17:00 analyzer_alert_events_20240217.sql
```

실증 사례

표 3-29 ▶ 실증 사례

내용	
우수 사례	• 시스템 복구 기능으로 이전 상태 복원 가능 - CBS에 장애가 발생하거나 설정 오류가 발생한 경우, 복구 기능을 통해 이전 정상 상태로 자동 복원할 수 있는 기능을 제공하고 있다. 이를 통해 긴급 상황에서도 운영 중단을 최소화하고 안정적인 시스템 가용성을 확보할 수 있다. • 복구 절차가 상세히 문서화 보유 - 시스템 복구 과정(복원 지점 선택, 복구 순서, 복구 후 점검 사항 등) 이 세부 절차가 문서에 작성되어 있어 담당자가 상황 발생 시 즉시 대응할 수 있다.
미흡 사례	• 시스템 복구 기능 부재 - CBS 장애 또는 설정 오류 발생 시 이전 정상 상태로 되돌릴 수 있는 복구 기능이 제공되지 않아, 장애가 발생하는 경우 운영 중단 시간 증가 및 데이터 손실 위험이 존재한다. • 복구 프로세스 미수립 - CBS의 복구 절차가 없으며, 담당자별 역할 · 복구 단계 · 필수 점검 사항 등이 정의되지 않았다.

개선 권고사항

- 백업 데이터 기반 복구 기능 적용
 - 백업된 설정값 및 데이터를 활용하여 시스템을 안정적으로 되돌릴 수 있는 복구 기능을 CBS 내에 구현한다. 복구 기능은 운영 중단을 최소화하도록 설계되어야 한다.
- 백업 데이터 별도 외장 장치 제공
 - 원본 시스템과 물리적으로 분리된 외장 저장장치를 사용해 백업 데이터를 별도로 보관하여, 장애·손상·31)랜섬웨어 감염 시에도 안전하게 복구할 수 있는 체계를 확보하도록 권고한다.
 - 도입 당시 운영 설정 정보가 변화 없이 운영이 가능하다면, 초기 설정 정보가 저장된 별도 보조장치를 제공하여 복구한다.
- 표준 복구 절차서 작성
 - CBS 장애 발생 시 일관된 방식으로 복구가 가능하도록, 단계별 복구 절차를 명확히 정의한 32)표준 복구 절차서(SOP)를 마련할 것을 권고한다.

31) 랜섬웨어: 파일을 암호화하거나 시스템을 잠가 사용 불가 상태로 만든 뒤 금전을 요구하는 악성 소프트웨어

32) 표준 복구 절차서: 장애·사고 발생 시 시스템을 정상 상태로 복원 단계와 방법을 표준화한 절차서

3.2.28 대체 전원

🔍 점검 목적

CBS는 기존 운영 상태에 영향을 주지 않고 대체 전원 공급으로 전환할 수 있는 능력을 제공해야 한다.

🔍 점검 내용

- UPS 또는 백업 전원 적용 여부 점검
 - CBS 장애를 예방하기 위해 UPS(무정전 전원장치) 또는 백업 전원 장비가 적용되어 있는지를 확인한다. 전원 공급 중단 시에도 시스템이 즉시 꺼지지 않고 안전하게 종료되거나 지속 운영될 수 있는지 점검한다.
- 전원 공급 중단 시 복구 절차 문서화 여부 점검
 - 예기치 않은 전원 차단 상황을 대비하여, 전원 복구 후 시스템을 정상 상태로 되돌리는 복구 절차가 수립되어 있는지 점검한다. 복구 과정, 담당자, 단계별 조치 등이 정의되어 있는지 확인한다.

그림 3-35 ▶ UPS 장치 적용 사례



그림 3-36 ▶ 하드웨어 이중 전원 구성 적용 사례



실증 사례

표 3-30 ▶ 실증 사례

내용	
우수 사례	• UPS 설치 또는 전원 이중화 적용 - UPS(무정전 전원장치)가 추가 설치되어 있으며, 장비에는 전원 이중화 구성이 적용되어 있다. 이를 통해 전원 공급이 순간적으로 중단되더라도 장비가 즉시 종료되지 않고 안정적으로 유지되어 데이터 손상 및 장비 오작동 가능성을 최소화한다. • 전원 중단 시 복구 절차 문서화 - 전원 장애 발생 후 시스템을 정상 상태로 복구하기 위한 절차가 상세히 작성되어 있다. 복구 단계, 담당자 역할, 점검 항목 등이 명확히 정의되어 있어, 실제 장애 발생 시 신속하고 체계적인 대응이 가능하다.
미흡 사례	• 장비 하드웨어 구성이 단일 전원만 사용 - CBS 하드웨어 구성이 단일 전원 소스에만 의존하고 있어, 전원 장애 발생 시 서비스 중단 위험성이 높은 상태이다. UPS나 이중화 전원이 적용되지 않아 전원 안정성 측면에서 취약하다. • 전원 공급 중단 후 복구 절차 미수립 - CBS를 어떻게 복구해야 하는지에 대한 표준 절차가 작성되어 있지 않아 장애 발생 시 체계화된 복구 절차를 수행하기 어려워 복구 지연, 설정 손실, 운영 중단 등의 추가적인 위험이 발생할 수 있다.

개선 권고사항

- 제어·운항 기관 등 선박 핵심 장비 UPS 도입 검토
 - 선박 운항 및 제어 기능에 직접 영향을 주는 핵심 장비(CBS, 제어 시스템, 항해 장비 등)에 대해 UPS(무정전 전원장치) 도입을 검토하여 전원 장애 시에도 안정적인 운영이 가능하도록 전원 보호 대책을 강화할 것을 권고한다.
- 전원 전환 실패 대비 전원 이중화 구성
 - 전원 장애나 예기치 못한 전원 전환 실패 상황을 대비하여 전원 이중화 구성을 적용하도록 권장한다. 이를 통해 단일 전원 고장으로 인한 서비스 중단 위험을 최소화할 수 있다.
- 전원 공급 중단 후 복구 시 체크리스트 운영
 - 전원 공급 중단 후 CBS 및 관련 시스템을 재가동하는 과정에서 누락이 발생하지 않도록, 복구 체크리스트를 운영하여 절차적 안정성을 확보할 것을 권장한다.

3.2.29 네트워크 및 보안 구성 설정

🔍 점검 목적

CBS는 제조사가 제공한 지침에 따라 권장되는 네트워크 및 보안 구성을 설정할 수 있는 기능을 제공해야 한다. 또한, CBS는 현재 배치된 네트워크 및 보안 구성 설정에 대한 인터페이스를 제공해야 한다.

🔍 점검 내용

- 사용자 관리 기능의 보안 설정 제공 여부 점검
 - CBS의 사용자 관리 기능에서 사용자 정보 관리, 세션 유효시간 설정, 로그인 만료일 설정 등 보안 관련 옵션이 제공되는지 점검한다.
- 역할(Role) 기반 권한 부여 기능 설계 여부 점검
 - 관리자가 사용자에게 역할별 권한(Admin / Operator / Viewer 등)을 부여할 수 있는 구조로 설계되어 있는지 점검한다.
- 패스워드 정책 설정 기능 제공 여부 점검
 - CBS가 패스워드 생성 규칙(최소 길이, 복잡도, 문자 조합 등)과 패스워드 초기화 절차, 변경 주기, 생애주기 관리 기능을 제공하는지 확인한다.
- 제품의 안전 상태 모니터링 기능 제공 여부 점검
 - CBS와 연동되는 하위 단말(Agent 포함)의 동작 상태, 보안 상태, 연결 상태를 실시간으로 모니터링 가능할 수 있는 기능이 구현되어 있는지 점검한다.

그림 3-37 ▶ 제품의 안전 상태 모니터링 기능 적용 사례

The screenshot displays the SpiderOT web interface. On the left, there is a sidebar with a tree view showing a hierarchy of devices: DOMAIN, GROUP, uncategorized, StudyGROUP, and FW. The main area contains a table titled '로그소스 현황' (Log Source Status) with columns for No, 그룹 (Group), 로그소스명 (Log Source Name), 로그소스 IP, 로그수집방식 (Log Collection Method), 링 제크 (Link Check), 수집 상태 (Collection Status), 에이전트 버전 (Agent Version), 에이전트 OS (Agent OS), 시스템 정보 (System Information), and 에이전트 상태 (Agent Status). The table lists 11 entries, mostly grouped under 'GROUP' and 'FW'. The status of the agents is indicated in the '에이전트 상태' column, with values like '정상' (Normal) and '단말' (Terminal).

No	그룹	로그소스명	로그소스 IP	로그수집방식	링 제크	수집 상태	에이전트 버전	에이전트 OS	시스템 정보	에이전트 상태
1	GROUP	[50.48] FW_pSense	192.168.50.48	AGENTLESS	정상	대상 외	-	-	-	-
2	uncategorized	ExdCollector 192.168...	192.168.50.68	EXDCOLLECT...	정상	대상 외	1.0.13	DESC=Linux HOST_NAME=ret PROCESS_NAME=CA...	CPU_MODEL=Xeon CPU_CORES=48 CPU_MHZ=33...	정상
3	GROUP	Ship_EDR	192.168.50.68	AGENTLESS	정상	대상 외	-	-	-	-
4	GROUP	Ping Check	2.2.2.2	AGENTLESS	대상 외	대상 외	-	-	-	-
5	uncategorized	TEST Server	3.3.3.3	EXDCOLLECT...	대상 외	대상 외	-	-	-	단말
6	GROUP	PCk2	192.168.70.200	AGENTLESS	대상 외	대상 외	-	-	-	-
7	GROUP	[50.48] LogMaker	192.168.50.49	AGENTLESS	정상	대상 외	-	-	-	-
8	GROUP	PCk3	192.168.70.130	AGENTLESS	대상 외	대상 외	-	-	-	-
9	GROUP	TEST_NW	192.168.1.100	AGENTLESS	대상 외	대상 외	-	-	-	-
10	FW	UPFW_TEST	192.168.1.101	AGENTLESS	대상 외	대상 외	-	-	-	-
11	GROUP	[통합테스트] PCk2	192.168.50.69	AGENTLESS	정상	대상 외	-	-	-	-

실증 사례

표 3-31 ▶ 실증 사례

내용	
우수 사례	• 사용자 계정 세션 유효시간 및 로그인 만료 설정 기능 제공 - CBS에서 사용자 계정별로 세션 유효시간을 설정하고, 일정 기간 사용하지 않은 계정에 대해 로그인 만료를 적용할 수 있는 기능을 제공하고 있다. 이를 통해 장시간 방치된 세션이나 미사용 계정으로 인한 보안 위험을 효과적으로 줄일 수 있다. • 패스워드 사용 기간에 대한 의무화 적용 - 사용자 계정의 패스워드 사용 기간이 시스템 정책에 따라 자동으로 관리되며, 일정 기간 경과 시 반드시 패스워드를 변경하도록 강제하고 있다. 이를 통해 장기간 동일 패스워드 사용으로 인한 계정 탈취 위험을 최소화하였다. • 연결된 센서·단말 등 장비 상태 모니터링 기능 제공 - CBS와 연동된 하위 단말, 센서, Agent 장비의 상태를 실시간으로 확인할 수 있는 모니터링 기능을 제공한다. 이를 통해 각 장비의 동작 상태, 연결 상태, 이상 여부 등을 중앙에서 확인하여 운항 안전성과 장애 대응 효율성을 높이고 있다.
미흡 사례	• 사용자 계정 권한 부여 불가 - 관리자가 사용자별 역할(Role) 기반으로 권한을 할당하거나 제한할 수 있는 기능이 제공되지 않아, 최소 권한 원칙 적용이 불가능하며 운영상·보안상 위험이 증가한다. • 패스워드 생명주기(Lifecycle) 관리 기능 없음 - 패스워드 사용 기간 설정, 만료 정책, 주기적 변경 등의 기능이 없어 취약한 패스워드 관리를 유발할 가능성이 높다. 기본 패스워드 장기 사용으로 인한 보안사고 위험이 존재한다.

개선 권고사항

- 사용자 계정 보안 설정 강화 기능 확대 적용
 - 사용자 계정에 대해 세션 유효시간, 로그인 만료, 비인가 접속 차단 등 고급 보안 옵션을 추가로 제공하도록 기능을 확장한다.
- 패스워드 생명주기(Lifecycle) 고급 정책 도입
 - 패스워드 재사용 금지, 유효기간 경과 전 변경 알림, 패스워드 강도 실시간 검사 기능 등 고도화된 패스워드 정책을 도입한다. 이를 통해 장기 사용 또는 단순 패스워드 사용으로 발생할 수 있는 계정 탈취 위험을 최소화할 수 있다.
- 연결 장비 · 센서에 대한 통합 모니터링 기능 구축
 - CBS와 연결된 하위 단말, 센서, Agent 등 주요 장비의 동작 상태, 통신 상태, 이벤트 발생 여부 등을 중앙에서 실시간 확인할 수 있는 통합 상태 모니터링 기능을 도입한다. 이상 동작 발생 시 자동 알림 기능을 포함하여 전체 시스템의 운영 안정성과 가시성 향상하는 것을 권고한다.

3.2.30 최소화 기능

◉ 점검 목적

다음의 설치, 가용성 및 접근 권한은 CBS에서 제공하는 기능의 엄격한 필요성에 따라 제한되어야 한다.

- 운영체제 소프트웨어 구성 요소, 프로세스 및 서비스
- 네트워크 서비스, 포트, 프로토콜, 경로 및 호스트 접근 및 소프트웨어

◉ 점검 내용

- 최소한의 기능 및 서비스로 구성하고, 불필요한 기능은 제한하는지 여부 점검
 - S/W 애플리케이션을 닫고, 운영체제 화면에 직접 접근을 제한하는 기능을 제공해야 한다.
 - 허가된 사용자 계정에만 접근이 가능하도록 제한하는 기능을 제공해야 한다.
 - 운영체제에서 기본으로 제공되는 기능과 서비스 중 불필요한 서비스는 비활성화해야 한다.

그림 3-38 ▶ 윈도우 서비스 제한 설정 적용 사례

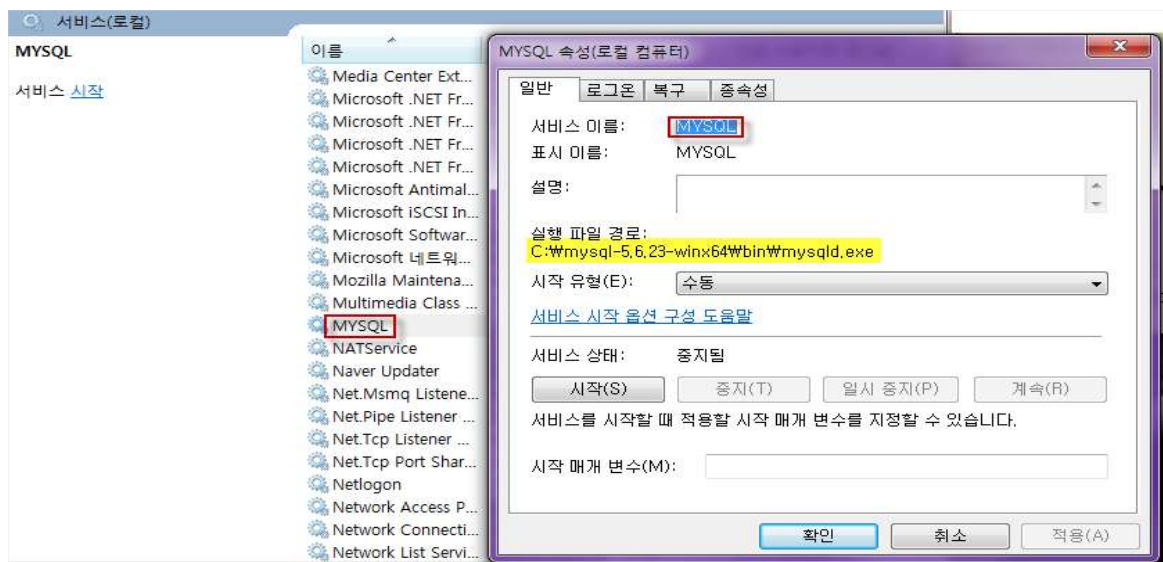
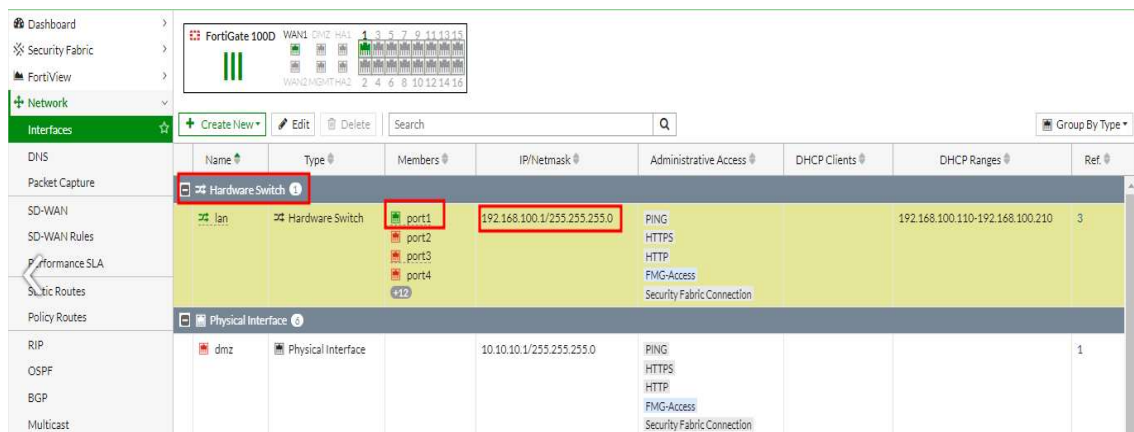


그림 3-39 ▶ 방화벽 장비의 불필요 서비스 제한 정책 적용 사례



실증 사례

표 3-32 ▶ 실증 사례

내용	
우수 사례	• 운영체제 직접 접근 차단 기능 적용 - CBS 애플리케이션 종료 시 운영체제 화면으로 접근되지 않도록 OS 접근 차단 기능을 적용했다. 운영체제에 직접 접근할 수 없어 사용자 조작 실수 및 설정 변경 위험이 원천적으로 차단된다. • 운영체제에서 기본 제공되는 불필요한 서비스 제한 - 운영체제에서 기본 제공되는 불필요한 서비스(파일 공유, 원격 접근 옵션 등)를 모두 비활성화하여 공격 표면을 최소화 적용하였다.
미흡 사례	• 애플리케이션 종료 후 운영체제 조작 가능 - CBS 애플리케이션을 종료하면 별도의 제한 없이 Windows 바탕화면으로 진입할 수 있어, 운영체제 설정 변경·파일 접근 등 비인가 조작 위험이 잔존 하는 것으로 확인되었다. 이는 애플리케이션 계층에서만 통제가 이루어지고 운영체제 수준의 접근 제한이 부재한 상태를 의미한다. • 운영체제에 대한 사용자 접근 차단 기능 미적용 - CBS 로그인 또는 계정 인증 절차가 운영체제 수준에서 적용되지 않아, 사용자라면 누구나 OS에 접근 가능 구조로 운영되고 있다. 이는 비인가 사용자에게 의한 설정 변경, 파일 열람, 시스템 손상 등 사고 발생 가능성을 높이는 취약점이다. • 운영체제 기본 서비스 다수 활성화 상태 유지 - Windows 운영체제에서 기본으로 제공되는 다양한 서비스가 불필요함에도 대부분 활성화되어 있는 것으로 확인되었다. 사용하지 않는 서비스가 활성화된 상태는 공격 표면을 확대하며, 악성코드나 외부 침입자가 취약한 서비스나 포트를 악용할 가능성을 높인다.

개선 권고사항

- 운영체제 접근 제한 기능 적용
 - CBS 애플리케이션 종료 후 운영체제로 직접 진입하지 못하도록 OS 접근 제한 기능⁽³³⁾GPO, ⁽³⁴⁾Kiosk Mode 등) 을 적용한다.
- 계정 기반 접근 통제 강화
 - 허가된 사용자 계정에만 운영체제 접근을 허용하고, 비인가 사용자는 로그인 단계에서 즉시 차단되도록 설정한다.
- 불필요 서비스 비활성화
 - 운영체제에서 사용하지 않는 기본 기능 및 서비스는 모두 비활성화하여 공격 표면을 축소한다.
- 운영체제 보안정책 및 최소 권한 원칙 적용
 - 필요시 GPO, Kiosk Mode, 최소 권한 실행 원칙 등을 적용하여 운영체제 접근 및 조작 가능 범위를

33) GPO(Group Policy Object): Windows 도메인 환경에서 사용자·컴퓨터 설정을 중앙에서 일괄적으로 관리·통제하기 위한 정책 구성 객체

34) Kiosk Mode: 사용자가 지정된 앱이나 기능만 이용하도록 장치를 제한해, 임의 조작이나 설정 변경을 막는 잠금 운영 모드

최소화한다.

1

2

3

4

5

6

3.2.31 인간 사용자에게 대한 다중요소 인증

🔍 점검 목적

비신뢰 네트워크를 통해 CBS에 접근하는 경우, 사용자 계정에 다중 요소 인증을 적용해야 한다.

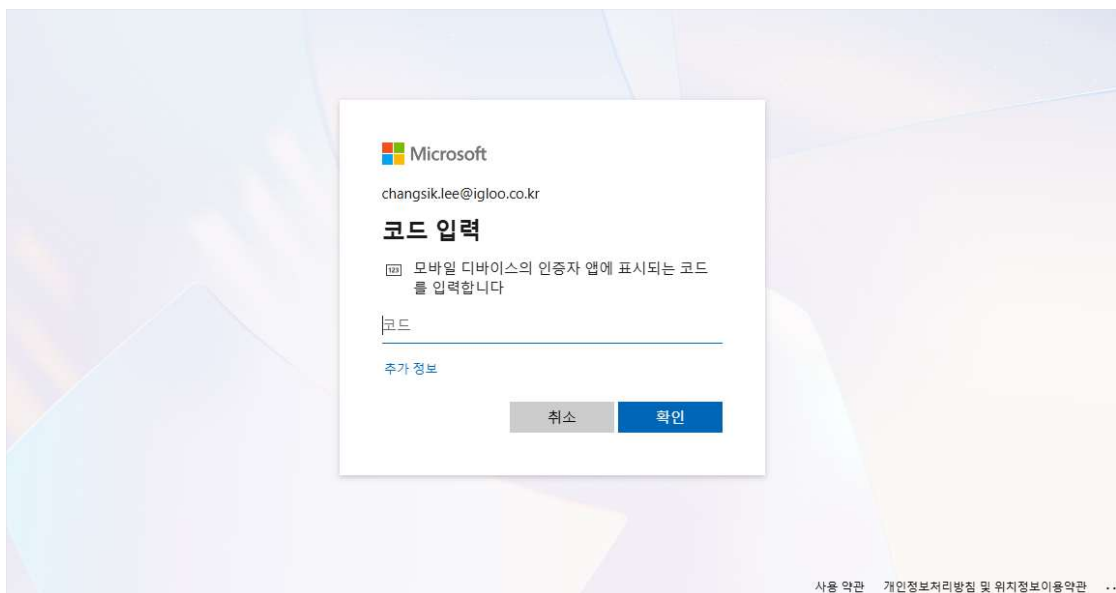
🔍 점검 내용

- 35) OTP·토큰 기반 인증 적용 여부 점검
 - 일회용 비밀번호(OTP), 토큰 기반 인증 장치 등 추가 인증 수단이 실제로 사용되고 있는지 확인하며, 관리 계정 또는 중요 기능 접근 시 필수 적용 여부를 점검한다.
- 관리자 계정 로그인 절차 점검
 - 관리자 계정 로그인 시 일반 사용자와 구분된 강화 절차(추가 인증, 별도 경로 등)가 적용되는지 점검한다.

표 3-33 ▶ 이중 인증 방식

인증 방식	내용
지식 기반 인증	아이디, 비밀번호, PIN 번호 등
소유 기반 인증	핸드폰, 토큰, USB 키, 이메일 등
생체 인증	사용자의 지문, 홍채 등

그림 3-40 ▶ MFA 인증 적용 사례



35) OTP(One-Time Password): 한 번만 사용할 수 있는 일회성 비밀번호를 생성해 인증 보안을 강화하는 방식

실증 사례

표 3-34 ▶ 실증 사례

내용	
우수 사례	- MFA 필수 적용 및 OTP 기반 인증 구성 - 비선외 네트워크 구간 로그인 시 다중 요소 인증(MFA)이 필수로 적용되어, 비밀번호 외에도 OTP · 토큰 기반 추가 인증 절차를 거쳐야만 시스템 접근이 가능하다. 일회성 비밀번호(OTP)를 사용하여 인증 강도를 높였고, OTP 유효시간도 짧게 설정해 보안성을 강화하였다. - 원격 접속 시 추가 인증 수행 - 원격으로 CBS나 시스템에 접속할 경우, 일반 로그인 이후 추가 인증 단계(OTP 또는 인증 앱 승인)가 자동으로 적용된다.
미흡 사례	- 패스워드만으로 관리자 권한 접근 가능 - 비선외 네트워크 접근에서도 관리자 권한 계정이 단일 패스워드 인증만으로 로그인 가능해, 계정 탈취 위험성이 높은 상태이다. - MFA 기능이 제공됨에도 비활성화 상태 - CBS가 MFA 기능을 지원 기능이 설정 비활성화되어 있어 보안 강화 기능이 제대로 활용되지 않고 있다.

개선 권고사항

- MFA 기능 적용이 어려운 경우 보안 시스템(VPN) 도입
 - VPN 접속 시 1차 패스워드 + 2차 OTP 인증 기능을 제공하여, 외부 접근에 대한 보안 수준이 대폭 강화된다.
- OTP 장비 또는 인증 앱 기반 MFA 운영
 - VPN 장비와 연동되는 OTP 토큰 · 모바일 인증 앱을 도입하여 사용자의 신원을 다단계로 검증하도록 구성한다. 이를 통해 패스워드 유출 시에도 인증 우회가 불가능해지며, 관리자 계정 보호에 효과적이다.
- MFA 적용을 통한 원격 접속 보안 강화
 - CBS 및 주요 OT 시스템의 원격 유지보수 · 원격 접속 시 반드시 VPN 기반 MFA 인증 절차를 거치도록 적용하여, 비인가 사용자의 접근을 사전에 차단한다.

3.2.32 소프트웨어 프로세스와 기기의 식별 및 인증

🔍 점검 목적

CBS는 소프트웨어 프로세스와 장치를 식별하고 인증해야 한다.

🔍 점검 내용

- 기기 간 상호 인증(Mutual Authentication) 적용 여부 점검
 - CBS 장비와 연결된 하위 단말 · 센서 · 필드 등이 상호 인증 절차를 통해 신뢰 된 기기만 통신하도록 구성되어 있는지 확인한다.
- 허가되지 않은 장비 연결 감지 기능 여부 점검
 - 네트워크에 연결되는 장비가 허가된 목록(Allow list)에 포함되어 있는지 자동 감지하고, 등록되지 않은 장비 연결 시 경고 · 차단 기능이 제공되는지 확인한다.

그림 3-41 ▶ 식별된 프로세스와 장치를 식별 기능 적용 사례



실증 사례

표 3-35 ▶ 실증 사례

내용	
우수 사례	• 기기 간 통신 시 인증 토큰(Token) 기반 상호 인증 적용 - CBS 장비와 연결된 센서·컨트롤러·필드 간 통신에서 인증 토큰 기반 상호 인증이 적용되어, 등록된 기기만 통신할 수 있도록 통제한다. 이를 통해 위장 기기 연결을 방지하며, OT 장비 연결 전반의 안전성을 강화한다. • 비인가 장비 연결 시 실시간 알람 발생 - 네트워크에 새로운 장비가 연결될 경우, 허가된 장비 목록(Allow list)과 자동 비교하여 등록되지 않은 장비는 즉시 알람을 발생시키도록 구성되어 있다. 이를 통해 비인가 단말 접속을 초기에 탐지하는 선제 대응이 가능하다.
미흡 사례	• 무서명 프로세스 실행 허용 - 서명되지 않은 프로세스도 실행 상태로, 악성 파일이나 변조된 코드를 식별하지 못하는 보안 취약점이 존재한다. • 외부 장비 연결 시 식별 기능 부재 - 네트워크에 신규 장비가 연결되더라도 해당 장비의 등록 여부를 확인할 수 없어 비인가 장비 연결 위험성이 높다. • 장비 간 상호 인증 기능 미적용 - CBS 장비와 하위 단말 간의 통신에서 기기 인증 절차가 없어, 중간자 공격 또는 위장 장비 접근 가능성이 존재한다.

개선 권고사항

- 장비 간 인증 프로토콜 적용
 - CBS 장비와 센서·필드 장비 간 통신 시 상호 인증(Mutual Authentication) 또는 인증 토큰 기반 프로토콜을 적용하여, 신뢰 장비 간에만 데이터 교환이 이루어지도록 보안 수준을 강화한다.
- 비인가 장비 탐지 기능 활성화
 - 네트워크에 연결되는 장비가 허가된 목록(Allow list)에 포함되는지 자동 확인하고, 등록되지 않은 장비 연결 시 즉시 차단 또는 알람 제공 기능을 활성화하도록 개선한다.
- 프로세스 서명 필수화
 - CBS 내 실행되는 모든 프로세스는 정식 서명(Signed Executable) 기반으로만 동작하도록 설정하여, 무서명·변조 파일 실행을 원천적으로 차단하도록 개선한다.

3.2.33 실패한 로그인 시도

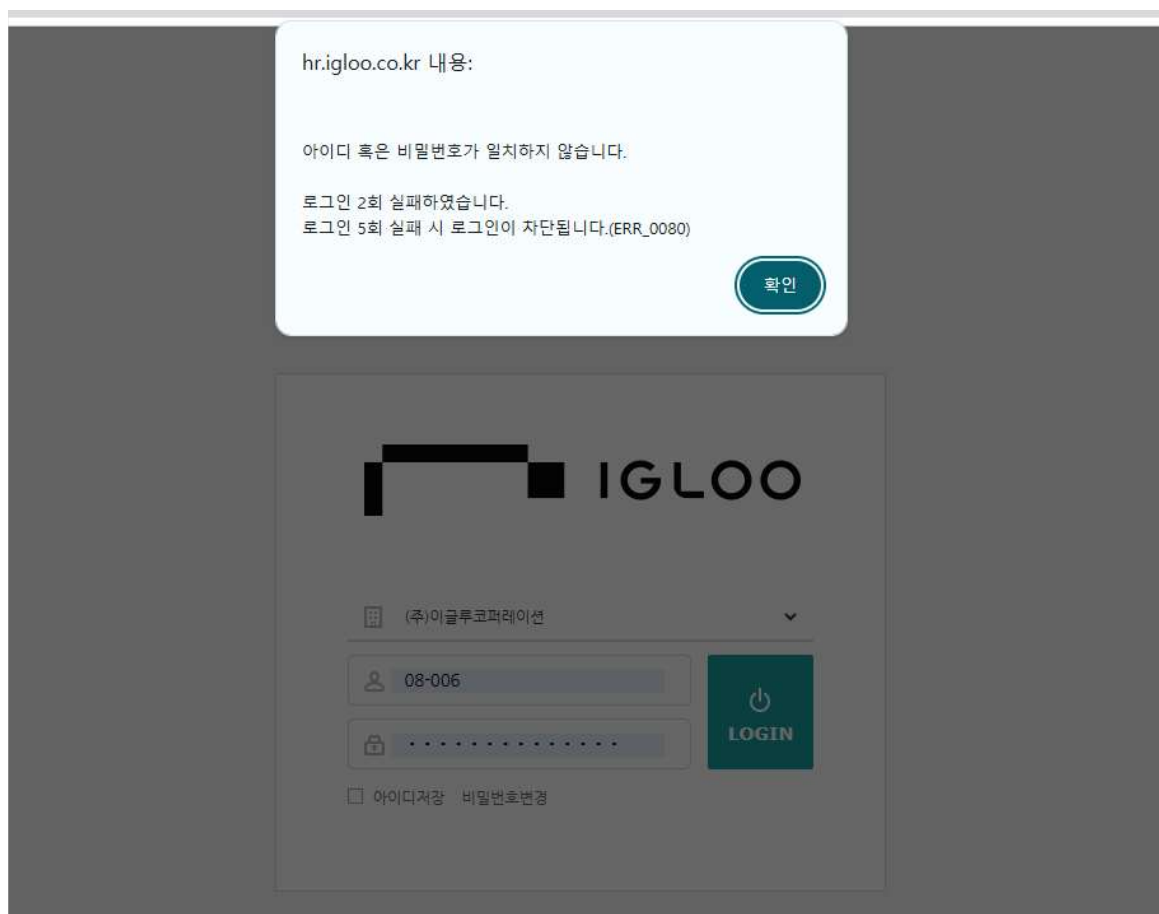
🔍 점검 목적

CBS는 지정된 시간 동안 비신뢰 네트워크로부터 연속적으로 발생하는 무효한 로그인 시도를 제한해야 한다.

🔍 점검 내용

- 일정 횟수 초과 시 계정 잠금 여부 점검
 - 로그인 실패가 설정된 허용 횟수를 초과할 경우, 계정을 자동으로 잠그는 보호 기능이 적용되어 있는지 확인한다.
- 관리자에게 알림 전송 여부 점검
 - 반복된 로그인 실패나 계정 잠금 발생 시, 관리자 또는 보안 담당자에게 자동 알림(이메일 · 팝업 · 시스템 경고 등)이 전달되도록 설정되어 있는지 점검한다.

그림 3-42 ▶ 실패한 로그인 시도 제한 기능 적용 사례



실증 사례

표 3-36 ▶ 실증 사례

내용	
우수 사례	• 5회 이상 로그인 실패 시 계정 자동 잠금 - 로그인 실패 횟수가 5회를 초과하면 계정이 자동으로 잠기도록 설정되어 있어, 패스워드 추측 공격(Brute-force)을 효과적으로 차단한다. • 모든 실패 로그인 시도에 대해 시간 · IP 정보 기록 - 실패한 로그인 시도의 발생 시각, 시도한 IP 주소 등이 모두 감사 로그에 기록되어, 비정상 접근에 대한 빠른 추적과 분석이 가능하다. • 비정상 로그인 시 관리자 알림 기능 활성화 - 다수의 연속된 실패 시도 또는 의심스러운 접근이 발생하는 경우 관리자에게 즉시 알림이 전송되어 실시간 대응이 가능한 구조다.
미흡 사례	• 로그인 실패 기록 없음 - 로그인 실패 시도에 대한 기록이 남지 않아 비정상 로그인 탐지 및 사후 분석 불가능한 상태로 확인되었다. • 계정 잠금 설정 미적용 - 반복적인 로그인 실패에도 계정이 잠기지 않아, 무차별 대입 공격(Brute-force Attack)에 취약한 구조로 운영되고 있다. • 반복 로그인 시도 감지 기능 없음 - 동일 IP 또는 동일 계정에 대한 반복 실패 시도를 감지하거나 관리자에게 알림을 제공하는 기능이 없어, 공격 징후를 실시간으로 파악할 수 없는 상태이다.

개선 권고사항

- 계정 잠금 정책 적용(예: 5회 실패 시 일정 시간 잠금)
 - 비정상적인 로그인 실패가 일정 횟수를 초과할 경우, 계정을 자동으로 잠그는 정책을 적용해 무차별 대입 공격(Brute-force)을 예방한다.
- 관리자 알림 자동화 기능 활성화
 - 반복된 실패 시도, 의심스러운 로그인 활동 등 이상 행동 발생 시 관리자에게 자동으로 알림이 전달되도록 설정해 신속한 대응이 가능하다.
- 실패 시도 누적 관리 기능 강화
 - 로그인 실패 이력을 시스템이 자동으로 누적 관리하도록 하여 반복적인 인증 시도를 식별할 수 있도록 한다.

3.2.34 시스템 사용 알림

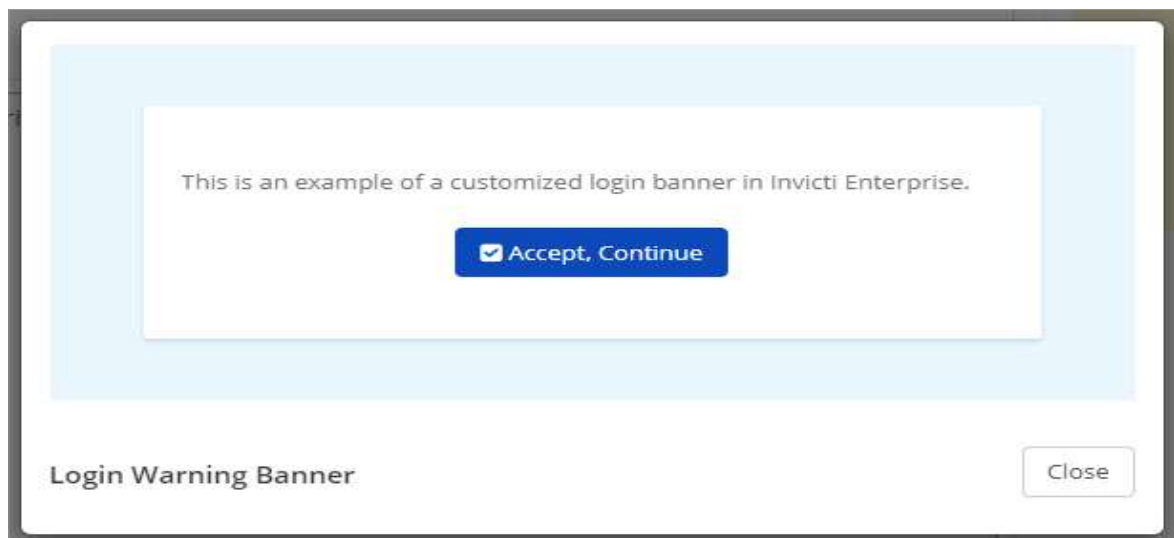
🔍 점검 목적

CBS는 인증 전에 사용 알림 메시지를 표시하는 기능을 제공해야 한다. 또한, 시스템 사용 알림 메시지는 허가된 선원에 의해 설정될 수 있어야 한다.

🔍 점검 내용

- 로그인 배너 기능 존재 여부
 - CBS 접속 시 사용자에게 보안정책과 주의 사항을 안내하기 위한 로그인 배너가 표시되는지 확인한다. 배너는 사용자가 직접 수정 및 설정 기능을 제공해야 한다.
- 경고문 내용의 법적 요구 준수 여부
 - 배너에 “비인가 사용자는 접근이 금지되며, 모든 활동이 저장됩니다.”와 같은 비인가 접근 금지 문구가 포함되어 있는지 점검한다. 이는 불법 접근 시 책임을 명확히 하기 위한 필수 요소이다.
- 시스템 경고 등) 이 전달되도록 설정되어 있는지 점검한다.

그림 3-43 ▶ CBS 접근 배너 문구 적용 사례



🔍 실증 사례

표 3-37 ▶ 실증 사례

내용	
우수 사례	• 정보보안 정책 및 모니터링 사실 고지 - “본 시스템은 승인된 사용자만 로그인 가능합니다.” 접근을 금지하는 문구가 명확히 표기되어 있으며, 사용자에게 보안 책임과 접근 제한을 명확히 안내하고 있다. • 관리자 기능에 배너 수정 가능한 별도의 기능 제공 - 관리자가 쉽게 배너 수정 및 활성화 가능하도록 별도의 기능을 개발 후 적용했다.

미흡 사례	• 별도 기능 제공이 아닌 소스코드에 하드 코딩된 문구 - 안내 문구가 별도 기능이 아닌 소스코드에 하드 코딩되는 경우 일반 사용자는 문구 수정이 사실상 불가능하다. • 경고 문구가 부정확하거나 미흡 - 제공되는 문구가 모호하거나 구체적이지 않아, 사용자에게 접근 통제 목적과 법적 책임을 명확히 안내하지 못하고 있으며, 보안 경고 기능으로서 역할이 미흡한 것으로 평가된다.
--------------	--

개선 권고사항

- 다국어 문구 옵션 제공
 - 비인가자 국적 다양성을 고려하여 한국어·영어 등 다국어 지원 배너를 제공해 이해도를 높인다.
- 사용 조건 및 모니터링 사실 포함
 - 시스템 사용 시 적용되는 보안정책, 모니터링 사실, 법적 고지 내용을 로그인 배너에 포함해 사용자 인지도를 높인다.

3.2.35 비신뢰 네트워크를 통한 접근

🔍 점검 목적

CBS는 비신뢰 네트워크를 통한 모든 접근을 감시하고 통제해야 한다.

🔍 점검 내용

- 원격 접속 시 암호화 적용 여부 점검
 - 원격으로 CBS 또는 관련 시스템에 접속할 때, 통신 구간이 암호화되어 있는지 확인한다.
- VPN 또는 전용 인증 방식 사용 여부 점검
 - 원격 접속 시 안전한 접속을 위해 VPN, 전용 인증 서버, 보안 터널링 등이 적용되어 있는지를 점검한다.
- 비인가 IP 차단 및 접속 허용 IP 관리 정책 여부 점검
 - 승인되지 않은 IP 주소의 접속을 자동으로 차단하는 기능(IP Allow list/Block list)이 설정되어 있는지 확인한다.

그림 3-44 ▶ 비신뢰 네트워크 접속 통제 장비 적용 사례



🔍 실증 사례

표 3-38 ▶ 실증 사례

내용	
우수 사례	• 원격 접근 시 반드시 VPN 사용 - CBS 및 관련 장비에 원격으로 접속할 경우, VPN을 통해서만 접근이 가능하도록 구성해 암호화되지 않은 연결을 원천 차단하였다. • TLS 기반 암호화 통신 적용 - 원격 접속 구간 전체에 TLS 기반의 암호화 프로토콜을 적용하여, 전송 중 데이터 탈취 · 변조 위험을 최소화하였다. • 화이트리스트 기반 IP 제한 적용 - 지정된 신뢰 IP 주소만 원격 접속을 허용하는 화이트리스트 정책, 비인가 IP의 접근 시도는 자동으로 차단되도록 구성하였다.

미흡 사례	• 접근제어 없이 모든 IP 허용 - 원격 접속을 위한 IP 제한 정책이 없어, 비인가 IP에서도 시스템 접근 시도가 가능해 보안 통제가 미흡하다. • 비신뢰 네트워크 통신 암호화 미적용 - VPN, TLS 등 보안 프로토콜이 적용되지 않아, 원격 접속 과정에서 데이터 탈취 · 변조 위험이 증가한다.
--------------	---

❶ 개선 권고사항

- 비인가 국가 · IP 차단 정책 적용
 - 화이트리스트 기반 접근제어 또는 국가 · IP 차단 정책을 적용하여 불필요한 외부 접근을 차단한다.
- 외부 접근 로그 별도 보관
 - 외부망에서의 모든 접속 이벤트는 별도 저장 · 보관하여 이상 행위 모니터링 및 사후 분석에 활용할 수 있도록 관리한다.
- VPN 의무화 적용
 - 모든 원격 접속은 반드시 VPN을 통해 이루어지도록 설정하고, 강력한 암호화 프로토콜을 사용하도록 개선한다.

3.2.36 명시적 접근 요청 승인

🔍 점검 목적

CBS는 선내 허가된 선원이 명시적으로 승인한 경우를 제외하고, 비신뢰 네트워크를 통한 접근을 거부해야 한다.

🔍 점검 내용

- 접근 요청 승인 절차 존재 여부 점검
 - 시스템 또는 CBS 기능 사용을 위해 사용자가 접근 요청을 신청할 때, 이를 관리자가 승인하는 절차가 존재하는지 확인한다.
- 관리자 승인 기록 보존 여부 점검
 - 승인된 요청에 대해 승인자, 승인 일시, 요청 내용 등이 기록으로 남는지, 그리고 해당 기록이 감사 목적에 활용 가능 형태로 유지되는지 점검한다.

그림 3-45 ▶ 명시적 접근 승인 기능 적용 사례(출처:오비스 사이트)



🔍 실증 사례

표 3-39 ▶ 실증 사례

내용	
우수 사례	• 신규 접근 요청은 관리자 승인 필수 - 새로운 사용자 또는 외부 엔지니어가 CBS에 접근하기 위해서는 반드시 관리자의 사전 승인이 필요하도록 운영된다. • 승인 기록 문서화 보관 - 모든 승인 요청 · 승인 내용 문서 및 시스템 로그로 남아 추후 활용 가능하다.

미흡 사례	• 승인 없이 계정 자동 생성 - 신규 접근 요청 또는 사용자 계정이 관리자의 승인 없이 자동으로 생성되어, 계정 발급에 대한 통제가 이뤄지지 않고 있다. • 승인된 기록의 누락 - 계정 생성 · 권한 부여 · 접근 승인 등 주요 보안 활동에 대한 승인 기록이 보관되지 않아, 사후 감사, 책임 추적이 불가능한 상태이다.
--------------	--

○ 개선 권고사항

- 승인 기록 장기 보관
 - 승인 내용, 변경 이력, 승인자 정보 등 모든 접근 승인 기록을 장기간 보관할 수 있는 체계를 구축하여 추적성과 감사 대응력을 강화한다.
- 원격 접근에 대한 신청 요청 시 관리자 2인 승인 적용
 - 관리자 권한 또는 고위험 원격 작업 요청 시 단일 승인으로 처리되지 않도록 2인 승인(dual-approval) 절차를 도입해 오남용 및 내부 위협을 예방한다.
- 접근 요청 업무 절차 문서화
 - 모든 신규 접근 요청이 표준화된 승인 절차에 따라 처리되도록 요청 · 검토 · 승인 · 기록의 업무 절차를 명확히 문서화한다.

3.2.37 원격 세션 종료

🔍 점검 목적

CBS는 설정된 미사용 시간이 지난 후 자동으로, 또는 세션을 시작한 사용자가 수동으로 원격 세션을 종료할 수 있는 기능을 제공해야 한다.

🔍 점검 내용

- 원격 세션 타임아웃 설정 여부 점검
 - 일정 시간 미사용 시 원격 세션이 자동으로 종료되도록 설정되어 있는지 확인한다.
- 세션 강제 종료 기능 적용 여부 점검
 - 사용자가 로그아웃하지 않더라도 시스템이 세션을 강제로 종료할 수 있는지 점검한다.
- 세션 강제 종료 시 자동 차단 여부
 - 비정상 종료 · 세션 끊김 등 발생 시 계정 · 세션이 자동으로 차단되는 보호 기능이 적용되어 있는지 확인한다.

그림 3-46 ▶ 명시적 접근 승인 기능 적용 사례(출처:네이버 사이트)

로그인 목록		등록한 기기 목록				
				전체 로그아웃		
타입	운영체제	브라우저/앱	로그인 IP	최근 접속일시	최초 로그인 일시	관리
일반로그인	모바일 (Android)	SamsungBrowse		2025. 11. 09. 07:38	2025. 11. 09. 07:38	로그아웃
일반로그인	모바일 (Android)	Chrome		2025. 10. 29. 17:33	2025. 03. 04. 18:04	로그아웃
일반로그인	모바일 (Android)	Chrome		2025. 10. 19. 17:28	2025. 05. 22. 18:50	로그아웃
일반로그인	모바일 (Android)	Chrome		2025. 10. 04. 12:33	2025. 10. 04. 12:33	로그아웃

🔍 실증 사례

표 3-40 ▶ 실증 사례

내용	
우수 사례	• 비정상 종료(네트워크 단절·장비 강제 종료 등) 발생 시 즉시 세션 강제 정리 - 접속이 비정상적으로 끊어진 경우에도 세션이 자동 차단되어 불법 재접속 위험을 최소화 되도록 운영한다.

	• 10분 미사용 시 원격 세션 자동 종료 - 세션 비활성 상태가 10분 지속되면 자동으로 로그아웃되어 불필요한 연결이 유지되지 않도록 한다.
미흡 사례	• 세션이 무기한 유지 - 원격 접속 세션 유지 시간이 설정되어 있지 않아, 사용자가 장시간 부재 시 세션이 자동 종료되지 않고 그대로 남아 있어 보안 위험이 존재한다. • 장기 미사용 세션 방치 - 미사용 상태의 세션에 대한 정리 기능이 없어, 여러 개의 유휴 세션이 지속적으로 활성화되며 불필요한 접근 가능성을 제공한다. • 비정상 종료 시 재인증 없이 재접속 가능 - 비정상 세션 종료 상황에서도 자동 차단 · 로그아웃이 적용되지 않아, 동일 세션 정보를 이용해 재인증 없이 다시 연결될 수 있는 문제점이 존재한다.

개선 권고사항

- 세션 만료 시간 설정
 - 모든 원격 세션에 대해 일정 시간(예: 5~10분) 미사용 시 자동 만료되도록 세션 타임아웃 정책을 적용하여 장기 미사용 세션 방치를 방지한다.
- 세션 종료 이벤트 기록
 - 정상 종료, 강제 종료, 비정상 종료 등 모든 세션 종료 상황을 감사 로그에 기록해 관리자 추적 · 모니터링이 가능하도록 개선한다.
- 비정상 종료 복구 방식 개선
 - 네트워크 단절, 비정상 종료 등 예외 상황 발생 시 기존 인증 정보를 자동 삭제하고 반드시 재인증을 요구하는 방식으로 변경해 세션 탈취 및 무단 재접속 위험을 차단한다.

3.2.38 암호 무결성 보호

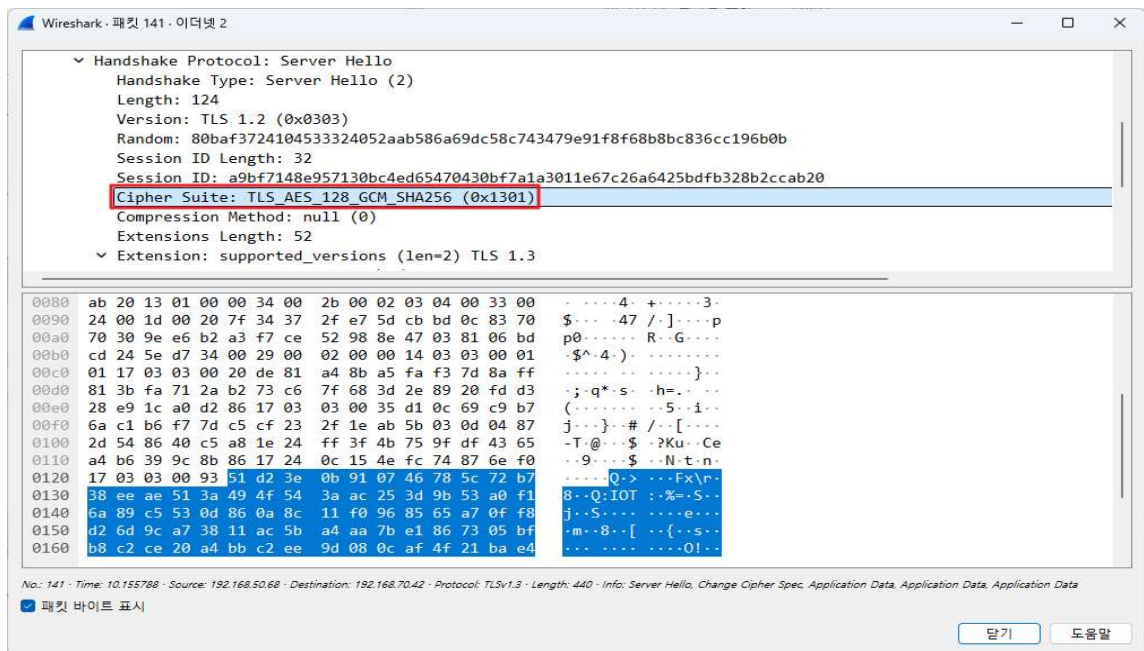
🔍 점검 목적

CBS는 비신뢰 네트워크를 통해 통신하는 동안 정보의 변경을 감지하기 위해 암호 메커니즘을 적용해야 한다.

🔍 점검 내용

- CBS와 비신뢰 네트워크 통신에 암호화 프로토콜(TLS/SSL 등) 적용 여부 점검
 - CBS가 외부 또는 비신뢰 네트워크와 통신할 때, TLS/SSL 등 암호화 프로토콜을 통해 통신 데이터가 보호되고 있는지 확인한다.
- 암호화 통신사용 시 인증서(서명 · 유효기간 · 신뢰성) 검증 여부
 - TLS/SSL 적용 시 서버·클라이언트 인증서의 서명 유효성, 만료 여부, 신뢰할 수 있는 CA 기반인지 확인한다.

그림 3-47 ▶ 암호화 통신 적용 사례



🔍 실증 사례

표 3-41 ▶ 실증 사례

내용	
우수 사례	• TLS/SSL 기반 암호화 적용 - CBS와 외부(비신뢰 네트워크 포함) 통신 구간에 TLS/SSL 암호화 프로토콜이 적용되어 있으며, 통신 중 데이터 유출 · 변조 위험이 효과적으로 통제된다. • 데이터 무결성 보호 기능 적용

	- VPN 통신 과정에서 MAC/³⁶⁾HMAC 기반 무결성 검증이 적용되어 패킷 변조 여부를 모니터링 가능하다.
미흡 사례	• 일부 구간만 암호화 통신 적용 - CBS와 외부망 통신 중 일부 구간이 암호화되지 않아 민감 정보가 공격에 노출될 가능성이 있다. • 취약한 포트 · 프로토콜 사용 지속 - WEB 프로토콜은 암호화 적용하였으나, Telnet, FTP 등 취약 프로토콜 서비스를 별도로 사용하고 있어 중간자 공격 및 정보 탈취 위험성이 높다.

🔗 개선 권고사항

- VPN·보안 게이트웨이 등 전용 보안 장비 설치
 - 암호화 미지원 장비가 존재할 경우, VPN 장비, 전용 보안 게이트웨이, 암호화 터널링 장비 등을 적용해 보안 수준을 보완하도록 권고한다.
- 암호화 프로토콜(TLS 1.2/1.3) 전면 적용
 - CBS와 외부 구간 전체에 TLS 기반 암호화를 필수 적용하며, 평문 통신 포트는 즉시 비활성화할 것을 권고한다.
- 인증서 주기적 검증 및 자동 갱신 체계 도입
 - 인증서 만료 · 오류 발생 시 자동 갱신되도록 관리 체계를 구축하고, 위변조 탐지 기능을 활성화해야 한다.

36) HMAC(Hash-based Message Authentication Code): 해시 함수와 비밀키를 함께 사용해 무결성과 인증을 검증하는 MAC 알고리즘

3.2.39 입력 검증

🔍 점검 목적

CBS는 비신뢰 네트워크를 통해 입력되는 데이터 중 프로세스 제어 입력 또는 동작에 직접 영향을 미치는 입력 데이터의 구문(syntax), 길이 및 내용을 검증해야 한다.

🔍 점검 내용

- 비정상 입력에 대한 예외 처리 여부 점검
 - API 및 WEB 화면의 입력값이 정상 규칙을 벗어나는 경우 시스템이 오류를 안전하게 처리하고, 비정상 입력이 프로그램 오작동이나 서비스 중단으로 이어지지 않도록 예외 처리가 적용되는지 점검한다.
- 파일 업로드 · 파일명 검증 여부
 - 파일 업로드 기능 사용 시 파일 확장자 · 크기 · 파일 타입 등 검증이 수행되는지, 그리고 파일명이 유효성 검증을 통해 악성 스크립트나 비정상 문자열을 포함할 수 없도록 제한하는지 확인한다.

그림 3-48▶ 로그인 입력 기능에서 시스템 조작 및 에러 발생 가능 여부 확인 예시

그림 3-49▶ 입력 기능에서 시스템 조작 및 에러 발생 가능 여부 확인 예시

실증 사례

표 3-42 ▶ 실증 사례

내용	
우수 사례	• 입력값 길이·형식 검증 적용 - UI 및 API 입력에 대해 길이 제한 · 허용 문자 세트·데이터 형식을 검증하여 비정상 입력을 사전에 차단하고 있다. 이를 통해 ³⁷⁾SQL Injection 등 사이버 공격 가능성을 효과적으로 감소시킨다. • 예외 처리 시 안전한 오류 메시지 제공 - 비정상 입력 또는 예외 상황 발생 시 내부 시스템 정보를 노출하지 않는 안전한 오류 메시지를 제공하여 공격자의 시스템 구조 파악을 어렵게 만들고 있다. 이를 통해 오용 · 오류 상황에서도 시스템의 보안성을 유지할 수 있다. • 파일 업로드 시 확장자 화이트리스트 적용 - 업로드되는 파일에 대해 허용된 확장자 목록만 통과하도록 구성되어 있어 실행 파일, 스크립트 파일 등 위험 파일 업로드를 원천적으로 차단하고 있다. 이를 통해 악성 파일 유입 가능성을 최소화하고 시스템 안전성을 강화하였다.
미흡 사례	• 입력 필터링 미적용 및 예외 처리 부재로 내부 오류 노출 - 길이 · 형식 검증이 없어 스크립트, 특수문자, SQL 구문 등 악성 입력이 그대로 처리된다. 또한 비정상 입력 시 시스템 오류 메시지가 그대로 노출되어 공격자에게 내부 구조 정보를 제공한다. • 파일 업로드 시 확장자 제한 없음 - 모든 파일 업로드 허용으로 인해 악성 스크립트 파일, 실행 파일 업로드 위험 존재한다.

개선 권고사항

- 파일 업로드 보안 강화
 - 파일 업로드 서비스에는 EDR 또는 파일 보안 장비 연동 검토한다.
- 입력 필터링 및 유효성 검증 강화
 - UI/API 입력값에 대해 길이 · 형식 검증, 정규식 기반 필터링, 특수문자 차단 등 적용한다.
- 안전한 예외 처리 적용
 - CBS 내부 정보가 노출되지 않도록 표준 오류 메시지 사용, 상세 오류는 내부 로그로만 기록한다.

37) SQL Injection: 입력값을 조작해 데이터베이스에 악의적 SQL 명령을 실행시키는 공격 기법

3.2.40 세션 무결성

🔍 점검 목적

CBS는 세션의 무결성을 보호하는 기능을 제공해야 하며, 무효한 세션 ID는 거부되어야 한다.

🔍 점검 내용

- 로그인 세션 ID 난수 확보 여부 점검
 - 로그인 세션 ID가 충분한 길이와 난수를 가지며, 예측 · 추측 불가능하도록 생성되는지 확인한다.
- 세션 고정(Session Fixation) 방지 여부 점검
 - 로그인 시 새로운 세션 ID로 재발급되는지, 외부에서 주입된 세션을 사용하지 못하도록 보호되는지 확인한다.

그림 3-50 ▶ 안전한 인증 세션 정보 적용 사례

Name	Value	Domain	Path	Expir...	Size	HttpO...	Secure	SameS...	Partiti...	Cross ...	Priority
AUTH_SESSION_ID	d0af0dac-7e9f-4b4a-8099-9bb0de173661.key...	192.168.5...	/aut...	Sess...	77	✓	✓	None			Medium
AUTH_SESSION_ID_LEGACY	d0af0dac-7e9f-4b4a-8099-9bb0de173661.key...	192.168.5...	/aut...	Sess...	84	✓					Medium
JSESSIONID	CFD753D262A91A19DD5535866D971618.key...	192.168.5...	/auth	Sess...	68						Medium
JSESSIONID	330752DAB1DDF6168DA20316A0BC6103	192.168.5...	/	Sess...	42	✓	✓				Medium
KC_REDIRECT	/api/v1/dms/products/search	192.168.5...	/	Sess...	38	✓					Medium
KEYCLOAK_IDENTITY	eyJhbGciOiJIUzI1NiIsInR5cCI6Ikp0eSI6ImVlbiIiwia2lk...	192.168.5...	/aut...	Sess...	587	✓	✓	None			Medium
KEYCLOAK_IDENTITY_LEGACY	eyJhbGciOiJIUzI1NiIsInR5cCI6Ikp0eSI6ImVlbiIiwia2lk...	192.168.5...	/aut...	Sess...	594	✓					Medium
KEYCLOAK_LOCALE	ko	192.168.5...	/aut...	Sess...	17	✓					Medium
KEYCLOAK_SESSION	lgloo/d438b958-7dd0-49d4-b985-0b43e8bb4...	192.168.5...	/aut...	202...	95		✓	None			Medium
KEYCLOAK_SESSION_LEGACY	lgloo/d438b958-7dd0-49d4-b985-0b43e8bb4...	192.168.5...	/aut...	202...	102						Medium

Cookie Value ☒ Show URL-decoded
330752DAB1DDF6168DA20316A0BC6103

🔍 실증 사례

표 3-43 ▶ 실증 사례

내용	
우수 사례	- 로그인 시마다 새로운 세션 ID 자동 생성 적용 - 사용자가 로그인할 때 기존 세션을 폐기하고 새로운 세션 ID를 생성하여 Session Fixation 공격을 원천 차단한다. - 일정 시간 미사용 시 세션 자동 만료 적용 5~10분 등 적절한 비활성 시간 이후 자동 로그아웃 처리하여 장시간 방치 세션 악용을 방지한다.
미흡 사례	- 고정된 세션 ID 사용 - 로그인 전후 동일한 세션 ID가 유지되고 있어 세션 고정(Session Fixation) 공격에 취약하다. 공격자가 사전에 발급받은 세션 ID를 사용해 정상 사용자의 세션을 탈취할 가능성이 존재한다.

- 세션 만료 시간이 과도하게 긴 설정
 - 세션 유지 시간이 과도하게 길어, 장기간 비활성 사용자의 세션이 살아 있는 상태로 유지된다. 이를 통해 무단 재사용, 세션 하이재킹 공격 위험이 발생할 수 있다.

❁ 개선 권고사항

- 세션 ID 난수 알고리즘 적용
 - 세션 생성 시 예측이 불가능한 난수 기반 세션 ID를 생성하도록 난수 알고리즘을 적용한다. 공격자가 세션 ID를 추측하거나 재사용하는 것을 차단하여 ³⁸⁾세션 하이재킹 위험을 최소화한다.
- HTTPS 기반 쿠키 사용 적용
 - 모든 세션 쿠키에 Secure(HTTPS-only) 옵션과 Http Only 옵션을 적용하여, ³⁹⁾네트워크 구간 탈취(MitM)와 ⁴⁰⁾스크립트 기반 공격(XSS)을 통한 쿠키 도용을 방지한다.
- 세션 만료 시간 최적화
 - 장기 유지되는 세션으로 인해 계정 탈취 가능성이 증가하지 않도록 적절한 세션 만료 시간(예: 10~20 분)을 설정한다. 일정 시간 비활성 시 자동 로그아웃이 적용되도록 하여 사용자의 세션 남용 위험을 낮춘다.

38) 세션 하이재킹: 사용자의 세션 ID를 탈취해 해당 사용자로 가장하여 시스템에 무단 접근하는 공격

39) 네트워크 구간 탈취(MitM): 통신 중간에 침입해 데이터를 가로채거나 조작하는 중간자 공격

40) 스크립트 기반 공격(XSS): 웹 페이지에 악성 스크립트를 삽입해 사용자 브라우저에서 임의 코드를 실행시키는 공격

3.2.41 세션 종료 이후의 세션 ID 무효화

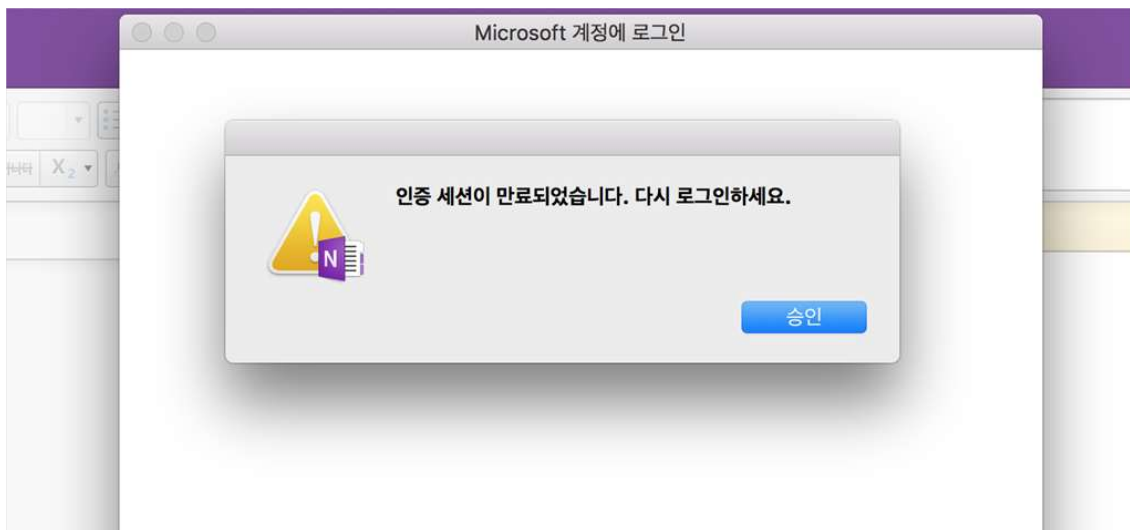
🔍 점검 목적

CBS는 사용자 로그아웃 또는 기타 세션 종료 시(브라우저 세션을 포함) 세션 ID를 무효화 한다.

🔍 점검 내용

- 로그아웃 시 세션 ID 삭제 여부 점검
 - 사용자가 로그아웃을 수행할 때, 클라이언트 측 세션 ID가 즉시 삭제되는지 확인한다.
 - 브라우저 쿠키와 저장된 인증 토큰이 세션 종료와 함께 완전히 제거되는지 점검한다.
- 서버 측에서 세션 강제 무효화 여부 점검
 - 로그아웃 시 서버가 기존 세션을 즉시 폐기(Invalidate)하는 기능이 적용되어 있는지 확인한다. 클라이언트 쿠키 삭제만으로 로그아웃 처리하는 취약 구조인지 여부를 확인한다.

그림 3-51 ▶ 세션 초기화 또는 만료 기능 적용 사례



🔍 실증 사례

표 3-44 ▶ 실증 사례

내용	
우수 사례	• 로그아웃 즉시 세션 무효화 - CBS에서 로그아웃을 수행하면 서버 측 세션이 즉시 종료되며, 세션 토큰이 더 이상 유효하지 않도록 무효화 처리가 적용된다. 이를 통해 세션 탈취(Session Hijacking) 위험을 최소화한다. • 로그인 시 새로운 세션 ID 발급 - 로그아웃 후 로그인하는 경우, 이전 세션 ID를 재사용하지 않고 항상 새로운 세션 ID를 생성하도록 설계되어 있다. 이를 통해 41)세션 고정 공격(Session Fixation)의 위험을 원천 차단하며 안전한 인증 절차를 확보하였다.

미흡 사례

- 세션 ID가 로그아웃 후에도 유효
 - 로그아웃을 수행해도 세션 ID가 서버 측에서 완전히 무효화 되지 않아, 동일 세션이 재사용될 위험이 존재한다. 세션 하이재킹 및 재사용 공격(Session Replay)에 악용될 가능성이 높다.
- 쿠키 삭제 누락
 - 로그아웃 시 클라이언트 측 쿠키가 삭제되지 않아 브라우저에 인증 정보가 잔존 한다. 동일 브라우저를 사용하는 사용자가 세션을 이어서 사용할 수 있어 계정 오남용 위험이 있다.
- 세션 재사용 가능
 - 로그아웃 이후에도 동일 세션 토큰을 사용해 접근이 가능한 상태로 확인되었다. 이는 인증 · 세션 관리 통제가 부재한 대표적인 취약점으로, 외부 공격자나 내부 사용자가 권한을 악의적으로 획득할 가능성이 존재한다.

❁ 개선 권고사항

- 강제 세션 무효화 적용
 - 로그아웃 시 서버 측에서 기존 세션을 즉시 무효화 설정하고, 클라이언트 쿠키 또한 자동 삭제되도록 프로세스를 강화한다.
- 로그아웃 프로세스 개선
 - 로그아웃 요청 시 세션 종료, 쿠키 삭제, 캐시 비우기 등이 일관되게 수행되도록 절차를 재정비하고 예외 상황(비정상 종료 등)에서도 동일한 세션이 폐기되도록 적용한다.
- 세션 의존 로그 정리
 - 세션별 접근 기록, 인증 이벤트 등 로그가 정확히 남도록 구성하고, 종료된 세션의 로그가 누락 되지 않도록 관리 체계를 강화한다.

41) 세션 고정 공격: 공격자가 미리 지정한 세션 ID를 피해자에게 사용하도록 유도해, 해당 세션을 가로채는 방식의 공격

4. 용어 정의

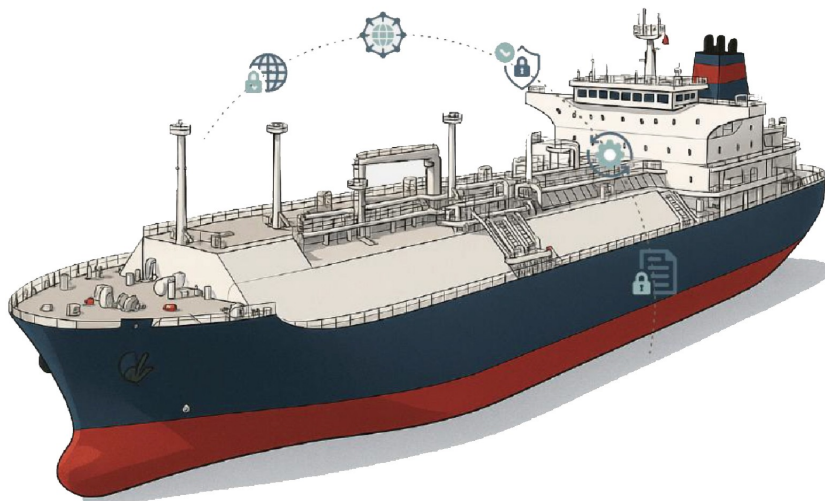
본 이행 가이드에서 사용되는 주요 용어의 정의는 다음과 같다. 이는 『스마트선박 보안모델』의 용어 정의를 기반으로 확장 및 보완되었다.

- **사이버 복원력 (Cyber Resilience)**: 사이버 위협으로 인한 역경에 대해 예측하고(Anticipate), 견디고(Withstand), 복구하고(Recover), 적응(Adapt)하는 능력. 시스템의 단순한 가용성을 넘어, 공격을 받더라도 필수 기능을 유지하고 신속하게 정상 상태로 돌아올 수 있는 총체적인 능력을 의미한다.
- **운영기술 (OT, Operational Technology)**: 물리적 프로세스를 직접 모니터링하거나 제어하는 하드웨어 및 소프트웨어. 스마트선박에서는 기관 제어 시스템(IAS), 항해 시스템(ECDIS, GPS), 화물 관리 시스템, 선박평형수 처리장치(BWTS) 등이 해당된다.
- **정보기술 (IT, Information Technology)**: 데이터의 저장, 검색, 전송 및 조작에 사용되는 시스템. 스마트선박에서는 선원 복지망, 선박 행정 시스템, 이메일 서버 등이 해당된다.
- **컴퓨터 기반 시스템 (CBS, Computer Based System)**: 선박 내에 설치된 프로그래밍 가능한 전자 장치 또는 그 집합으로, IT 및 OT 시스템을 포괄하는 개념이다. IACS 규정에서 주로 사용된다.
- **최소 권한의 원칙 (Principle of Least Privilege)**: 모든 사용자, 프로그램, 프로세스는 업무 수행에 필요한 최소한의 권한만 가져야 한다는 보안 원칙이다.
- **심층 방어 (Defense in Depth)**: 단일 보안 조치에 의존하지 않고, 여러 계층의 다양한 보안 대책(물리적, 기술적, 관리적)을 중첩하여 구성함으로써 하나의 방어선이 뚫리더라도 다음 방어선이 위협을 막을 수 있도록 하는 보안 전략이다.
- **보안 구역 (Security Zone)**: 공통된 보안 요구사항을 공유하는 자산들의 논리적 또는 물리적 그룹. 네트워크 분할을 통해 각 구역은 경계에서 통제된다.
- **위험 분석 및 위험 평가 (TARA, Threat Analysis and Risk Assessment)**: 특정 자산에 대한 잠재적 위협과 시스템의 내재적 취약점을 식별하고, 이를 통해 발생 가능한 위험의 수준(가능성 및 영향도)을 평가하는 체계적인 프로세스.
- **소프트웨어 자재 명세서 (SBOM, Software Bill of Materials)**: 소프트웨어를 구성하는 다양한 구성 요소(오픈소스 라이브러리, 모듈 등)의 목록과 정보를 담은 명세서. 공급망 보안을 강화하고 잠재적 취약점을 관리하는 데 사용된다.
- **복구 목표 시간 (RTO, Recovery Time Objective)**: 재해 또는 장애 발생 시, 업무 및 서비스를 복구하는 데까지 걸리는 목표 시간이다.
- **복구 목표 지점 (RPO, Recovery Point Objective)**: 재해 또는 장애 발생 시, 어느 시점의 데이터로 복구할 것인지를 결정하는 목표 지점. 즉, 최악의 경우 유실을 감내할 수 있는 데이터의 양(시간)을 의미한다.

참고 자료

1. 한국인터넷진흥원(KISA), 스마트선박 보안모델 (2025.02)
2. 국제해사기구(IMO), MSC.428(98) – Maritime Cyber Risk Management in Safety Management Systems
3. 국제선급연합회(IACS), UR E26 – Cyber resilience of ships (2023)
4. 국제선급연합회(IACS), UR E27 – Cyber resilience of on-board systems and equipment (2023)
5. 국제전기기술위원회(IEC), IEC 62443 Series – Security for industrial automation and control systems
6. 국제표준화기구(ISO), ISO/IEC 27001 – Information security management systems
7. 미국 국립표준기술연구소(NIST), Cybersecurity Framework Version 2.0
8. BIMCO, Guidelines on cyber security onboard ships V4 (2020)
9. 해양수산부, 해사 사이버안전 관리지침 (고시 제2024-52호)

(이상으로 스마트선박 사이버보안모델 해설서 및 사례집을 마칩니다. 본 문서가 승조원 및 보안/IT 엔지니어 분들께 실질적인 도움이 되기를 바랍니다.)



스마트선박 보안 모델 해설서 및 사례집

2026.01

[한국인터넷진흥원 나주본원]
(58324) 전라남도 나주시 진흥길 9
[서울청사]
(05717) 송파구중대로 135 (가락동), IT벤처타워